



Σavante

Seguridad de los Sistemas de Información. Infraestructura física de un CPD. Sistemas de gestión de incidencias. Control Remoto de puestos de Usuario

ÍNDICE

1. Conceptos de Seguridad de los Sistemas de Información	8
1.1. Principales términos de Seguridad Informática	9
1.1.1. Relaciones entre los conceptos	13
2. Riesgos. Seguridad física y lógica	15
2.1. Seguridad física	17
2.2. Seguridad lógica	19
2.2.1. Salvaguardas	20
2.2.2. Análisis de Riesgos	21
2.2.3. Esquemas de Arquitectura de Red	23
2.2.3.1. Esquema con zona neutra	24
2.2.4. Auditorías del sistema	24
2.2.4.1. Análisis Forense	25
2.2.4.2. Test de intrusión (Pen Test)	27
3. Amenazas y vulnerabilidades	28
3.1. Tipos de atacantes	28
3.2. Ciberataques	30
3.2.1. Clasificación de los ciberataques	31
3.2.1.1. Basados en la técnica	31
3.2.1.1.1. Ataques de explotación	31
3.2.1.1.2. Ataques de acceso	32
3.2.1.1.3. Ataques de ingeniería social	32
3.2.1.1.4. Ataques de denegación de servicio	33
3.2.1.1.5. Ataques de Malware	33
3.2.1.1.6. Ataques de Red	36
3.2.1.1.7. Ataques de canal lateral	39
3.2.1.1.8. Software de Riesgo	39
3.2.1.1.9. Otras vulnerabilidades	39
3.2.1.2. Basados en el Objetivo	39

3.2.2. Dinámica, Prevención y Futuro de los Ciberataques	40
3.2.2.1. La cadena del Ataque	40
3.2.2.2. Actores de las amenazas	40
3.2.2.3. Prevención y mitigación	40
3.2.2.4. Casos de estudio	40
3.2.2.5. Tendencias futuras	41
3.3. Vulnerabilidades	41
4. Técnicas criptograficas y protocolos seguros	44
4.1. Algoritmo criptográfico	46
4.1.1. Tipos de Algoritmos según su Cifrado	47
4.1.2. Tipos de Algoritmos según Uso de Claves	48
4.1.2.1. Criptografía Simétrica	49
4.1.2.2. Criptografía Asimétrica	53
4.1.2.3. Criptografía Hibrida	55
4.2. CCN-CERT	55
4.3. Mecanismos de firma digital	57
4.3.1. Algoritmos de Autenticación Hash	57
4.3.2. Formatos de firma digital	60
4.3.2.1. Estándares	60
4.3.2.2. Formatos Principales	61
4.4. Uso de protocolos	62
4.5. Certificados digitales	63
4.5.1. Concepto	63
4.5.2. Autoridades de Certificación	63
4.5.3. Funciones	63
4.5.4. Tipos: gratuito y de pago	64
4.5.5. Composición	64
4.5.6. Específicos o multipropósito	65
4.5.7. Proceso de obtención	65
4.5.8. Mantenimiento, renovación y revocación	65
4.5.9. Jerarquías de PSC	66

5. Single Sign-On	66
6. Infraestructura física de un CPD: acondicionamiento y equipamiento	67
6.1. El Estándar TIA 942	69
6.1.1. El concepto de TIER	70
6.1.2. Novedades en el cableado	73
6.1.3. Actualizaciones del Estándar TIA 942	73
6.2. Condiciones del edificio y de la sala	77
6.2.1. Situación y accesos	77
6.2.2. Dimensiones	77
6.2.3. Falso suelo	78
6.2.4. Iluminación	79
6.2.5. Acústica	79
6.2.6. Especificaciones ambientales	79
6.2.7. Contaminación y limpieza del aire	80
6.2.8. Sistema de protección contra incendios	80
6.3. Suministro eléctrico y tierras	81
6.3.1. Toma de tierra	81
6.3.2. Acometida eléctrica	82
6.3.2.1. SAI	82
6.3.3. Cuadro eléctrico y circuitos internos	83
6.3.4. Interferencias electromagnéticas	84
6.3.5. Compatibilidad electromagnética	84
6.4. Recomendaciones en el uso de la sala	84
6.5. Seguridad de los equipos y de la información	85
7. Sistemas de gestión de incidencias	86
7.1. ITIL	90
7.1.1. Help Desk	92
7.1.2. Service Desk	95
7.1.3. Actividades principales de la Gestión de Incidencias según ITIL	95
7.1.4. Definición del Ciclo de vida por ITIL	98

7.2. ITSM. Gestión de servicios de Tecnologías de la Información	99
7.2.1. Gobernanza de las Tecnologías de la Información	102
7.3. Gestion de problemas	104
7.3.1. Gestión de incidentes frente a gestión de problemas	105
7.3.2. Gestión de problemas reactiva frente a gestión de problemas proactiva	107
7.3.3. Beneficios de la gestión de problemas de TI	108
7.3.4. Roles y responsabilidades de la gestión de problemas de TI	109
7.3.5. Flujo del proceso de gestión de problemas de TI	109
7.3.6. Relación entre la gestión de problemas y los procesos de ITIL	112
7.3.7. Cinco pasos del análisis de problemas	115
7.3.7.1. Definir el problema	115
7.3.7.2. Describir el problema	116
7.3.7.3. Establecer las posibles causas	116
7.3.7.4. Probar la causa más probable	117
7.3.7.5. Comprobar la verdadera causa	118
7.3.8. Técnicas de gestión de problemas de TI utilizadas en ITIL	118
7.3.8.1. Brainstorming (Tormenta de ideas)	118
7.3.8.2. Método Kepner-Tregoe	119
7.3.8.3. Análisis de Ishikawa, o análisis de diagrama de causa y efecto	119
7.3.8.4. Análisis de Pareto	121
7.3.8.5. Técnica de los 5 porqués	122
7.3.8.6. Otras técnicas	123
7.3.9. Mejores prácticas de la gestión de problemas de TI	124
7.3.10. Indicadores clave de rendimiento para la gestión de problemas de TI	125
7.3.11. Mejores funciones para el software de gestión de problemas	126
7.3.12. Resumen	127
7.4. Herramientas de Ticketing	128
7.4.1. Ejemplos de Herramientas de Ticketing	130
7.4.2. GLPI	135
7.4.2.1. Principales características de la versión GLPI 9.4	136

7.5. TIC. Las TIC en la educación	138
7.5.1. Las claves del uso de las TIC en el aula	140
7.5.2. Impacto de las TIC en la sociedad	141
7.5.3. La Gestión de Servicios de TIC en la universidad	141
8. Control remoto de puestos de usuario	143
8.1. Conceptos previos	144
8.1.1. Fabricas OEM O ODM	144
8.1.2. Administración fuera de banda o en banda	147
8.1.3. Interfaz de gestión de plataforma inteligente (IPMI)	151
8.2. Servicio de acceso remoto	157
8.2.1. Modo terminal	157
8.2.1.1. Telnet	158
8.2.1.2. SSH	163
8.2.2. Modo gráfico	164
8.2.2.1. Escritorio remoto de Google Chrome	165
8.2.2.1.1. Configuraciones	165
8.2.2.2. Escritorio remoto de Windows 10	167
8.2.2.2.1. Configurar el PC para que acepte conexiones remotas	168
8.2.2.2.2. Conectarte de forma remota al ordenador	170
8.2.2.3. Apple Remote Desktop	170
8.2.2.4. TeamViewer	171
8.2.2.5. SupRemo	171
8.2.2.6. Ammyy Admin	172
8.2.2.7. Iperius remote	172
8.2.2.8. AnyDesk	173
8.2.2.9. VNC Connect	173
8.3. Tecnología Wake On Lan	173
8.3.1. Funcionamiento	175
8.3.2. Cómo realizar el arranque	178
8.3.3. Herramientas de software para Wake On Lan	179

8.4. Intel AMT/vPro	182
8.4.1. Funciones y tareas de administración de AMT	185
8.4.2. Aplicaciones	186
8.4.3. Aprovisionamiento e integración	189
8.4.4. Comunicación	191
8.4.5. Diseño	192
8.4.6. Seguridad	194
8.4.7. Redes	195
8.4.8. Evitación y mitigación	198
8.4.9. Configuración de un cliente Intel AMT	199
8.5. Entorno PXE	201
8.5.1. Protocolo PXE	202
9. Bibliografía	204



1. Conceptos de Seguridad de los Sistemas de Información

Ya has estudiado en unidades anteriores la importancia de la seguridad de la información.

Vamos a realizar un breve resumen como repaso y a ampliar conocimientos sobre el tema.

Recordemos que la seguridad de la información se articula sobre tres dimensiones, que están reguladas según el estándar ISO/IEC 27002: "La seguridad de la información se puede caracterizar por la preservación de":

- **Disponibilidad de la información:** "Asegura que los usuarios autorizados pueden acceder a la información cuando la necesitan".
- **Integridad de la información:** "salvaguarda la precisión y completitud de la información y sus métodos de proceso".

(Que la información sea correcta y esté libre de modificaciones y errores. La información ha podido ser alterada (posiblemente de forma intencionada) o ser incorrecta).

- **Confidencialidad de la información:** "asegura que el acceso a la información está adecuadamente autorizado".

(La información debe ser accesible únicamente por el personal autorizado: *need-to-know*). Ejemplos de falta de confidencialidad son: robo o divulgación de información sin autorización, acceso de un empleado a carpetas a las que no debería tener acceso etc.

Estos son los 3 pilares sobre los que aplicar las medidas de protección de nuestra información:
disponibilidad, integridad y confidencialidad.

No repudio

Algunos estándares añaden un objetivo más denominado **no repudio**. Este objetivo garantiza la participación de las partes en una comunicación.

En toda comunicación existe un emisor y un receptor, por lo que podemos distinguir dos tipos de no repudio:

- **No repudio en origen:** garantiza que la persona que envía el mensaje no puede negar que es el emisor del mensaje ni que lo ha enviado. El receptor tendrá pruebas del ello.
- **No repudio en destino:** el receptor no puede negar que recibió el mensaje. El emisor tendrá pruebas de la recepción del mensaje.

Este servicio es muy importante en las transacciones comerciales por Internet y en temas legales.



Recuerda ver las clases emitidas en Temario Audiovisual

Las clases impartidas en directo y disponibles en Campus, en Temario Audiovisual, te ayudarán al entendimiento de la unidad, y además pueden tener información adicional.

[ACCEDE DIRECTAMENTE DESDE AQUÍ](#)

1.1. Principales términos de Seguridad Informática

Existen varios términos que suelen confundirse entre sí y que no están demasiado claros. Distintos autores los definen de distintas formas e incluso utilizan solo algunos de los términos.

Vamos a intentar darte una visión clara de estos elementos con gráficos y un ejemplo para que puedas entenderlo, ya que puede ser un poco lioso.

Términos que vamos a analizar:

- Activo.
- Criticidad.
- Vulnerabilidad.
- Amenaza.
- Ataque.
- Impacto.
- Probabilidad.
- Nivel de riesgo.

Activo

Son los bienes que hay que proteger. Por ejemplo:

- **Personas:** usuarios, programadores, administradores, etcétera.
- **Hardware:** equipos, infraestructura de red, periféricos, elementos de interconexión, unidades de almacenamiento externo, etcétera.



- **Software:** software base (incluye SO), programas de aplicación, software de seguridad y comunicaciones, etcétera.
- **Información:**
 - Datos.
 - Documentación.
 - Código.
 - Etcétera.

Criticidad

Es la importancia que tiene un recurso para el funcionamiento del sistema.

Vulnerabilidad

Una vulnerabilidad es un estado o característica de un activo que permite la consecución de ataques que comprometan la confidencialidad, integridad o disponibilidad de ese mismo activo o de otros activos de la organización.

Son las deficiencias de un activo que pueden ser explotadas por amenazas.



Ejemplo

Ejemplos de vulnerabilidades:

- Falta de conocimientos del usuario.
- Falta de medidas de seguridad.
- Mala elección de contraseñas.
- Inexistencia de medidas contra incendios.



Amenaza

Es todo elemento o acción capaz de atentar contra la seguridad del sistema de información. Las amenazas surgen a partir de la existencia de vulnerabilidades.

Una amenaza solamente puede existir si existe una vulnerabilidad que pueda ser aprovechada. La amenaza es la posibilidad de que alguien pueda explotar la vulnerabilidad.

Pueden clasificarse en dos tipos:

- **Intencionadas:** se intenta producir un daño deliberadamente.
- **No intencionadas:** se producen por omisiones o acciones que no buscan explotar la vulnerabilidad, pero que ponen en riesgo los activos y pueden producir un daño.



Ejemplo

Ejemplos de amenazas **no intencionadas**:

- Desconocimiento (mala formación).
- Fallo de un equipo.
- Desastres naturales.

Ejemplos de amenazas **intencionadas**:

- Robo.
- Fraude mediante técnicas de ingeniería social.

Ataque

Un ataque informático o ciberataque es un método por el cual un individuo, mediante un sistema informático, intenta tomar el control, desestabilizar o dañar otro sistema informático.

Un ataque intenta explotar o aprovechar una vulnerabilidad del sistema para conseguir un comportamiento no deseado del sistema.

Para realizar el ataque se puede utilizar un fragmento de *software*, un fragmento de datos o una secuencia de comandos o acciones.



Ejemplo

Un virus es un ejemplo de ataque informático.

Impacto

Hace referencia a la magnitud de las consecuencias que tiene para el sistema el hecho de que uno o varios activos hayan visto comprometida su confidencialidad, integridad o disponibilidad, debido a que una o varias amenazas hayan explotado las vulnerabilidades de estos u otros activos.



Ejemplo

Ejemplos de impacto:

- Pérdida directa de dinero.
- Sanción por violar la legislación.
- Daño a la imagen de la empresa.
- Daño a personas.
- Reducción de la eficacia del sistema.
- Interrupción de la actividad.

Probabilidad

Es la probabilidad de que una amenaza pueda explotar una vulnerabilidad de los activos. De esta probabilidad dependerá la frecuencia con la que se materializan las amenazas.

$$\text{Probabilidad} = \text{Amenaza} \times \text{Vulnerabilidad}$$



Nivel de riesgo

Es la probabilidad de que el sistema se vea sometido a un determinado nivel de impacto (determinado a su vez por las consecuencias de la agresión).

Su estimación se basa en la combinación de dos factores:

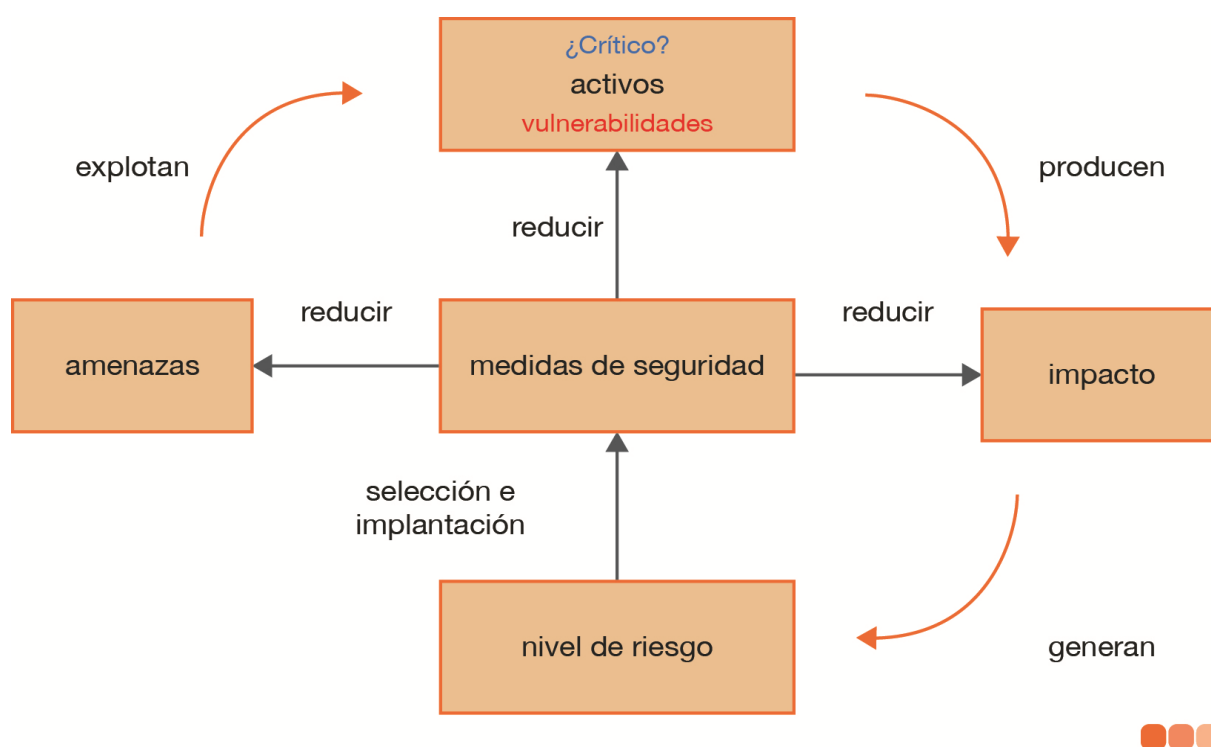
- La frecuencia con la que se materializan las amenazas (probabilidad de que las amenazas exploten las vulnerabilidades de los activos).
- Nivel de impacto causado en el sistema en caso de que las amenazas consideradas se hagan efectivas.

Resumiendo:

$$\text{Nivel de riesgo} = \text{Amenaza} \times \text{Vulnerabilidad} \times \text{Impacto} = \text{Probabilidad} \times \text{Impacto}$$

1.1.1. Relaciones entre los conceptos

Vamos a ver, de forma simplificada y de un solo vistazo, cómo se relacionan estos conceptos.





Ejemplo

Para terminar de verlo claro, vamos a aplicar los conceptos a un caso del mundo real:

Thiago Alcántara es un jugador que ha sufrido lesiones en su rodilla izquierda. Imaginemos que juega un partido con la selección española contra Portugal.

- **Activo:** Thiago Alcántara.
- **Vulnerabilidad:** rodilla izquierda.
- **Amenazas:** entradas de jugadores rivales, estado del césped, etcétera.
- **Ataque:** un jugador lucha con él por un balón y le golpea en la rodilla izquierda.
- **Impacto:** daño provocado por el golpe.
 - **Bajo:** un ligero dolor que se pasa al poco tiempo.
 - **Medio:** cae al suelo y tiene molestias durante parte del partido.
 - **Alto:** cae lesionado y tiene que retirarse del partido.
- **Probabilidad:** depende de la amenaza y la vulnerabilidad. Es la probabilidad de que se produzca el ataque.

Puede aumentar o disminuir en función de diversos factores:

- La entrada la producen varios jugadores al mismo tiempo (aumenta la amenaza).
- El jugador conoce la vulnerabilidad (aumenta la amenaza).
- El jugador es Pepe (aumenta mucho la amenaza).
- Ya ha recibido otros golpes en la rodilla y la tiene dolorida (aumenta la vulnerabilidad).
- **Nivel de riesgo:** es el grado de exposición. Depende de la probabilidad de que se produzca el ataque (reciba un golpe) y el daño que le pueden hacer (impacto).
- **Criticidad:** es la importancia que tiene el jugador para el equipo.

Podría ser baja porque tenemos buenos suplentes. Sin embargo, si se han realizado los tres cambios, podría ser un activo crítico.



2. Riesgos. Seguridad física y lógica

Un sistema informático puede interrumpirse (dejar de funcionar) por diferentes motivos, y también variará la repercusión de la interrupción sobre la empresa, organismo etc.

Las interrupciones se pueden dar por causas muy variadas:

- Virus informáticos, hackers...
- Fallos de electricidad; picos de tensión, corte de suministro...
- Fallos de hardware y software, caídas del sistema de red...
- Errores humanos...
- Incendios, inundaciones, etc.

Aunque es imposible prevenir cada una de las posibles interrupciones, una empresa, sí puede y debe prepararse para evitar las consecuencias que éstas puedan ocasionarles.

Del tiempo que tarde la empresa en reaccionar dependerá la gravedad de sus consecuencias.

Podemos diferenciar en tres enfoques las medidas para controlar la seguridad:

- **Proactivas o preventivas:**

Contribuyen a prevenir que se materialicen los riesgos.

Protegen a los activos antes de que estos sufran ataques.

Ejemplos:

- Política de seguridad.
- Formación de usuarios.
- Controles de acceso.
- Cifrado de la información.

- **Detectivas:**

Contribuyen a reducir o evitar el impacto al proteger a los activos en el momento en el que sufren el ataque.

Ejemplos:

- Registro de *logs*.
- Sistemas integrados de auditoría.
- Sistemas de detección de intrusos (IDS).



- **Reactivas, correctivas o curativas:**

Contribuyen a eliminar o reducir el impacto negativo de la materialización de una amenaza (en otras palabras, *curan* a los activos después de que hayan sufrido el ataque).

Ejemplos:

- Copias de seguridad.
- Plan de contingencias.

Para aumentar la seguridad de un sistema informático, se pueden utilizar medidas de control físicas y lógicas.



+ Info

CERT y CSIRT

CERT, siglas del inglés Computer Emergency Response Team (Equipo de Respuesta ante Emergencias Informáticas).

El CERT es la entidad superior que soluciona problemas generalizados de ciberseguridad y desarrolla métodos y herramientas.

CSIRT siglas del inglés Computer Security Incident Response Team, (Equipo de Respuesta ante Incidencias de Seguridad Informáticas).

Los CSIRT despliegan actividades de preparación, planeación, detección y respuesta a todos los eventos que afecten los activos críticos de una entidad privada o pública.

Los CSIRT están constituidos por una entidad organizativa, privada o pública, a la que se asigna una responsabilidad de coordinar y respaldar la respuesta a un evento o incidente de seguridad informática, y el CERT es el aliado o socio de un gobierno o industria.



2.1. Seguridad física

Normalmente nos centramos en proteger el sistema informático contra ataques de *hackers*, virus, etcétera, y no prestamos atención a un aspecto importante de la seguridad informática: la seguridad física.

La seguridad física es aquella que trata de proteger el sistema de:

- De incendios.
- Inundaciones por rotura de tuberías o similar.
- Robos.
- Afecciones Eléctricas.
- Desastres naturales (terremotos, inundaciones por lluvia, desbordamiento de ríos, etcétera).
- Etcétera.

A continuación, vamos a ver con más detalle estas principales amenazas y los mecanismos para protegernos de las mismas.

Incendios

- El mobiliario de los centros que contengan datos o equipamiento crítico (almacén de copias de seguridad, etcétera) debe ser ignífugo.
- No se debe colocar el CPD (centro de procesamiento de datos) cerca de zonas donde se manejen o almacenen sustancias inflamables o explosivos.
- Deben existir sistemas antiincendios para sofocar el incendio en el menor tiempo posible y evitar daños a personas o materiales.
 - Detectores de humo.
 - Rociadores de gas.
 - Extintores.
 - Señalización de salida de incendios.
 - Políticas de emergencia ante incendios.
 - Simulaciones de incendios.



Inundaciones

- No ubicar los centros de cálculo en plantas bajas o sótanos que puedan inundarse por la entrada de aguas superficiales.
- Impermeabilizar las paredes y techos del CPD.
- Sellar las puertas para evitar la entrada de agua.

Robos

- Proteger los centros de cálculo y CPD para evitar la entrada de personal no autorizado mediante:
 - Puertas con medidas biométricas:
 - » Sensor de huella dactilar.
 - » Reconocimiento facial.
 - » Etcétera.
 - Cámaras de seguridad.
 - Vigilantes jurados.
 - Etcétera.
- Utilizar controles de acceso a las oficinas mediante tarjetas, claves o medidas biométricas.
- Eliminar medios de entrada/salida: quitar físicamente elementos como como disqueteras (ya en desuso, y lectores de cdroms y/o DVD, y configurar en la BIOS los puertos USB como deshabilitados (la BIOS estará por tanto protegida por contraseña), para evitar posibles infecciones con virus traídos desde el exterior de la empresa por el personal, o la extracción de información de la empresa.

Afecciones Eléctricas

El suministro eléctrico puede provocar diferentes problemas en nuestros equipos, que son y pueden prevenirse de diferentes formas:

- **Señales electromagnéticas:**
 - Evitar la ubicación de los centros de cálculo cerca de lugares con gran radiación de señales electromagnéticas. Estas pueden interferir en el correcto funcionamiento de los equipos informáticos y del cableado de red y de las comunicaciones inalámbricas.



- Si no se puede evitar dicha ubicación, se debe proteger el centro de cálculo de las emisiones mediante:
 - » Filtros.
 - » Cableado especial.
 - » Fibra óptica.
- **Corte del suministro eléctrico:**
 - Debemos utilizar sistemas de alimentación ininterrumpida (SAI) que proporcionen electricidad durante un tiempo suficiente, al menos, para poder apagar los sistemas de forma no forzada.
- **Sobrecargas eléctricas:**
 - La mayoría de SAI protegen contra sobrecargas eléctricas.
 - Dotar a la red eléctrica del edificio con enchufes conectados a un SAI central.
 - Utilizar regletas con filtros que protegen de los picos de tensión.

Desastres naturales

- Informarse diariamente sobre movimientos sísmicos, meteorología, etcétera, en el lugar donde esté ubicado (en nuestro caso, España).
- Consultar diariamente la información ofrecida por el Instituto Geográfico Nacional y la Agencia Estatal de Meteorología sobre movimientos sísmicos, meteorología, etcétera, en España.

2.2. Seguridad lógica

Podemos realizar diferentes actuaciones para mejorar la seguridad de la información.

Las principales actuaciones a seguir son:

- Identificar los activos que queremos proteger.
(Activo: componente de un sistema de información susceptible de ser atacado).
- Formación de los trabajadores en materia de seguridad.
- Concienciar a los trabajadores de la importancia de la seguridad informática.
- Analizar y evaluar los riesgos, considerando:
 - Vulnerabilidades del sistema.
 - Amenazas.
 - Impacto sobre los activos de un ataque.



- Diseñar el plan de actuación, que debe incluir:
 - Plan de prevención: medidas que traten de prevenir los daños minimizando la existencia de vulnerabilidades.
 - Plan de contingencia: medidas que traten de minimizar el impacto de los daños ya producidos.
- Mejorar la arquitectura de red.
- Revisar periódicamente las medidas de seguridad adoptadas.

2.2.1. Salvaguardas

Los sistemas RAID, ayudan a evitar pérdidas de información sin tener que apagar el ordenador, pero no evita tener que realizar copias de seguridad.

Las copias de seguridad son uno de los elementos más importantes y que requieren mayor atención a la hora de definir las medidas de seguridad del sistema de información, la misión de las mismas es la recuperación de los ficheros al estado inmediatamente anterior al momento de realización de la copia.

Vamos a recordar algunas de las conocidas "Leyes de Murphy", relacionadas con la informática:

- Si un archivo puede borrarse, se borrará.
- Si dos archivos pueden borrarse, se borrará el más importante.
- Si tenemos una copia de seguridad, no estará lo suficientemente actualizada.

Debemos tener copias de seguridad, actualizarlas con frecuencia (confiar en que no deban usarse).



Recuerda

Entendemos por salvaguarda a las políticas, procedimientos, normas, procesos, contramedidas, controles o mecanismos que contribuyen a:

- Reducir las vulnerabilidades de los activos.
- Reducir la probabilidad de que las amenazas puedan explotar vulnerabilidades.
- Reducir el impacto producido en el negocio por la materialización de amenazas.

Las salvaguardas se miden basándose en dos factores: coste de adquisición y la dificultad de implantación.



2.2.2. Análisis de Riesgos

Un análisis de riesgos es un procedimiento de ayuda a la decisión. Sus resultados constituyen una guía para poder tomar decisiones sobre:

- Necesidad de modificar los mecanismos de seguridad.
- Necesidad de implantar nuevos mecanismos de seguridad.
- Especificar qué controles o procesos de seguridad serán los más adecuados.

Una vez conocidos los riesgos, podemos decidir qué medidas tomar. Para ello estudiaremos:

- Los costes de la implantación de controles que reduzcan los riesgos.
- Los costes derivados de las consecuencias de la materialización de estos riesgos.
- Comparamos los costes (vemos si cuesta más prevenir o curar).

Basándonos en este estudio podemos tomar una de las siguientes medidas:

- Disminuir el riesgo mediante la implantación y mantenimiento de controles de seguridad que minimicen estos riesgos y los mantengan a un nivel aceptable.
- Asumir ciertos riesgos a los que está expuesta la organización. Esto lo hacemos cuando las consecuencias acarreen un coste económico y estratégico menor que el coste necesario para reducir dichos riesgos.
- Transferir estos riesgos:
 - Contratando los servicios de una empresa especializada.
 - Contratando una póliza de seguros.



+ Info

El nivel de riesgo al que está sometida una organización nunca puede eliminarse completamente.

Se trata de buscar un equilibrio entre los recursos dedicados a minimizar riesgos y el nivel de riesgo aceptable.



El análisis de riesgos es un procedimiento sistemático en el que se necesitan realizar determinadas tareas y estimaciones de forma totalmente imparcial y objetiva:

- Inventariar los activos e identificar las amenazas que existen sobre ellos.
- Identificar las vulnerabilidades presentes en los activos.
- Estimación de la probabilidad con la que las amenazas pueden explotar las vulnerabilidades de los activos.
- Estimación del impacto en el negocio en caso de que ciertas amenazas se hagan efectivas.
- Estimación de:
 - Si se puede asumir el riesgo.
 - Si es necesario invertir en la implantación o actualización de controles de seguridad.
 - Si se puede transferir el riesgo a terceras partes.

Si estos factores no se evalúan con total imparcialidad y objetividad, el análisis de riesgos no nos servirá para tomar decisiones sobre la seguridad de nuestros activos.

Hay que dividir el análisis de riesgos en dos partes:

- **Análisis de riesgos cuantitativo:**

Las métricas asociadas al impacto causado por la materialización de las amenazas se valoran en cifras concretas de forma objetiva.

Un modelo cuantitativo habitual es aquel en el que las consecuencias de la materialización de amenazas se asocian a un determinado nivel de impacto en función de la estimación del coste económico que suponen para la organización.

- **Análisis de riesgos cualitativo:**

Las métricas asociadas al impacto causado por la materialización de las amenazas se valoran en términos subjetivos (muy alto, alto, medio, bajo o muy bajo).

Las consecuencias de la materialización de amenazas se asocian a un determinado nivel de impacto en función de multitud de factores:

- Pérdidas económicas.
- Pérdida de conocimiento.
- Pérdida de competitividad.
- Interrupción de la actividad.
- Daño a la imagen.
- Etcétera.



Basándonos en este análisis y en la evaluación de los riesgos, se creará una relación de riesgos priorizados.

Esta relación nos ayudará a tomar las decisiones necesarias para:

- La planificación de la implantación de controles.
- La asignación de recursos.
- Implantar un proceso general de gestión de riesgos.
- Establecer el nivel de riesgo aceptable.
- Realizar una declaración de aplicabilidad (SoA).
- Seleccionar controles.
- Implantar controles.
- Verificar controles.



+ Info

SoA es un documento que enlista los controles de seguridad establecidos en el estándar ISO/IEC 27001 (anexo A).

Se utiliza para:

- Implementar medidas de protección de la información.
- Comprobar si no se han considerado algunas medidas de seguridad necesarias.

Un SoA no está limitado a los controles que se encuentran listados en el anexo. Se pueden utilizar otros controles que estimemos oportunos.

2.2.3. Esquemas de Arquitectura de Red

Uno de los aspectos básicos de la seguridad en la red es su arquitectura. En el diseño de la arquitectura de red utilizamos determinados componentes que nos permitan canalizar, permitir o restringir el tráfico de la información.



Hay tres elementos básicos para aumentar la seguridad:

- **Uso de enrutadores:** conecta dos o más redes y permite o deniega la comunicación entre redes.
- **División de la red interna:** para aumentar la seguridad se puede dividir la red interna en varias redes para controlar (permitir o denegar) el tráfico entre ellas.
- **Establecer una zona desmilitarizada** (protección perimetral). Red ubicada entre dos redes para proteger una de ellas. En esta red suelen estar ubicados los servidores de la empresa. Por ejemplo, el CNN-CERT aconseja tener en ellos los servidores de correo corporativo. De esta forma, si hay una intrusión en uno de los servidores, la red interna estará aislada y no se le permitirá el acceso.

A continuación, vamos a ver algunos ejemplos de esquemas de red sencillos. La elección de uno u otro dependerá de las necesidades de la organización.

2.2.3.1. Esquema con zona neutra

Como ya viste en la Unidad 3, uno de los esquemas de seguridad más sencillos, pero efectivos, es el de Red con zona neutra o "desmilitarizada".

En el más básico utilizamos dos enrutadores que nos permiten crear un perímetro de seguridad en la que ubicar los servidores accesibles desde el exterior. Es más común verlo en entornos medios y grandes, por la elevada complejidad de configuración y superior coste.

El de Zona neutra con red interna y un solo enrutador con tres conexiones, a la zona neutra, a internet, y a la red interna, es más económico y fácil de mantener, pero menos seguro.

A partir de aquí podemos ver redes con más de una zona neutra y con dos o más redes internas, según el tamaño y complejidad de la empresa.

Pero lo que es imprescindible, es la correcta programación, actualización y mantenimiento de los enrutadores. Si quedan huecos de seguridad nuestra red interna se puede ver fácilmente comprometida.

2.2.4. Auditorías del sistema



Fuente:
<https://pxhere.com/es/photo/1446123>



Una vez establecidas las medidas de seguridad necesarias en nuestros sistemas, se debería realizar una auditoría de seguridad de la plataforma completa para verificar que se cumple la política de seguridad. Esta auditoría del sistema debería repetirse periódicamente.

Una de sus herramientas es el Análisis Forense.

2.2.4.1. Análisis Forense

El análisis forense se refiere a una investigación detallada para detectar y documentar el curso, los motivos, los culpables y las consecuencias de un incidente de seguridad o violación de las reglas de la organización o las leyes estatales.

El análisis forense a menudo se vincula con pruebas para los tribunales, particularmente en asuntos penales. Implica el uso de una amplia gama de tecnologías y métodos y procedimientos de investigación. Los especialistas forenses recopilan diferentes tipos de información trabajando con dispositivos electrónicos y también trabajando de manera convencional con la información en papel.

El proceso se puede dividir, por ejemplo, en seis etapas:

1. Disponibilidad

La preparación forense es una etapa importante y ocasionalmente pasada por alto en el proceso. En informática forense comercial, podría incluir educar a los clientes sobre la preparación del sistema. Por ejemplo, los análisis forenses ofrecen evidencia más sólida cuando las funciones de auditoría de un dispositivo están activadas previamente a que suceda un incidente.

Para el examinador forense, la preparación incluye capacitación, pruebas y verificación apropiadas de su propio software y equipo.

Estos analistas deben conocer la legislación, saber cómo hacer frente a problemas inesperados (qué hacer si durante el análisis de un fraude encuentran imágenes de abuso infantil) y garantizar la adecuación para esa tarea de su ordenador de adquisición de datos y los elementos asociados.

2. Evaluación

Durante la etapa de evaluación, el examinador recibe instrucciones y busca aclaraciones si alguna de ellas no es clara o ambigua, realiza un análisis de riesgos y asigna roles y recursos.

Para la aplicación de la ley, el análisis de riesgos puede incluir la evaluación de la probabilidad de una amenaza física al ingresar a la propiedad de un sospechoso y la mejor manera de lidiar con ella.

Las organizaciones comerciales también deben tener en cuenta los problemas de salud y seguridad, los conflictos de intereses y los posibles riesgos, financieros y para su reputación, cuando aceptan un proyecto en particular.



3. Colección

Si la adquisición de datos se lleva a cabo en el sitio en lugar de en la oficina del examinador forense del ordenador, esta etapa incluye la identificación y protección de dispositivos que pueden almacenar evidencia y documentar la escena.

El examinador también mantendría entrevistas o reuniones con el personal que podría tener información relevante para el examen, como los usuarios finales del ordenador, el gerente y la persona responsable de los servicios informáticos, es decir, un administrador de TI.

La etapa de recolección también puede involucrar el etiquetado de artículos del sitio que pueden usarse en la investigación; estos se sellan en bolsas numeradas a prueba de manipulaciones. Luego, el material debe transportarse de manera segura a la oficina del examinador o al laboratorio.

4. Análisis

El análisis incluye el descubrimiento y la extracción de información recopilada en la etapa de recopilación. El tipo de análisis depende de las necesidades de cada caso. Puede ir desde separar un solo correo electrónico hasta reunir las dificultades en un supuesto de fraude o terrorismo.

Durante el análisis, el examinador generalmente retroalimenta a su gerente de línea o cliente. Estos intercambios pueden hacer que el análisis tome un camino diferente o se reduzca a áreas específicas.

El análisis forense debe ser preciso, exhaustivo, imparcial, registrado, repetible y completado dentro de los plazos disponibles y los recursos asignados.

Existen múltiples herramientas disponibles para el análisis forense informático. El analista debe utilizar cualquier herramienta con la que se encuentre cómodo, pero siempre justificando su preferencia. Una herramienta forense de computadora debe hacer lo que debe hacer, por lo que los examinadores deben probar y calibrar sus herramientas regularmente antes de realizar cualquier análisis.

Los examinadores también pueden usar la «verificación de doble herramienta» para confirmar la integridad de sus resultados durante el análisis. Por ejemplo, si el examinador encuentra el artefacto X en la ubicación Y utilizando la herramienta A, debería poder replicar estos resultados con la herramienta B.

5. Presentación

En esta etapa, el examinador produce un informe estructurado sobre sus hallazgos, abordando los puntos en las instrucciones iniciales, junto con cualquier otra instrucción que hayan recibido. El informe también debe cubrir cualquier otra información que el examinador considere relevante para la investigación.

El informe debe ser escrito con el lector final en mente. A menudo, el lector no será técnico, por lo que se debe utilizar la terminología adecuada. El examinador puede necesitar participar en reuniones o llamadas en conferencia para discutir y elaborar su informe.



6. Revisión

Al igual que en la etapa de preparación, la revisión a menudo se pasa por alto o se ignora, porque no es un trabajo facturable o porque el examinador necesita continuar con el próximo trabajo. Pero llevar a cabo una revisión de cada examen puede hacer que los proyectos futuros sean más eficientes y eficaces en el tiempo, lo que ahorra dinero y mejora la calidad a largo plazo.

La revisión de un examen puede ser simple, rápida y comenzar durante cualquiera de las etapas anteriores. Podría incluir un análisis básico de lo que salió mal y lo que salió bien, junto con los comentarios de la persona o empresa que solicitó la investigación. Cualquier lección aprendida de esta etapa debe aplicarse a futuros exámenes y alimentarse en la etapa de Preparación.



Recomendación de Estudio

Aconsejamos que visites la siguiente web oficial del Cuerpo Nacional de Ingenieros Peritos Judiciales para completar el estudio:

[Análisis Forense Tecnológico](#)

2.2.4.2. Test de intrusión (Pen Test)

Llamado también prueba de penetración, es una simulación de ataque a un sistema informático para encontrar las debilidades de seguridad. Se determina el nivel de seguridad del sistema y el grado de acceso que tiene un atacante con intenciones maliciosas.

Hay diferentes tipos de enfoque al realizar es Pen Test, que son:

- **Caja Negra (Black-box):** En este enfoque, el evaluador carece de cualquier información sobre el sistema que va a analizar. Normalmente, se contrata a un tercero para realizar esta prueba, quien no tiene ninguna relación previa con el sistema.
- **Caja Blanca (White-box):** En este caso, el evaluador posee un conocimiento exhaustivo sobre el funcionamiento y las características del sistema, así como de su arquitectura de red, sistemas operativos y software utilizados.
- **Caja Gris (Gray-box):** Este enfoque simula la perspectiva de un empleado interno de la organización que cuenta con información limitada (por ejemplo, un nombre de usuario y contraseña de un sistema), pero sin permisos elevados. El propósito de este tipo de prueba es identificar vulnerabilidades que puedan permitir la escalada de privilegios por parte de esos usuarios.



3. Amenazas y vulnerabilidades

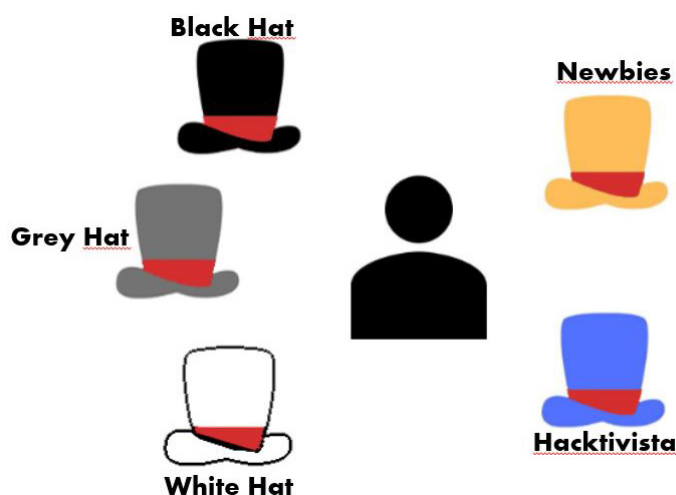
Un sistema informático se ve expuesto a un gran número de amenazas y ataques, que aprovechan las vulnerabilidades de los sistemas para hacer acciones perjudiciales en dichos sistemas.

Los principales ataques que sufre un sistema aprovechando sus vulnerabilidades son:

- **Interrupción:** un recurso del sistema o la red deja de estar disponible debido a un ataque.
- **Intercepción:** un intruso accede a la información de nuestro equipo o a la que enviamos por la red.
- **Modificación:** la información ha sido modificada sin autorización, por lo que ya no es válida.
- **Fabricación:** se crea un producto (por ejemplo, una página web) difícil de distinguir del auténtico y que se utiliza para suplantar un organismo o empresa y solicitar información confidencial al usuario.

3.1. Tipos de atacantes

Existen muchos tipos de atacantes, y además a medida que aumenta el desarrollo en la informática y comunicaciones, aumenta también el tipo de atacantes y su forma de actuar.



Vamos a nombrar los más destacados:

- **Hackers:**

Son expertos informáticos, cuya motivación principal es el reto de descubrir las vulnerabilidades de los sistemas informáticos ajenos, e introducirse en ellos, aunque luego hagan o no algo dañino, su satisfacción ya es lograr entrar en el sistema.



Tipos de Hackers:

- **Black Hat Hacker:**

También llamados Ciberdelincuentes, acceden a los sistemas con el objetivo de infringir daños, obtener acceso a información financiera, datos personales, contraseñas e introducir virus.

Dentro de esta clasificación existen dos tipos:

- » **Crackers:** Es un hacker que, además de romper la seguridad de un sistema y entrar en él, lo hace con fines ilícitos, para dañarlo o para obtener un beneficio económico. Modifican softwares, crean malwares, colapsan servidores e infectan las redes.
- » **Phreakers:** actúan en el ámbito de las telecomunicaciones (crackers telefónicos), sabotean las redes de telefonía, para usar o abusar de teléfonos ajenos consiguiendo llamadas gratuitas.

- **White Hat Hacker:**

También denominados Hackers éticos, se dedican a la investigación y notifican vulnerabilidades o fallos en los sistemas de seguridad.

- **Grey Hat Hacker:**

Prestan sus servicios a diferentes tipos de organismos, tanto grandes empresas como gobiernos o agencias de inteligencia, por lo que su ética varía según el momento de su trabajo. Por ejemplo, se les puede encargar simplemente divulgar una determinada información.

- **Newbies:**

Hackers novatos, que no tienen mucha experiencia ni conocimientos, se acaban de iniciar en el mundo de la ciberseguridad.

- **Lammers:**

Chicos jóvenes sin grandes conocimientos de informática, pero que se consideran a sí mismos hackers y se vanaglorian de ello.

- **Sniffers:**

Expertos en redes que analizan el tráfico para obtener información extrayéndola de los paquetes que se transmiten por la red, poniendo en peligro la confidencialidad de los datos.

Los SNIFFERS están muy relacionados con el "MODO PROMISCOUO", es aquel en el que una computadora conectada a una red compartida, tanto la basada en cable de cobre como la basada en tecnología inalámbrica, captura todo el tráfico que circula por ella. Utilizan el ataque llamado sniffing.



Sniffing es un tipo de ciberataque, es un programa de captura de las tramas de una red de computadoras. (para escuchar todo lo que sucede en una red). Estos ataques son especialmente en redes internas.

- **Ciberterroristas:**

Expertos en informática e intrusiones en la red que trabajan para países y organizaciones como espías y sabotadores informáticos.

- **Programadores de virus:**

Expertos en programación, redes y sistemas que crean programas dañinos que producen efectos no deseados en los sistemas o aplicaciones.

- **Carders:**

Personas que se dedican al ataque de los sistemas de tarjetas, como los cajeros automáticos.

- **Hacktivista:**

Es una moda creciente en los últimos años, utilizan sus conocimientos y habilidades para fines políticos, uno de los ejemplos más representativos sería Anonymous.

Anonymous es un pseudónimo utilizado mundialmente por diferentes individuos y colectivos, que, coordinándose con otros, realizan acciones o publicaciones individuales o concertadas, especialmente ataques cibernéticos contra gobiernos, corporaciones, instituciones y agencias gubernamentales.

Anonymous surgió inicialmente como un grupo de usuarios que realizaban bromas e incursiones en internet en 2003 en el imageboard 4chan y en el foro Hackers.

Desde 2008, tras el Proyecto Chanology, Anonymous se manifiesta en acciones de protesta a favor de la libertad de expresión, acceso a la información, la independencia de Internet, y en contra de diversas organizaciones.

Se suelen distinguir en público por usar la máscara de Guy Fawkes.

3.2. Ciberataques

Un ciberataque es cualquier intento deliberado de explotar sistemas, redes o dispositivos informáticos con el fin de causar daños, robar datos, interrumpir servicios o acceder de manera no autorizada a recursos digitales. Estos ataques pueden ser llevados a cabo por individuos, grupos organizados o incluso estados, y sus motivaciones pueden variar entre intereses financieros, políticos, vandalismo o el simple desafío personal.

En términos financieros, los atacantes buscan ganancias económicas a través de robos, extorsiones mediante ransomware o fraudes. Políticamente, los ciberataques son utilizados para espionaje, propaganda o desestabilización de gobiernos. También pueden tener fines vandálicos, como la destrucción de datos o la interrupción de servicios, o estar impulsados por la curiosidad y la superación de retos técnicos.



Conviene abordar dos términos que nos serán de utilidad en el mundo semántico de los ciberataques. Si bien el término "ware" denominaría en lengua inglesa "producto", en el mundo digital tiene a adquirir la acepción de programa. Por otro lado, el término 'jacking' proviene del verbo en inglés "jack". Un verbo que originalmente se refiere a levantar algo usando un gato o aparejo (como cuando se levanta un coche con un gato mecánico), y con el tiempo, se ha adaptado y ampliado para referirse a la acción de tomar control de algo o interferir con su funcionamiento normal.

Los tipos de ciberataques incluyen una amplia variedad de técnicas, tales como Hijacking, que implica el secuestro de recursos como servidores DNS, cuentas de usuario o sesiones, realizado por programas conocidos como Hijackers. También están los ataques relacionados con vulnerabilidades específicas como Heartbleed, una falla en OpenSSL que permite leer la memoria del sistema, y Pharming, que redirige el tráfico web a sitios falsos mediante la manipulación de DNS o equipos.

Otros ejemplos incluyen Eavesdropping, que captura datos sensibles al interceptar paquetes de red, y Man-in-the-Middle (MITM), donde un atacante intercepta o manipula la comunicación entre dos partes. Técnicas como IP Splicing se usan en combinación con ataques como MITM, DoS, DDoS y Hijacking para modificar paquetes de datos y controlar la comunicación.

Desde sus inicios, los ciberataques han evolucionado significativamente, comenzando con simples virus y gusanos en las décadas de 1980 y 1990, hasta las actuales amenazas sofisticadas como ransomware dirigido, ataques a la cadena de suministro y deepfakes. Además, las tendencias actuales apuntan al uso de inteligencia artificial en los ataques y a una mayor superficie de ataque debido al crecimiento del Internet de las Cosas (IoT).

3.2.1. Clasificación de los ciberataques

Los ciberataques se pueden clasificar de varias maneras, principalmente basados en las técnicas utilizadas y los objetivos que persiguen.

3.2.1.1. Basados en la técnica

3.2.1.1.1. Ataques de explotación

Estos ataques buscan aprovechar vulnerabilidades de software, como las conocidas vulnerabilidades de "zero-day" y "día N". También incluyen técnicas como la inyección de código (SQL Injection, Cross-Site Scripting) y los desbordamientos de búfer, donde los atacantes sobrecargan la memoria para ejecutar código malicioso.

SQL Injection

La inyección SQL es una vulnerabilidad de seguridad web que permite a un atacante interferir con las consultas que una aplicación realiza en su base de datos. En general, permite a un atacante ver datos que normalmente no pueden recuperar, como información de otros usuarios o datos confidenciales. Además, en muchos casos, un atacante puede modificar o eliminar estos datos, causando cambios persistentes en el contenido o el comportamiento de la aplicación.



3.2.1.1.2. Ataques de acceso

Phishing

Es una técnica que utiliza engaños, como correos electrónicos falsos o páginas web fraudulentas, para inducir a los usuarios a revelar información personal o financiera. A menudo se disfraza de comunicación de confianza proveniente de bancos, servicios en línea o instituciones reconocidas. La denominación hace un juego de palabras con "**fishing**" pescar, pues se pescaría a las víctimas con anzuelos como lo siguientes.

- **Smishing:** Variante del phishing que utiliza mensajes SMS para engañar a las víctimas, la denominación sería una mezcla de **SMS** y **Phishing** resultando Smishing.
- **Vishing:** Variante que emplea llamadas telefónicas para obtener información sensible, la denominación responde a la combinación de **Voice** y **Phishing**.
- **Whaling:** Si bien el phishing común trataría de la "pesca común" o engaño al usuario común, el **whaling** sería otro juego de palabras que significaría la caza de peces gordos, **whale** es ballena, caza pues de ballenas que sería gente influyente, altos ejecutivos, políticos, etc.

3.2.1.1.3. Ataques de ingeniería social

Tailgating o piggybacking

Es un ataque en el que un atacante sigue a una persona autorizada para ganar acceso físico a un área restringida sin que la víctima se percate. El atacante puede hacer pasar por una persona legítima para entrar detrás de alguien con permiso.

Quid pro quo

En este ataque, el atacante ofrece algo a cambio de obtener acceso o información confidencial. Por ejemplo, puede ofrecer soporte técnico, pero solicita información sensible a cambio, como contraseñas.

Pretexto

Este ataque consiste en que el atacante crea una historia falsa para obtener información. Se hace pasar por alguien legítimo (como un empleado de una empresa, o una autoridad de confianza) para que la víctima le revele datos o entregue acceso a sistemas.

Baiting

El "cebo" es un ataque en el que el atacante ofrece algo tentador (como software gratuito, un archivo descargable, un dispositivo USB infectado, etc.) para que la víctima haga clic en él o lo conecte a su sistema. El objetivo es que el usuario instale software malicioso o entregue información.



Watering hole

Este ataque es indirecto pero efectivo. El atacante identifica sitios web frecuentados por su objetivo (como empleados de una empresa específica) y luego compromete esos sitios para infectarlos con malware. La víctima visita el sitio y, sin saberlo, descarga el malware.

Shoulder sufring

En este caso, el atacante no interactúa directamente con la víctima, sino que observa desde cerca para ver información sensible (como contraseñas o datos bancarios) mientras la víctima está trabajando o usando un dispositivo, generalmente en lugares públicos o poco vigilados.

3.2.1.1.4. Ataques de denegación de servicio

Estos ataques buscan interrumpir el acceso a sistemas o servicios. Los ataques **DoS** (Denial of Service o denegación de servicio) sobrecargan un recurso (inunda un servidor o red con una gran cantidad de solicitudes, datos, o tráfico), mientras que los **DDoS** (Distributed Denial of Service, Denegación de Servicio Distribuida) distribuyen esta acción utilizando múltiples dispositivos, al venir el ataque desde múltiples puntos, es más difícil de detener porque parece tráfico legítimo. Utiliza una red de sistemas comprometidos (a menudo llamados "botnets") para generar un tráfico masivo hacia el objetivo.

3.2.1.1.5. Ataques de Malware

El malware que viene de **malicious software**, abarca una amplia gama de programas maliciosos diseñados para causar daño:

Virus

Requieren un archivo anfitrión (ejecutables, documentos con macros) para poder infectar y reproducirse. Su nombre lo adoptan de la similitud que tienen con los virus biológicos que afectan a los humanos. En este caso, los antibióticos serían los programas antivirus. Infectan archivos del sistema incrustando código malicioso, transformándolos en fuentes de infección.

Gusanos

Se reproducen sin necesidad de un archivo anfitrión y se propagan a través de redes y dispositivos. Pueden reproducirse utilizando diferentes medios de comunicación como las redes locales, el correo electrónico, los programas de mensajería instantánea, redes P2P, dispositivos USB y las redes sociales.



Trojanos

Programas disfrazados de aplicaciones útiles que ejecutan acciones maliciosas. A diferencia de los virus y gusanos, los trojanos no se replican ni se propagan por sí mismos. Pueden permitir el acceso remoto no autorizado al sistema infectado, permitiendo que los atacantes controlen el equipo. Entre otras acciones pueden registrar pulsaciones de teclas (keyloggers) para capturar contraseñas o datos financieros o crear puertas traseras (backdoors).

Ransomware

Cifra de datos del equipo atacado y exige un rescate para desbloquearlos. La denominación viene de Ransom, rescate, así que la traducción literal sería algo así como "programa de rescates". La víctima, para obtener la contraseña que libera la información, debe pagar al atacante una suma de dinero, según las instrucciones que este disponga.

Spyware

Recopila información del usuario sin su consentimiento. El objetivo más común es distribuirlo a empresas publicitarias u otras organizaciones interesadas. Normalmente, este software envía información a sus servidores, en función de los hábitos de navegación del usuario. También recoge datos acerca de las webs que se navegan y la información que se solicita en esos sitios, así como direcciones IP y URL que se visitan.

Esta información es explotada para propósitos de mercadotecnia y muchas veces es el origen de otra plaga como el spam, ya que puede encarar publicidad personalizada hacia el usuario afectado. Además, con esta información es posible crear perfiles estadísticos de los hábitos de los internautas. Al igual que los trojanos, este software suele disfrazarse de aplicaciones útiles y que cumplen una función al usuario, además de auto ofrecer su descarga en muchos sitios reconocidos.

Adware

Despliega publicidad intrusiva (en ventanas emergentes, etc.). La denominación le viene por el término **advertising**, que significa publicidad, y **ware**, programa.

Rootkits

Colección de programas usados por un hacker para evitar ser detectado mientras busca obtener acceso no autorizado a un ordenador.

Esto se logra de dos formas:

- Reemplazando archivos o bibliotecas del sistema.
- Instalando un módulo de kernel.



El hacker instala el rootkit después, obteniendo un acceso similar al del usuario: por lo general, craqueando una contraseña o explotando una vulnerabilidad, lo que permite usar otras credenciales hasta conseguir el acceso de raíz o administrador.

Al eliminarlos puede causar graves daños en el sistema operativo, ya que ha sustituido archivos críticos por aquellos bajo el control del rootkit. Si estos se retiran, el sistema operativo puede quedar inutilizado.

Backdoors

Estos programas son diseñados para abrir una puerta trasera en nuestro sistema, de modo que permite al creador de esta aplicación tener acceso al sistema y hacer lo que desee con él. El objetivo es lograr una gran cantidad de computadoras infectadas para disponer de ellas libremente.

Botnets

Redes de dispositivos infectados, controlados por un atacante, que realizan tareas maliciosa de forma conjunta y distribuida. Cuando un ordenador ha sido afectado por un malware de este tipo, se dice que es un equipo es un robot (de ahí su denominación robot de red) o zombi.

Hoax

Correos electrónicos en cadena con información falsa. Cuentan que su etimología podría proceder del término latino "hocus", abreviación de "hocus pocus" interjección usada en los hechizos o encantamientos, trascendiendo al significado de engaño o truco perpetrado para hacer creer a las personas algo incierto. Se crean para confundir, alarmar o manipular a las personas. Se propagan rápidamente debido a la facilidad con la que se pueden compartir en línea.

Hijacking

Hijack se traduce como secuestro, el hijacking sería pues el secuestro de recursos, como navegadores, sesiones (cuentas de usuario) o servidores DNS (mapeando ips), realizado mediante programas denominados hijackers. El término antes de trascender al mundo digital, definía el secuestro de aviones o vehículos. En muchos el usuario no es consciente del hijacking pues el atacante actúa de manera encubierta, manipulando sesiones, redirigiendo el tráfico.

El **browser hijacking** es quizás el más indiscreto pues el usuario puede notar comportamientos sospechosos como cambios en la página de inicio del navegador, ventanas emergentes frecuente. Sin embargo en técnicas como el **DNS hijacking**, el ataque puede pasar totalmente desapercibido hasta que haya consecuencias drásticas.

El **DNS hijacking** implica modificar configuraciones DNS en el dispositivo, router o servidor DNS para redirigir todo el tráfico de manera persistente.

Keyloggers

Capturan las pulsaciones del teclado para robar información. Son usados por muchos troyanos para robar contraseñas e información de los equipos en los que están instalados.



PUPs

Programas potencialmente no deseados (potentially unwanted programs) que afectan la privacidad o el rendimiento del sistema. Se instalan sin el consentimiento del usuario y realizan acciones o tienen características que pueden menoscabar el control del usuario sobre su privacidad, confidencialidad, uso de recursos del ordenador, etcétera.

Spam

Correo electrónico no solicitado enviado masivamente para publicidad, fraudes o distribución de malware. El término spam se origina a raíz de un sketch cómico del grupo sarcástico británico Monty Python, titulado Spam. El sketch se desarrolla en un curioso restaurante en el que las opciones culinarias llevan de manera sistemática cantidades ingentes de Spam (marca de carne enlatada). Un sketch de 1970 que tuvo tal popularidad que basculó a la jerga de una de las primeras plataformas de comunicación llamada Usenet, creada en 1980 en la que servía para describir el envío masivo de mensajes irrelevantes o indeseados. Trascender al mundo del correo electrónico, redes sociales o SMS y llamadas solo fue cuestión de tiempo.

Rogue Software

Programas falsos que pretenden ser útiles (como antivirus o herramientas de optimización) pero que en realidad son dañinos. Con la proliferación del spyware, el rogue software comenzó a surgir como un importante negocio para los ciberdelincuentes en formato de falso antispyware. Con el tiempo fueron evolucionando, creando falsos optimizadores de Windows y falsos antivirus. Al ejecutarlos nos muestran información sobre una falsa infección o falso problema en el sistema. Si queremos arreglarlos debemos comprar su versión de pago (que en realidad no arregla nada). Rogue en inglés significa pícaro o tramposo.

Bromas

Programas que no causan daño directo, pero generan advertencias o mensajes falsos diseñados para alarmar al usuario, como simulaciones de formateo o detección de virus inexistentes.

3.2.1.1.6. Ataques de Red

Estos ataques se centran en interceptar y manipular las comunicaciones:

Man-in-the-Middle (MitM)

Se divide en dos partes: **posicionamiento activo entre comunicantes** (con **ARP spoofing** o **DNS spoofing**, suplantación de certificados, u otros métodos) y la **intercepción de comunicaciones** de los dialogantes. La denominación 'hombre en el medio' refleja que la información no viaja directamente entre el remitente y el receptor, sino que cuenta con un tercer actor, un intruso. Su función es capturar el tráfico, ya sea para observarlo, almacenarlo o modificarlo más adelante.



Una vez que se lleva a cabo la interceptación, el intruso decide qué técnica o acción específica usar: eavesdropping, manipulación activa (cambiar o inyectar datos en la comunicación) o redirección de los datos interceptados a otro destino.

Este tipo de ataque puede ocurrir en redes cableadas comprometidas o en redes Wi-Fi no seguras. Aunque es especialmente peligroso para protocolos sin cifrado, como HTTP, otros protocolos también pueden ser vulnerables si no se implementan correctamente medidas de seguridad como el cifrado TLS.

Eavesdropping

La denominación proviene de 'eaves', que en inglés antiguo se refería a los aleros de los tejados. El término 'eavesdropping' describe la acción de ocultarse bajo esos aleros para escuchar conversaciones privadas que se filtran o se dejan caer ('dropping') hacia el exterior de los muros. En redes no cifradas, es una técnica altamente efectiva. Es una forma de espionaje que no manipula la información, ya que está enfocada exclusivamente en escuchar y robar datos.

Es un término genérico que se refiere a cualquier actividad de espionaje ya sea en el mundo digital o no. En el contexto de redes abarca distintos métodos como pueden ser entre otros el Sniffing o la Escucha pasiva en llamadas VoIP.

IP Splicing

Es una característica inherente al protocolo IP diseñada para fragmentar paquetes y adaptarlos a las limitaciones de las redes intermedias. Esta funcionalidad, completamente neutral, es ejecutada automáticamente por los routers cuando el tamaño del paquete supera el MTU de la red de salida. Sin embargo, también puede ser explotada por un atacante con fines maliciosos.

Un atacante puede aprovechar la fragmentación legítima o inducida del paquete IP para manipular estos fragmentos (inyección de código, manipulación de offsets, etc.) con el objetivo de comprometer el sistema de destino. Esta funcionalidad es explotada frecuentemente en ataques como DoS, DDoS y Hijacking.

Pharming

El pharming, en esencia, **es un ataque que explota la resolución de nombres de dominio (DNS)**, ya sea manipulando el archivo **hosts** local del sistema atacado o **comprometiendo un servidor DNS** para redirigir el tráfico hacia una dirección controlada por el atacante (IP Spoofing). Esta dirección maliciosa es donde se lleva a cabo el ataque. Combina técnicas de hijacking y spoofing. La persistencia dependerá de la técnica utilizada.

A diferencia del secuestro o hijacking el objetivo es el robo de información. La denominación es un juego de palabras entre '**phishing**', y '**farming**', cultivo.



Clickjacking

Engaño mediante interfaces web para realizar acciones no deseadas al usuario, como revelar información confidencial o redirigir a páginas maliciosas. El atacante puede superponer, por ejemplo, un elemento HTML transparente en la interfaz y cuando el usuario pretenda hacer click sobre el elemento que está debajo, pues es el único que ve, efectuará una acción no deseada (compartir permisos o realizar compras online). Se denomina así porque se entiende como un "secuestro de click".

Sniffing

Técnica que implica la interceptación y monitoreo del tráfico de red con el objetivo de capturar información sensible, como credenciales de inicio de sesión o datos confidenciales. Es especialmente efectivo en redes no cifradas. Sniffing viene de "to sniff" que significa olfatear o husmear. En ciberseguridad este olfateo describe la captura y análisis de paquetes de datos que circulan a través de una red. El sniffing se refiere específicamente a la acción de capturar tráfico en una red, mientras que el MITM (Man-in-the-Middle) posicionarse activamente entre dos partes que están comunicándose e interceptar esa comunicación.

Spoofing

Término que viene del verbo inglés "to spoof", que sería algo así como falsificar, engañar o suplantar. Es una técnica que consiste en la suplantación de identidad de dispositivos o usuarios dentro de una red. El spoofing incluye, entre otras técnicas:

- **IP Spoofing:** El atacante crea generalmente paquetes ip maliciosos desde su dispositivo, alterando manualmente los encabezados para falsificar la dirección IP de origen. Generalmente el IP spoofing no requiere interceptar ni modificar paquetes existentes porque el atacante no necesita controlar la respuesta.
- **DNS Spoofing:** Envío de respuestas DNS falsas al usuario para redirigirlo a un sitio malicioso. Ataque temporal pues el ataque afecta solo a la sesión, caché del usuario o servidor DNS. No implica comprometer necesariamente al servidor DNS. Esto significa que no modifica configuraciones como sí hace el **DNS hijacking** sino que lo que hace es falsificar respuestas DNS. Un ejemplo sería la interceptación de una consulta DNS por parte de un atacante para devolver una IP falsa al solicitante.
- **ARP Spoofing:** El **ARP spoofing** ocurre cuando un atacante responde de manera falsa a una solicitud ARP, proporcionando su propia dirección MAC en adelantándose al equipo legítimo. Esto permite que un mapeo falso en las tablas ARP en la que la dirección MAC del atacante estará mapeada a una IP legítima.
- Como resultado, el atacante puede interceptar o redirigir el tráfico destinado al dispositivo suplantado, haciéndose pasar por él en la red. Es una técnica comunmente usada en ataques MitM.



Barrido o escaneo

Proceso de envío masivo de solicitudes a un rango de direcciones IP para identificar dispositivos activos y servicios accesibles. Los atacantes utilizan herramientas de escaneo como **Nmap** para descubrir vulnerabilidades y puntos de entrada.

3.2.1.1.7. Ataques de canal lateral

Se basan en características físicas de los dispositivos:

- **Ataques de tiempo**, que analizan el tiempo de ejecución de los procesos.
- **Análisis de energía**, que observa el consumo energético de un dispositivo.
- **Ataques basados en sonidos**, que capturan patrones acústicos, como las pulsaciones de teclas.
- **Monitorización de ondas electromagnéticas** para descifrar actividades del sistema.

3.2.1.1.8. Software de Riesgo

Riskware

Software de riesgo también llamado Riskware son programas legítimos que contienen vulnerabilidades explotables por atacantes para realizar acciones dañinas. No es intrínsecamente defectuoso, pero puede ser utilizado para fines maliciosos o configurado de manera insegura.

3.2.1.1.9. Otras vulnerabilidades

Heartbleed: Una vulnerabilidad crítica en la biblioteca de OpenSSL (solo en su versión 1.0.1f), que permite a un atacante leer la memoria de servidores o clientes, obteniendo información sensible como claves privadas SSL. Esta vulnerabilidad ha sido explotada incluso antes de ser descubierta públicamente.

3.2.1.2. Basados en el Objetivo

Los ciberataques pueden clasificarse también según el impacto deseado.

Si atendemos a la confidencialidad, la meta es la de conseguir un acceso no autorizado a información sensible. Si hablamos de integridad se tratará de la modificación no autorizada de datos y si se trata de la disponibilidad el objetivo es el de impedir el acceso a sistemas o servicios.



3.2.2. Dinámica, Prevención y Futuro de los Ciberataques

3.2.2.1. La cadena del Ataque

Un ciberataque típicamente sigue una cadena estructurada de acciones:

- Reconocimiento: Identificación de objetivos y recopilación de información.
- Explotación: Aprovechamiento de vulnerabilidades identificadas.
- Instalación: Establecimiento de un punto de apoyo en el sistema.
- Comando y control: Comunicación entre el atacante y el sistema comprometido.
- Acción: Ejecución de la carga útil, como robo de datos o destrucción.

3.2.2.2. Actores de las amenazas

Los actores que llevan a cabo ciberataques pueden ser diversos, por ejemplo los hackers individuales suelen estar motivados por el desafío personal o el lucro económico.

En cambio, los grupos organizados tienen objetivos políticos o económicos claros. Los Estados-nación realizan ciberespionaje o ciberguerra como estrategia. Los Criminales cibernéticos atacan con fines puramente financieros.

3.2.2.3. Prevención y mitigación

La prevención de ciberataques requiere la gestión de parches y actualizaciones regulares. Asimismo, es muy importante la concienciación de los usuarios a través de capacitación. Imprescindibles también son los respaldos regulares de datos críticos, así como la segmentación de redes para limitar el alcance de los ataques.

Entre las soluciones técnicas más comunes se incluyen sistemas avanzados como los EDR (Endpoint Detection and Response), que permiten la detección y respuesta a incidentes en los dispositivos finales mediante el monitoreo continuo. Los sistemas de detección de intrusiones (IDS) identifican actividades sospechosas analizando el tráfico de red. Los firewalls controlan el tráfico entrante y saliente para evitar accesos no autorizados. Además, los antivirus juegan un rol clave al detectar y eliminar malware conocido. Complementando estas herramientas, se recomienda implementar protocolos de seguridad robustos, realizar auditorías regulares y establecer estrategias de recuperación ante incidentes.

3.2.2.4. Casos de estudio

Ransomware dirigido a hospitales, afectando infraestructura crítica.

Violaciones masivas de datos, comprometiendo la información de millones de usuarios.

Ataques a la cadena de suministro, donde los atacantes comprometen proveedores para alcanzar objetivos finales.



3.2.2.5. Tendencias futuras

El panorama de los ciberataques seguirá evolucionando, con tendencias como el uso de inteligencia artificial en ciberataques, incluidos deepfakes y ataques generativos.

Existe una creciente superficie de ataque debido a la proliferación del IoT (Internet of Things o Internet de las cosas) que se ha de afrontar con un mayor énfasis en la resiliencia cibernética, diseñando sistemas capaces de resistir y recuperarse de ataques.

3.3. Vulnerabilidades

Una vulnerabilidad es una debilidad o deficiencia en un sistema informático que puede ser utilizada por una persona malintencionada para realizar un ataque. Se les llama también agujeros de seguridad.

Existen muchos tipos de vulnerabilidades, vamos a indicar una clasificación:

- **De desbordamiento de búfer (BufferOverflow o BoF).**

En principio se piensa que la única consecuencia es que el programa se bloquee, ya que se produce un desbordamiento cuando se intenta escribir más datos en un búfer de tamaño fijo de lo que el búfer tiene asignado. Pero también puede permitir que se ejecute un código malicioso.

Para evitar esto hay que realizar en la programación una comprobación de límites en todos los datos de entrada.

- **De secuencia de comandos en sitios cruzados (Cross-Site Scripting o XSS).**

Este tipo de vulnerabilidad permitir a un atacante inyectar código malicioso (normalmente en JavaScript) en páginas web, de forma que los usuarios al visitar la página lo ejecutan y puede provocar filtración o el robo de información, e incluso permitir al atacante tomar el control de la sesión del navegador.

Aunque es más común en sitios web disponibles en Internet, también puede darse en el navegador en sí y en aplicaciones locales.

Esta vulnerabilidad se puede dar de dos formas:

- Persistente (llamada también Directa): consiste en insertar código HTML peligroso en sitios que lo permitan (como etiquetas `<script>` o `<iframe>`).
- Reflejada (llamada también Indirecta): consiste en modificar valores que la aplicación web utiliza para pasar variables entre dos páginas, sin usar sesiones. Se produce cuando hay un mensaje o una ruta en la URL del navegador, en una cookie, o cualquier otra cabecera HTTP.



Indicamos algunas medidas para evitar un ataque a través de esta vulnerabilidad:

- Comprobar todas las entradas de datos desde formularios.
- Desactivar la ejecución de JavaScript y VBScript en el navegador.
- Realizar auditorías de seguridad de todas las aplicaciones web.
- En los servidores web, comprobar los logs (ficheros de registro) y aumentar las medidas de control de acceso.

Esta vulnerabilidad puede evitarse utilizando medidas de seguridad como CSP, CSP, siglas de Cryptographic Service Provider, traducido como proveedor de servicios, es una biblioteca de software que implementa Microsoft CryptoAPI (CAPI). Los CSP son módulos independientes que implementan los algoritmos y estándares criptográficos, funciones de codificación y decodificación, y que pueden ser utilizados por diferentes aplicaciones, por ejemplo para un correo electrónico seguro o una autenticación segura de usuario.

El atributo de seguridad **HttpOnly** ayuda a prevenir los ataques XSS pues impide que las cookies sean accesibles a través de scripts del lado del cliente.

- **De Falsificación de Peticiones en Sitios Cruzados (Cross-Site Request Forgery o CSRF).**

El ataque CSRF es posible debido a que los navegadores web envían automáticamente, con cada petición a un sitio web, las credenciales de autenticación (por ejemplo, las cookies). Por tanto, si un usuario que se ha autenticado en un sitio web hace clic en un enlace malicioso en otro sitio web, la petición maliciosa es enviada con las credenciales de autenticación del usuario.

Un sitio web malicioso o un correo electrónico fraudulento hacen que un usuario envíe una petición no deseada a otro sitio web, como hacer una compra, cambiar una contraseña o publicar comentarios.

El uso, por ejemplo, de tokens CSRF únicos para cada solicitud y verificaciones de referido evitan esta vulnerabilidad.

Un token CSRF es un valor secreto único e impredecible que se genera por una aplicación del lado del servidor y es enviado al cliente para su inclusión en las solicitudes HTTP posteriores emitidas por el cliente.

Con el fin de mitigar este tipo de ataques se implementa el **atributo de seguridad de las cookies SameSite** que permitirá al navegador enviar la cookie en cuestión solo si ésta se originó en el mismo sitio con el que está contactando. Es un atributo que se establece en el lado del servidor y puede tener distintos valores Lax, Strict o None con Secure:

- **SameSite=Lax:** cookies y tokens de autenticación se mandarán en las solicitudes solo si la acción es el resultado de una navegación desde otro sitio (p.e hacer click en un enlace).
- **SameSite=Strict:** cookies y tokens de autenticación solo serán enviados en este caso si la acción es el resultado de una navegación desde el mismo sitio. Es una opción más conservadora que minimiza el riesgo de CSRF pero que repercute en la interoperabilidad.



- **SameSite=None:** cookies y tokens de autenticación podrán ser enviados desde cualquier sitio, incluidas las solicitudes de terceros. Aparece a menudo junto a la directiva **Secure** que forzará que las cookies solo sean transmitidas desde conexiones HTTPS seguras.
- **Control de Acceso Débil (Broken Access Control).**

Cuando un sistema o aplicación no tiene una restricción adecuada el acceso a funciones o recursos se puede permitir que atacantes realicen acciones maliciosas o accedan a información confidencial e incluso tomen control de una cuenta de usuario, manipulando información y pudiendo ejecutar acciones no autorizadas.

Para evitarlo es imprescindible la autenticación de usuarios, autorización de acceso y la validación de datos. Debe realizarse siempre una programación teniendo en cuenta la adopción de buenas prácticas para evitar la inclusión de errores de seguridad.

- **De inyección SQL.**

Se produce cuando la entrada del usuario no se valida adecuadamente antes de ser utilizada en una consulta SQL.

Un atacante puede ejecutar código SQL arbitrario, originándose filtración o robo de información, o que el atacante tome el control del servidor de la base de datos.

- **Configuración insegura de CORS (Cross-Origin Resource Sharing).**

CORS es un mecanismo de seguridad que define cómo los navegadores permiten que recursos de un servidor sean solicitados desde un dominio distinto. Una configuración permisiva o incorrecta (por ejemplo, Access-Control-Allow-Origin: *) puede permitir que sitios web maliciosos realicen peticiones autenticadas a APIs o servicios protegidos desde el navegador del usuario, y accedan a los datos devueltos, especialmente si coexisten vulnerabilidades como XSS o CSRF.

Para mitigar este riesgo, es necesario limitar los orígenes autorizados, validar los métodos y encabezados permitidos, y evitar el uso innecesario de credenciales compartidas (Access-Control-Allow-Credentials: true). El control de CORS debe ser gestionado desde el backend, alineado con los orígenes legítimos de la aplicación web.



+ Info

Agujeros de Seguridad Spectre y Meltdown

Spectre es una vulnerabilidad que permite leer ubicaciones arbitrarias en la memoria asignada de un programa.



Meltdown es una vulnerabilidad que permite que un proceso lea toda la memoria en un sistema determinado. También conocido como carga maligna de la caché de datos (Rogue Data Cache Load), al que le fue asignado.

4. Técnicas criptograficas y protocolos seguros

Para asegurar la información, se realiza un cifrado de la misma, mediante la criptografía, que consiste en utilizar unas herramientas criptográficas para ofuscar la información mediante técnicas de codificación, evitando que los datos sean legibles por cualquier persona que desconozca la clave de decodificación.

La criptografía (escritura oculta) se define, como el ámbito de la criptología que se ocupa de las técnicas de cifrado o codificado destinadas a alterar los mensajes o representaciones lingüísticas para hacerlos ininteligibles a receptores no autorizados.

Esta técnica es usada también en las nuevas tecnologías para conseguir la confidencialidad de los mensajes.



Importante

Por ejemplo, en el S.O. UNIX, las contraseñas de los usuarios se guardan encriptadas en el fichero `/etc/shadow`.

Con el uso masivo de las comunicaciones digitales en la informática, se han ido produciendo cada vez más problemas de seguridad que afectan a estas comunicaciones.

Es necesario garantizar que las transacciones que se realizan a través de la red no pueden ser interceptadas, para asegurar la seguridad de la información que se transmite.

La criptografía, utiliza herramientas para proteger la confidencialidad de la información permitiendo su transmisión a través de canales de comunicación inseguros.

En un principio, se diseñaban sistemas de cifrado y códigos, y la única criptografía existente era la llamada criptografía clásica.



Máquina de enigma cifrado criptológico del ejército, en el museo de tecnología. Fuente: Pxfuel

Actualmente la criptografía se encarga del estudio de algoritmos, protocolos (llamados protocolos criptográficos), y sistemas para proteger y dotar de seguridad a las comunicaciones que se realizan a través de la red, así como a las entidades que se comunican.

Los grandes avances producidos en la criptografía se deben a la gran en el campo de la matemática y la informática. Los criptógrafos investigan, desarrollan y aprovechan estas técnicas matemáticas.

Estas técnicas de criptografía son la mejor opción para el almacenamiento y transmisión de información sensible, ya que:

- Permiten controlar el acceso a la información.
- Limitan la difusión no autorizada en caso de pérdida o robo de soportes.

Sin embargo, hay que tener en cuenta una serie de aspectos:

- La clave debe ser robusta para que dificultar el acceso no autorizado a la información.
- La pérdida de la clave de acceso imposibilita el acceso a la información.



+ Info

La expresión **Autoridad de Certificación**, con las siglas **AC** (también indicado a veces como certificadora o certificante), indica una entidad de confianza, responsable de emitir y revocar los certificados, utilizando en ellos la firma electrónica, para lo cual se emplea la criptografía de clave pública.

También se puede ver con la indicación en inglés **Certification Authority**, con las siglas **CA**.

4.1. Algoritmo criptográfico

Recuerda que, un algoritmo criptográfico modifica los datos de un documento con el objetivo de alcanzar algunas características de seguridad como autenticación, integridad y confidencialidad.

Los diferentes algoritmos para:

- **Acuerdo de claves.**

Permite a dos partes acordar una clave secreta, y así establecer una comunicación cifrada usando un canal inseguro.

- **Autenticación de las partes.**

Permiten la verificación de que los extremos de una comunicación sean quienes dicen ser.

- **Firma electrónica.**

Permiten firmar un fichero, un mensaje etc. mediante su cifrado con una clave, garantizando así su procedencia.

Los algoritmos criptográficos se pueden clasificar según:

- Uso de claves.
- Según su cifrado.



+ Info

El cifrado pervasivo de IBM

Es la propuesta de IBM como una solución de cifrado de datos en tránsito de las más seguras, el cual puede ser accesible mediante una plataforma denominada IBM z15.

Este método de cifrado permite proteger los datos en todos los puntos por donde viaja a través de la red. No sólo se aplica el cifrado cuando están en tránsito, sino también cuando están almacenados (at-rest).

El funcionamiento es que, los datos procesados viajarán por la red cifrados a nivel de red, minimizando las posibilidades de que un cibercriminal quiera hacer «sniffing». Utiliza el protocolo TLS. IBM cuenta con una tecnología que detecta ataques y los mitiga, de forma que si el ataque consigue hacerse con los datos, no podrá descifrarlos.

4.1.1. Tipos de Algoritmos según su Cifrado

Independientemente de que sean algoritmos simétricos o asimétricos, se pueden clasificar también según la forma en la que operan los algoritmos en el cifrado o descifrado, es posible distinguir:

- **Cifrado en flujo:**

El cifrado se realiza bit a bit.

Están basados en la utilización de claves muy largas que son utilizadas tanto para cifrar como para descifrar.

Estas claves pueden estar predeterminadas (libreta de un solo uso) o generarse usando un generador de claves pseudoaleatorias o RKG (acrónimo del inglés random key generator).

- **Cifrado por bloques:**

El cifrado se realiza bloque a bloque.

Primero se descompone el mensaje en bloques de la misma longitud. A continuación, cada bloque se va convirtiendo en un bloque del mensaje cifrado mediante una secuencia de operaciones.



4.1.2. Tipos de Algoritmos según Uso de Claves

Los algoritmos criptográficos se pueden clasificar en tres grupos:

- **Criptografía simétrica** o de clave secreta **o de una clave**.

Son algoritmos simétricos:

- DES
- 3DES
- RC2
- RC4
- RC5
- IDEA
- AES (Advanced Encryption Standard)
- Blowfish
- ChaCha20
- Cifrado TwoFish

- **Criptografía asimétrica** o de clave pública o criptografía **de dos claves**.

Son algoritmos asimétricos:

- Diffie-Hellman: (No es un algoritmo asimétrico propiamente dicho, es un protocolo de establecimiento de claves, se usa para generar una clave privada a ambos extremos de un canal de comunicación inseguro)
- ElGamal
- RSA
- DSA
- Criptografía de curva elíptica (CCE)

- **Criptografía Híbrida**.

Son algoritmos asimétricos:

- PGP
- GnuPG

También vamos a ver las funciones Hash o de resumen.



4.1.2.1. Criptografía Simétrica

También llamada de clave secreta o de una clave.

Sólo se utiliza una clave, que debe conocer el emisor y el receptor para cifrar y descifrar el mensaje. Esa clave se usa para cifrar y descifrar mensajes en el emisor y el receptor.

Las dos partes que se comunican han de ponerse de acuerdo de antemano sobre la clave a usar. Una vez que ambas partes tienen acceso a esta clave, el remitente cifra un mensaje usando la clave, lo envía al destinatario, y este lo descifra con la misma clave.

Existe una clasificación de este tipo de criptografía en tres familias:

- Criptografía simétrica de bloques (block cipher).
- Criptografía simétrica de lluvia (stream cipher).
- Criptografía simétrica de resumen (hash functions).

Principales algoritmos

Veamos los principales algoritmos de criptografía simétrica:

- **DES:**

Siglas de Data Encryption Standard.

En ocasiones, DES es denominado también DEA (Data Encryption Algorithm).

Es estándar FIPS en los Estados Unidos en 1976, y cuyo uso se ha propagado ampliamente por todo el mundo.

Trabaja con claves simétrica, fue desarrollado en 1977 por la empresa IBM, se basa en un sistema monoalfabético, con un algoritmo de cifrado consistente en la aplicación sucesiva de varias permutaciones y sustituciones.

El algoritmo fue controvertido al principio, con algunos elementos de diseño clasificados, una longitud de clave relativamente corta, y las continuas sospechas sobre la existencia de alguna puerta trasera para la National Security Agency (NSA).

Posteriormente DES fue sometido a un intenso análisis académico y motivó el concepto moderno del cifrado por bloques y su criptoanálisis.

Actualmente DES se considera inseguro ya que el tamaño de clave de 56 bits es corto; las claves de DES se han roto en menos de 24 horas.

Se cree que el algoritmo es seguro en la práctica en su variante de Triple DES, aunque existan ataques teóricos.

Desde hace algunos años, el algoritmo ha sido sustituido por el nuevo AES (Advanced Encryption Standard).



- **3DES:**

Triple DES es el algoritmo que hace triple cifrado del DES.

También es conocido como TDES o 3DES, en 1998 IBM desarrollo 3DES o Triple DES (TDES) que sería sucesor directo de DES.

Como 56 bits no era suficiente para evitar un ataque de fuerza bruta, TDES fue elegido como forma de agrandar el largo de la clave sin necesidad de cambiar de algoritmo de cifrado.

Este método de cifrado es inmune al ataque por encuentro a medio camino, doblando la longitud efectiva de la clave (112 bits), pero en cambio es preciso triplicar el número de operaciones de cifrado, haciendo este método de cifrado muchísimo más seguro que el DES. Por tanto, la longitud de la clave usada será de 168 bits (3x56 bits), aunque como se ha dicho su eficacia solo sea de 112 bits. Se continúa cifrando bloques de 64 bits.

El Triple DES está siendo reemplazado por el algoritmo AES, aunque todavía (principios de 2020) la mayoría de las tarjetas de crédito y otros medios de pago electrónicos tienen como estándar el algoritmo Triple DES (anteriormente usaban el DES).

Por su diseño, el DES y por lo tanto el TDES son algoritmos lentos.

- **RC2:**

También conocido como ARC2.

"RC" significa "Código de Ron" o "Cifrado de Rivest". (otros diseñados son RC4, RC5 y RC6).

RC2 es un cifrado de bloque de 64 bits con un tamaño de clave de tamaño variable (40 bits).

Inicialmente, los detalles del algoritmo se mantuvieron en secreto, propiedad de RSA Security, pero el código fuente de RC2 fue publicado anónimamente en Internet en el foro de Usenet, sci.crypt.

- **RC4:**

Su nombre completo es Rivest Cipher 4, teniendo el acrónimo RC un significado alternativo al de Ron's Code utilizado para los algoritmos de cifrado RC2, RC5 y RC6.

Fue diseñado por Ronald Rivest de la RSA Security en el año 1987.

Inicialmente el algoritmo era un secreto registrado, pero en septiembre de 1994 una descripción del algoritmo fue distribuida anónimamente.

RC4 aún es una marca registrada. Actualmente la implementación no oficial de RC4 es legal, pero no puede utilizarse bajo el nombre de RC4. Por este motivo, y con el fin de evitar problemas legales a raíz de la marca registrada, a menudo podemos verlo nombrado como ARCFOUR, ARC4 (Alleged-RC4).

RSA Security nunca ha liberado de manera oficial el algoritmo de su RC4.



Dentro de la criptografía RC4 o ARC4 es el sistema de cifrado de flujo Stream cipher más utilizado y se usa en algunos de los protocolos más populares como Transport Layer Security (TLS/SSL) (para proteger el tráfico de Internet).

Wired Equivalent Privacy (WEP) (para añadir seguridad en las redes inalámbricas).

RC4 fue excluido enseguida de los estándares de alta seguridad por los criptógrafos y algunos modos de usar el algoritmo de criptografía RC4 lo han llevado a ser un sistema de criptografía muy inseguro, incluyendo su uso WEP. No está recomendada su aplicación en proyectos nuevos; sin embargo, algunos sistemas basados en RC4 son lo suficientemente seguros para un uso común.

- **RC5:**

Siglas en inglés de "Cifrado de Rivest".

Tiene tamaño variable de bloques (32, 64 o 128 bits), con tamaño de clave (entre 0 y 2040 bits) y número de vueltas (entre 0 y 255). La combinación sugerida originalmente era: bloques de 64 bits, claves de 128 bits y 12 vueltas.

Una característica importante de RC5 es el uso de rotaciones dependientes de los datos; uno de los objetivos de RC5 era promover el estudio y evaluación de dichas operaciones como primitivas de criptografía.

RC5 usa otra operación, llamada dependencia de datos, que aplica sifths a los datos para obtener así el mensaje cifrado.

- **IDEA:**

Siglas de International Data Encryption Algorithm, en castellano, algoritmo internacional de cifrado de datos.

Es un algoritmo de cifrado criptográfico, que opera con bloques de 64 bits. operando siempre con números de 16 bits usando operaciones como XOR y suma y multiplicación de enteros. El algoritmo de descryptación es muy parecido al de encriptación, por lo que resulta muy fácil y rápido de programar, y hasta ahora no ha sido roto nunca, por lo que se ha difundido ampliamente, utilizándose en sistemas como UNIX y en programas de cifrado de correo como PGP.

- **AES:**

Siglas de Advanced Encryption Standard.

También conocido como Rijndael (pronunciado "Rain Doll" en inglés).

Es un esquema de cifrado por bloques adoptado como un estándar de cifrado por el gobierno de los Estados Unidos, creado en Bélgica.

- Es de dominio público, disponible para todo el mundo.
- Soportar bloques de, como mínimo, 128 bits.



- Las claves de cifrado podrían ser de 128, 192 y 256 bits.
- Es implementable, tanto en hardware como en software.

AES puede llegar a ser hasta 6 veces más rápido que DES y RDES que son lentos por su diseño, y hasta la fecha no se ha encontrado ninguna vulnerabilidad.

Desde 2006, el AES es uno de los algoritmos más populares usados en criptografía simétrica.

- **Blowfish:**

Usa bloques de 64 bits y claves que van desde los 32 bits hasta 448 bits.

No se han encontrado técnicas de criptoanálisis efectivas contra el Blowfish.

Criptoanálisis es la parte de la criptología que se dedica al estudio de sistemas criptográficos con el fin de encontrar debilidades en los sistemas y romper su seguridad sin el conocimiento de información secreta.

- **ChaCha20:**

A diferencia de AES que es un cifrado por bloques, ChaCha20 es un cifrado de flujo.

Es el sucesor de Salsa20, su código fue publicado, estandarizado por la IETF en la RFC 7539.

En implementaciones de software, es mucho más eficiente y rápido que AES.

Soporta claves de 128 y 256 bits.

- **Cifrado TwoFish:**

Dispone de un tamaño de bloque de 128 bits, la longitud de su clave puede variar entre los 128, 192 o 256 bits. Es de código abierto y uso totalmente gratuito.

Nació en el año 1998, pensado y optimizado para usarse en unidades de procesamiento de 32 bits. Aunque es muy seguro y se estableció como uno de los mejores algoritmos de cifrado, para sustitución de DES, fue descartado por resultar muy lento en comparación con otros algoritmos.

Utiliza una clave para cifrar y descifrar todos los datos e información, soporta las claves junto con la información sin ningún tipo de formato. Una vez recibida toda la información, la cifra, por lo cual, ya no es visible sin pasar por el proceso de decodificación. Todos estos datos, se enviarán al usuario o sistema final, acompañados de la clave de cifrado, para que se pueda ver la misma.

Sus cajas de sustitución (S-Boxes) son calculadas previamente y se utilizan para hacer menos visible la relación entre un texto plano y uno cifrado, pero pueden ser vulnerables a ataques de canal lateral, aunque el riesgo se minimiza mucho al hacer que las S-Boxes dependan de la clave transmitida.



4.1.2.2. Criptografía Asimétrica

También llamada de clave pública (en inglés public key cryptography) o criptografía de dos claves (en inglés two-key cryptography).

Esta criptografía se creó con el fin de evitar por completo el problema del intercambio de claves de los sistemas de cifrado simétricos.

Se utilizan dos claves para el envío de mensajes, una pública y otra privada.

Llave o clave es lo mismo. Existiendo, por tanto: llave o clave privada y llave o clave pública.

Las dos claves pertenecen a la misma persona que recibirá el mensaje, la clave pública puede entregarse a cualquier persona, y la clave privada solo la conocerá el propietario y debe guardarla de modo que nadie tenga acceso a ella.

Si una persona que emite un mensaje a un destinatario usa la llave pública de este último para cifrarlo; una vez cifrado, sólo la clave privada del destinatario podrá descifrar el mensaje, ya que es el único que debería conocerla. Por tanto, se logra la confidencialidad del envío del mensaje, es extremadamente difícil que lo descifre alguien salvo el destinatario. Cualquiera, usando la llave pública del destinatario, puede cifrarle mensajes; los que serán descifrados por el destinatario usando su clave privada.

Si el propietario del par de claves usa su clave privada para cifrar un mensaje, cualquiera puede descifrarlo utilizando la clave pública del primero. En este caso se consigue la identificación y autenticación del remitente, ya que se sabe que sólo pudo haber sido él quien empleó su clave privada (salvo que un tercero la haya obtenido). Esta idea es el fundamento de la firma electrónica, donde jurídicamente existe la presunción de que el firmante es efectivamente el dueño de la clave privada.

Con las claves públicas no es necesario que el remitente y el destinatario se pongan de acuerdo en la clave a emplear. Todo lo que se requiere es que, antes de iniciar la comunicación secreta, cada uno debe conseguir la llave pública del otro y cuidar cada uno su llave privada. Es más, esas mismas claves públicas pueden ser usada por cualquiera que desee comunicarse con alguno de ellos siempre que se utilice correctamente la llave pública de cada uno.

Los métodos criptográficos garantizan que esa pareja de claves sólo se puede generar una vez, de modo que se puede asumir que no es posible que dos personas hayan obtenido casualmente la misma pareja de claves.

La criptografía asimétrica presenta dos ventajas principales: suprime el problema de transmisión segura de la clave y permite la firma electrónica.

Principales algoritmos

Ejemplos:

- **Diffie-Hellman:**

Es un protocolo de establecimiento de claves entre partes que no han tenido contacto previo, utilizando un canal inseguro y de manera anónima (no autenticada).



En el año 1976, los criptólogos Whitfield Diffie y Martin Hellman publicaron un algoritmo capaz de implementar un acuerdo de claves de forma asimétrica, es decir, que no requería enviar la clave de un extremo a otro, sino que otorgaba los medios suficientes para que ambas partes (y nadie más) pudiese calcularla.

Aunque no es un algoritmo asimétrico propiamente dicho, se le clasifica así por que otorga los medios para generar una clave privada a ambos extremos.

- **RSA:**

Siglas de Rivest, Shamir y Adleman.

Es el primer algoritmo de este tipo, desarrollado en 1979, y el más utilizado.

Es válido tanto para cifrar como para firmar digitalmente.

La seguridad de este algoritmo radica en el problema de la factorización de números enteros. Los mensajes enviados se representan mediante números, y el funcionamiento se basa en el producto, conocido, de dos números primos grandes elegidos al azar y mantenidos en secreto.

Este algoritmo necesita una clave privada y otra pública. Es decir, para intercambiar mensajes entre 3 usuarios es necesario que cada uno de ellos conozca la clave pública y la privada de sus otros dos compañeros.

- **ElGamal:**

Se refiere a un esquema de cifrado basado en el problema matemático del logaritmo discreto. Es un algoritmo basado en la idea de Diffie-Hellman y que funciona de una forma parecida a este algoritmo discreto.

(Un algoritmo discreto es un término que se utiliza en álgebra abstracta, dónde se usan elementos d un grupo cíclico finito.)

Puede ser utilizado tanto para generar firmas digitales como para cifrar o descifrar.

- **Criptografía de curva elíptica (CCE):**

Del inglés: Elliptic curve cryptography, ECC.

Está basada en las matemáticas de las curvas elípticas.

Sus autores argumentan que puede ser más rápida y usar claves más cortas que los métodos antiguos (RSA) que proporcionando un nivel de seguridad equivalente.



4.1.2.3. Criptografía Híbrida

Este sistema es la unión de las ventajas de los dos anteriores, debemos de partir que el problema de ambos sistemas criptográficos es que el simétrico es inseguro y el asimétrico es lento.

La criptografía híbrida es un método criptográfico que usa tanto un cifrado simétrico como un asimétrico. Emplea el cifrado de clave pública para compartir una clave para el cifrado simétrico. El mensaje que se esté enviando en el momento, se cifra usando su propia clave privada, luego el mensaje cifrado se envía al destinatario. Ya que compartir una clave simétrica no es seguro, ésta es diferente para cada sesión.

El proceso para usar un sistema criptográfico híbrido es el siguiente (para enviar un archivo):

- Generar una clave pública y otra privada (en el receptor).
- Cifrar un archivo de forma síncrona.
- El receptor nos envía su clave pública.
- Ciframos la clave que hemos usado para encriptar el archivo con la clave pública del receptor.
- Enviamos el archivo cifrado (síncronamente) y la clave del archivo cifrada (asíncronamente y solo puede ver el receptor).

Los algoritmos de cifrado híbridos más conocidos son:

- PGP.
- GnuPG.

4.2. CCN-CERT

El Centro Criptológico Nacional (CCN) es un organismo del estado español adscrito al Centro Nacional de Inteligencia que se dedica a criptoanalizar y descifrar por procedimientos manuales, medios electrónicos y criptofonía, así como realizar investigaciones tecnológico-criptográficas y formar al personal especializado en criptología.

El CCN quedó legalmente regulado por el Real Decreto 421/2004 el 12 de marzo.

El CCN no se trata de una agencia independiente al CNI, sino que, siguiendo el modelo de Alemania o Francia, está integrada en el servicio de inteligencia español, siendo parte y responsabilidad de éste.



Funciones del CCN

- Elaborar y difundir normas, instrucciones, guías y recomendaciones para garantizar la seguridad de los sistemas de las tecnologías de la información y las comunicaciones de la administración del estado.
- Formar al personal de la administración especialista en el campo de la seguridad de los sistemas de las tecnologías de la información y las comunicaciones a través del CCN-CERT.
- Constituir el Organismo de Certificación del Esquema Nacional de Evaluación y Certificación de la Seguridad de las Tecnologías de Información.
- Valorar y acreditar la capacidad de los productos de cifra y de los sistemas de las tecnologías de la información para procesar, almacenar o transmitir información de forma segura.
- Coordinar la obtención y desarrollo de la tecnología de seguridad.
- Proteger la información clasificada.
- Establecer relaciones con órganos similares de otros países.

Dentro del CCN se encuentran dos partes integradas:

- El Organismo de Certificación (OC) del Esquema Nacional de Evaluación y Certificación de la Seguridad de las Tecnologías de Información (**ENECSTI**).
- El Centro Criptológico Nacional Computer Emergency Response Team (**CCN-CERT**).



Atención

En la página oficial puedes consultar las Soluciones de Ciberseguridad.

Debes conocer sus nombres (son nombres propios de mujer), y su función.

<https://www.ccn-cert.cni.es/soluciones-seguridad.html>



4.3. Mecanismos de firma digital

Una firma digital es un mecanismo criptográfico que permite al receptor de un mensaje firmado digitalmente identificar a la entidad originadora de dicho mensaje (autenticación de origen y no repudio), y confirmar que el mensaje no ha sido alterado desde que fue firmado por el originador (integridad).

La firma digital no debe confundirse con Firma electrónica o Firma digitalizada.

Un mecanismo (o esquema) de firma digital consiste en un algoritmo de generación de firma y su algoritmo de verificación asociado.

Para ello se utilizan los protocolos vistos anteriormente:

- De cifrado asimétrico (RSA, DSA y ECDSA).
- De cifrado simétrico con clave pre-compartida (PSK).
- Algoritmo de resumen (MD5 y SHA) y mecanismos de estampado de tiempo para incorporar no-repudio.

4.3.1. Algoritmos de Autenticación Hash

Algoritmos de autenticación (hash), también llamadas funciones hash, de resumen y firmas digitales. (También se les llama funciones digest).



Anécdota

El término hash proviene, aparentemente, de la analogía con el significado estándar (en inglés) de dicha palabra en el mundo real: picar y mezclar.

Las funciones hash no cumplen estrictamente el objetivo de la criptografía, ya que es un cifrado irreversible.



Una función Hash es un algoritmo matemático que transforma, cualquier bloque de datos, sea cual sea su longitud, en una nueva cadena alfanumérica con una longitud fija. El valor hash de salida tendrá siempre la misma longitud.

El más mínimo cambio que pudiera sufrir el bloque de entrada (archivo), alterara el resultado de la función hash, siendo un resultado totalmente diferente.

Los resultados de la función hash son únicos e irrepetibles a partir de la información tratada.

Tiene como entrada un conjunto de elementos, que suelen ser cadenas, y los convierte en un rango de salida finito, normalmente cadenas de longitud fija.

Se dice que estas funciones resumen datos del conjunto dominio.

Estas funciones sirven para:

- Asegurar la autenticidad de datos.
- Almacenar de forma segura contraseñas.
- La firma de documentos electrónicos.
- Tiene como objetivo garantizar la integridad de un mensaje y la autenticación del origen del mensaje.

Ejemplos:

- **MD5:**

Abreviatura de Message-Digest Algorithm 5, en castellano Algoritmo de Resumen del Mensaje 5.

Es un algoritmo de reducción criptográfico de 128 bits ampliamente usado.

Uno de sus usos es el de comprobar que algún archivo no haya sido modificado.

- **SHA-1:**

Abreviatura de Secure Hash Algorithm, en castellano Algoritmo de Hash Seguro.

SHA-0 y SHA-1 producen una salida resumen de 160 bits (20 bytes) de un mensaje que puede tener un tamaño máximo de 2^{64} bits.

- **SHA-2:**

La familia SHA-2 incluye varias variantes con diferentes longitudes de resumen hash. Entre ellas se encuentran SHA-224, SHA-256, SHA-384, SHA-512, SHA-512/224 y SHA-512/256. Cada variante tiene una longitud de resumen hash diferente, pero comparten el mismo diseño básico de seguridad y resistencia criptográfica.



SHA-384 pertenece a la familia de algoritmos de funciones hash criptográficas conocida como SHA-2 (Secure Hash Algorithm 2). SHA-2 es una familia de algoritmos de hash diseñados para proporcionar mayor seguridad que sus predecesores, como SHA-1.

SHA-384, en particular, produce un resumen hash de 384 bits (48 bytes) y se utiliza en aplicaciones donde se requiere un nivel más alto de seguridad en comparación con algoritmos más antiguos como MD5 y SHA-1. En general, SHA-2, incluida SHA-384, es ampliamente utilizado en protocolos de seguridad y aplicaciones criptográficas modernas.

SHA384 es un algoritmo de huella para la firma que se usaría para la aplicación AutoFirma 1.8.2 por las siguientes razones:

- Seguridad: SHA384 es un algoritmo más seguro que ECDSA. Esto se debe a que SHA384 produce un resumen más grande, lo que lo hace más difícil de falsificar.
 - Compatibilidad: SHA384 es compatible con AutoFirma 1.8.2. La FNMT ha aprobado el uso de SHA384 para la firma electrónica, por lo que es un algoritmo compatible con AutoFirma.
- **ECDSA:**

ECDSA es un poco más eficiente que SHA384. Sin embargo, la diferencia en eficiencia es pequeña, y el aumento de seguridad que ofrece SHA384 lo compensa.

Los archivos firmados con SHA384 son solo un poco más grandes que los archivos firmados con ECDSA. Esta diferencia de tamaño es probablemente insignificante para la mayoría de las aplicaciones.

ECDSA, o Elliptic Curve Digital Signature Algorithm, es un algoritmo de firma digital asimétrica que utiliza curvas elípticas. Es un algoritmo seguro y eficiente, y se utiliza en una variedad de aplicaciones, incluyendo la firma electrónica.

La clave pública y la clave privada de ECDSA están relacionadas por una curva elíptica. Una curva elíptica es una curva plana que satisface una ecuación particular.

Para generar una firma, el firmante selecciona un punto aleatorio en la curva elíptica. Luego, multiplica el punto aleatorio por su clave privada. El resultado de la multiplicación es un punto en la curva elíptica. El punto en la curva elíptica es la firma del mensaje.

Para verificar una firma, el destinatario utiliza la clave pública del firmante para multiplicar el punto de la firma por la clave pública. El resultado de la multiplicación debe ser el punto aleatorio que utilizó el firmante para generar la firma.

Si el resultado de la multiplicación es el punto aleatorio, entonces la firma es válida.

ECDSA es un algoritmo de firma digital asimétrica seguro, eficiente y compatible. Es una buena opción para una variedad de aplicaciones.



- **DSA:**

Siglas de Digital Signature Algorithm, en castellano Algoritmo de **Firma digital**.

Es un estándar del Gobierno Federal de los Estados Unidos de América o FIPS para firmas digitales.

Fue un Algoritmo propuesto por el Instituto Nacional de Normas y Tecnología de los Estados Unidos para su uso en su Estándar de **Firma Digital** (DSS), especificado en el FIPS 186.

DSA se hizo público el 30 de agosto de 1991.

Este algoritmo:

- Sirve para firmar.
- No sirve para cifrar información.

Una desventaja de este algoritmo es que requiere mucho más tiempo de cómputo que RSA.

4.3.2. Formatos de firma digital

Los formatos de firma digital son estándares que garantizan la interoperabilidad, la validez legal y la seguridad de los documentos firmados electrónicamente. Estos formatos permiten encapsular datos y añadir elementos esenciales como firmas digitales, certificados, y sellos de tiempo, asegurando la autenticidad e integridad de los documentos.

4.3.2.1. Estándares

Los formatos de firma digital están basados en una serie de estándares técnicos que definen cómo estructurar, encapsular y proteger los datos. Los principales estándares incluyen:

CMS (Cryptographic Message Syntax)

Definido en la RFC 5652, es un estándar para encapsular datos de manera segura, soportando operaciones como firmas digitales y cifrado. Es la base para formatos avanzados como CAdES y para correos seguros mediante S/MIME. Se utiliza en firmas digitales en documentos binarios y para la protección de mensajes.

XML (Extensible Markup Language)

Estándar utilizado para comprimir y combinar múltiples archivos. Su función principal en el contexto de firmas digitales es contener documentos firmados junto con sus metadatos en un solo archivo, como en el estándar ASiC. Es ideal para proyectos que requieren almacenar y firmar varios documentos simultáneamente.



ZIP (Formato comprimido)

Es un estándar de compresión y combinación de archivos, su función principal es la de contener documentos firmados junto a sus metadatos en un solo archivo, por ejemplo en ASiC. Se usa en proyectos que requieren almacenado y firma de varios documentos simultáneamente.

PDF (Portable Document Format)

El formato PDF soporta firmas digitales integradas de forma nativa. La tecnología PAdES, basada en PDF, garantiza la validez legal y la interoperabilidad de estas firmas digitales. Es especialmente útil para documentos empresariales, contratos y acuerdos legales.

ASN.1 (Abstract Syntax Notation One)

Estándar para la representación de datos en sistemas criptográficos. Proporciona soporte técnico para formatos como CMS y otros estándares criptográficos. Se utiliza principalmente en certificados digitales y sistemas de autenticación.

4.3.2.2. Formatos Principales

CAdES (CMS Advanced Electronic Signature)

Extiende el estándar **CMS** (Cryptographic Message Syntax) añadiendo funcionalidades específicas para firmas digitales avanzadas. Sus principales perfiles incluyen:

- **BES** (Basic Electronic Signature) incluye los datos firmados y el certificado del firmante.
- **EPES** (Explicit Policy Electronic Signature): Agrega una referencia a una política de firma.
- **T** (Timestamp): Incorpora sellos de tiempo para garantizar la validez temporal.
- **C, X, X-L y A**: Diseñados para firmas de larga duración, incluyen referencias adicionales a certificados, listas de revocación, y otros elementos que garantizan la validez legal a lo largo del tiempo.

Se usa en contratos digitales, transacciones legales y documentos empresariales que requieren validez legal a largo plazo.

XAdES (XML Advanced Electronic Signature)

Ideal para los documentos estructurados:

- **BES y EPES**: Similares a CAdES pero adaptados a XML.
- **T, C, X, X-L y A**: Perfiles avanzados con sellos de tiempo y soporte para firmas de larga duración.

Facturación electrónica, aplicaciones gubernamentales, interoperabilidad en sistemas administrativo.



PAdES (PDF Advanced Electronic Signature)

Diseñado para incluir firmas digitales directamente en documentos PDF. La firma se integra al documento y permanece accesible al lector. Compatibilidad con verificación visual y digital. Usos: Contratos legales, informes financieros y documentos que deben mantenerse inalterables.

ASiC (Associated Signature Containers)

Es un formato contenedor que puede comprender firmas **CAdES, XAdES o PAdfES**. Usado como veíamos para archivos que integran varios documentos, auditorías, paquetes de y archivos de cumplimiento normativo.

4.4. Uso de protocolos

Para garantizar la confidencialidad de la información, debemos proporcionar a los usuarios de los equipos, la formación y herramientas necesarias (protocolos criptográficos).

También utilizamos en las comunicaciones los diferentes protocolos actuales. Entre otros se incluyen los siguientes:

- SSH para el acceso seguro remoto a la administración de equipos (no utilizar Telnet que no va cifrado).
- SFTP/FTPS para la transferencia segura de ficheros.
- HTTPS para la transferencia segura de datos en servicios web críticos (pagos online, descarga de información sensible, etc.).

(Estos protocolos se estudiarán en unidades posteriores).



+ Info

Cifrado de la wifi de la empresa.

La configuración debe hacerse con el estándar de cifrado más seguro, actualmente WPA2, y se debe cambiar la clave inicial por defecto, y también realizar cambios periódicos.



4.5. Certificados digitales

4.5.1. Concepto

El certificado digital, también conocido como certificado de seguridad, es un documento electrónico que usa una infraestructura de clave pública (PKI) a la que se vinculará la identidad de un servidor, dispositivo, organización o persona. Los certificados son emitidos por una entidad confiable llamada Autoridad de Certificación (CA) y que jugará un papel esencial en la seguridad de las comunicaciones.

4.5.2. Autoridades de Certificación

- Let's Encrypt: es la CA (Autoridad de Certificación) más popular del mundo, gratuita y de código abierto ofrece a quien lo solicite los certificados SSL/TLS.
- Comodo CA.
- DigiCert.
- GoDaddy.
- GlobalSign.
- Thales.
- Entrust Datacard.
- SSL.com.

Autoridades de Registro

La RA (Autoridad de Registro) actúa como intermediaria entre el solicitante y la CA. Su función principal es validar la identidad de los solicitantes antes de que se emita el certificado. Aunque en muchos casos la RA y la CA pueden ser parte de la misma entidad, algunas veces están separadas. La RA verifica los documentos del solicitante y garantiza que la información proporcionada sea legítima y precisa.

4.5.3. Funciones

Si nos acercamos un poquito más, veremos que tiene determinados cometidos:

- **Autenticación:** verifica que el servidor es auténtico y es quien dice ser, asegurando que el sitio web es legítimo.
- **Cifrado:** habilita la encriptación de datos entre usuario y servidor evitando que la información sensible pueda ser interceptada.
- **Integridad:** garantiza que los datos no hayan sido alterados durante la transmisión, pues en el caso en que lo fueran darían un aviso al usuario.



4.5.4. Tipos: gratuito y de pago

Los certificados digitales son herramientas esenciales para garantizar la seguridad pues aseguran la autenticación y verifican la identidad de entidades y sitios web.

Se pueden encontrar dos tipos principales de certificados digitales de pago y gratuitos.

Los certificados mínimos exigibles para una CA gratuita, son los certificados:

- **DV (Domain Validation)**: es el certificado de validación de dominio, su cometido es el de validar la propiedad del dominio solicitante. Adecuados para pymes y webs personales.
- **OV (Organization Validation)**: valida la existencia e identidad de la organización solicitante. Más seguros que los anteriores y adecuados para sitios web que maneja información sensible: comercio electrónico, sitios web de bancos.

No todas las Autoridades de Certificación sin ánimo lucro, emiten todos los certificados, como es el caso del certificado de **Validación Extendida**:

- **EV (Extended Validation)**: para emitir este certificado se debe verificar y validar la identidad, legitimidad y autenticidad del solicitante. Su presencia en el navegador es revelada con una barra verde en la barra de direcciones indicando al usuario su grado de seguridad y confiabilidad. Este certificado se usa cuando los datos son de alta sensibilidad o confidencialidad. Webs bancarios online, sitios web gubernamentales.

El nivel de seguridad de los certificados de pago suele ser más elevado (medio o alto) que el de los gratuitos, además a diferencia de estos últimos cuentan con soporte, pueden incluir funciones adicionales como herramientas de gestión de certificados, comodines SAN, soporte para varios dominios y sellos de sitio.

4.5.5. Composición

Son unos documentos que suelen estar formados por una clave pública, el nombre del propietario, el de la entidad emisora, indica asimismo el periodo de validez (el certificado caduca y ha de ser mantenido) y la firma digital de la CA.

Además de los certificados orientados a servidores web (SSL/TLS), existen también certificados electrónicos personales que permiten la identificación del titular y la firma digital. Estos certificados no se utilizan en servidores, sino por ciudadanos o empleados públicos, y requieren mecanismos de custodia más estrictos para proteger la clave privada.

Las **smart cards** son tarjetas criptográficas que incorporan un chip con capacidad para generar y custodiar claves privadas de forma segura, realizando internamente las operaciones de firma sin permitir nunca la extracción de la clave. Funcionan de manera similar a una tarjeta bancaria con chip, pero destinadas a usos de identificación y firma electrónica.



Almacenamiento seguro del certificado

Además de almacenarse en archivos de software dentro del sistema, los certificados personales y sus claves privadas pueden custodiarse en dispositivos criptográficos seguros como las smart cards y el DNle. Estos soportes incluyen un chip capaz de realizar internamente las operaciones de firma y cifrado, sin permitir en ningún caso que la clave privada sea extraída. Para su uso se requiere la autenticación mediante un PIN, lo que añade una capa adicional de seguridad y evita accesos no autorizados al certificado.

4.5.6. Específicos o multipropósito

Los certificados pueden ser específicos (para un protocolo determinado) o bien multipropósito. Estos últimos asegurarán distintos protocolos (P.e: HTTP, FTP, SMTP, IMAP, POP3 pasándolos a HTTPS, SFTP, SMTPS, IMAPS, POP3S).

4.5.7. Proceso de obtención

El proceso de obtención de un certificado digital consta de varios pasos:

1. **Generación claves:** el solicitante generará las claves privada y pública a través de un software específico que usará un algoritmo criptográfico como el de curva elíptica (Elliptic Curve Cryptography, ECC) o RSA.

Mantendrá la clave privada secreta y en lugar seguro (archivo cifrado o módulo de seguridad de hardware -HSM), alejada de accesos no autorizados.

Crearé una solicitud, por último, que deberá incluir la clave pública y la información del solicitante.

2. Solicitud: **Envío de solicitud** a la Autoridad Certificadora (CA) para el nombre de dominio elegido.
3. **Instalación:** Tras esto la CA emitirá el certificado en formato electrónico y lo enviará al solicitante que habrá de **instalarlo en el servidor o dispositivo solicitante**.

4.5.8. Mantenimiento, renovación y revocación

Al ser la **vida útil del certificado limitada** habrá de renovarse periódicamente para garantizar su validez. Un proceso que será similar al inicial, pero en el que no habrán de generarse nuevas claves.

Si el certificado ha sido vulnerado o ya no es útil, habrá de revocarse. Para ello una vez se haya notificado a la CA correspondiente, ésta lo incluirá en las listas de certificados revocados CRL (Certificate Revocation List), con el fin de que los navegadores y demás software cliente puedan asegurarse de que ya no son válidos.



Las auditorías periódicas son importantes para identificar y corregir fallas de seguridad relacionadas con estos documentos electrónicos. Monitorización y auditorías para comprobar fechas y estado de revocación son esenciales.

Se pueden encontrar diversas herramientas para la gestión automática de las renovaciones, revocaciones, detección de amenazas y monitorizaciones de estado.

4.5.9. Jerarquías de PSC

PSC es el acrónimo de Políticas de Seguridad de Certificación o Puntos de Certificación de Seguridad. Términos que hacen referencia a cómo se organizan en un sistema jerárquico las Autoridades de Certificación con el fin de maximizar la seguridad. Todas ellas emiten Certificados de Seguridad, pero no para los mismos destinatarios.

Los puntos de certificación de seguridad están formados por distintas Autoridades de Certificación (CA) de distinto rango. Se dividen fundamentalmente en tres grupos, los CAs Raíz o Root CAs, los CAs intermedios y en algún caso las CAs subordinadas. Las intermedias serán certificadas por la firma de las CAs raíz. Las CAs raíz poseen un certificado autofirmado y se encuentra la mayor parte del tiempo offline pues ver comprometida su clave privada y pondría en riesgo no solo a las autoridades avaladas por ellas mismas sino todos los certificados firmados por estas últimas, intermedias.

Las CAs intermedias proporcionarán certificados a los propietarios de dominios o a los usuarios finales. Los clientes web antes de establecer una comunicación con cifrado simétrico verificarán la cadena de confianza hasta llegar a una autoridad raíz. El proceso de verificación de un certificado consta de varios pasos: verificación de la firma digital (encriptación del hash), descifrándola con la clave pública incluida en propio navegador. Comprobación de la vigencia del certificado. Cálculo del hash especificado en el propio certificado y comparación del recién calculado con el descriptado. Se le dará validez si se cumplen estos pasos. El proceso se repetirá hasta llegar a la CA raíz en la que el certificado no nos llevará más atrás.

5. Single Sign-On

El "Inicio de Sesión Único" o "Inicio de Sesión Unificado" (Single Sign-On, SSO) es un procedimiento de autenticación que habilita a un usuario determinado para acceder a varios sistemas con una sola instancia de identificación. Su traducción literal es «autenticación única» o «validación única».

Hay cinco tipos principales de SSO, también se les llama reduced sign on systems ("sistemas de autenticación reducida").

- **Enterprise SSO (E-SSO)**

También llamado *Legacy SSO*, funciona para una autenticación primaria, interceptando los requisitos de login presentados por las aplicaciones secundarias para completar los mismos con el usuario y contraseña. Los sistemas E-SSO permiten interactuar con sistemas que pueden deshabilitar la presentación de la pantalla de login.



- **Web SSO (Web-SSO)**

También llamado gestión de acceso web (web access management, Web-AM o WAM) trabaja solamente con aplicaciones y recursos accedidos vía web.

El objetivo es permitir autenticar a los usuarios en diversas aplicaciones, sin necesidad de volver a autenticar.

Los accesos son interceptados con la ayuda de un servidor proxy o de un componente instalado en el servidor web o en la aplicación web destino.

Los usuarios no autenticados que tratan de acceder son redirigidos a un servidor o servicio web de autenticación y regresan solamente después de haber logrado un acceso exitoso o con un TOKEN de autenticación para la aplicación destino.

Se utilizan cookies, parámetros por GET (más inseguro) o POST para reconocer aquellos usuarios que acceden y su estado de autenticación.

- **Kerberos**

Es un método popular de externalizar la autenticación de los usuarios. Los usuarios se registran en el servidor Kerberos y reciben un tique, luego las aplicaciones cliente lo presentan para obtener acceso.

- **Identidad federada**

Es una nueva manera de enfrentar el problema de la autenticación, también para aplicaciones Web. Utiliza protocolos basados en estándares para habilitar que las aplicaciones puedan identificar los clientes sin necesidad de autenticación redundante.

- **OpenID**

Es un proceso de SSO distribuido y descentralizado donde la identidad se compila en un Localizador Uniforme de Recursos (URL) que cualquier aplicación o servidor puede verificar.

6. Infraestructura física de un CPD: acondicionamiento y equipamiento

CPD es un centro de proceso de datos, o también llamado Data Center.

Son grandes edificios seguros que cuentan con una serie de instalaciones de servidores en red. Permiten el almacenamiento de datos y disponen de unos sistemas de recuperación, redundancia y seguridad que proporcionan entornos controlados seguros de almacenaje de datos.

Las grandes compañías gestionan centros de datos que les permiten almacenar datos operativos de su empresa, o bien ofrecer servicios cloud (en la nube) a sus clientes.



Básico

El software como servicio (SaaS) permite a los usuarios conectarse a aplicaciones basadas en la nube a través de Internet y usarla.

Uno de los mayores puntos de confusión en el campo del uptime (tiempo disponible de los sistemas) es definir si un Data center es confiable, ya que lo que es aceptable para una persona o compañía no lo es para otra.

Diferentes empresas competitivas con infraestructuras de Data Center totalmente diferentes pueden proclamar que poseen alta disponibilidad, esto puede ser cierto ya que, dependerá de la interpretación subjetiva de disponibilidad que se realice para el tipo de negocio en que se encuentre una compañía.

Para aumentar la redundancia y los niveles de disponibilidad, los puntos únicos de falla deben ser eliminados tanto en el Data Center como en la infraestructura que le da soporte.

La industria tecnológica distingue cuatro modalidades de tipos de Data Center clasificándolos en cuatro niveles distintos, (definidos en la norma TIA 942).

Los veremos al estudiar la norma TIA 942, pero veamos un primer resumen:

- **Tier I:**

Se trata del tipo más básico de centro de datos. Sólo pueden garantizar la continuidad del servicio al 99,671%, aunque parece una gran cantidad, en realidad es la más baja que existe.

En un Data Center de Tier 1 se puede interrumpir el servicio sin previo aviso. No cuentan, además, con sistemas de redundancia y refrigeración.

- **Tier II:**

Su disponibilidad es algo superior a la del anterior, del 99,741%.

Disponen de sistemas de redundancia, generadores auxiliares de energía y suelos elevados, entre otras ventajas. Sin embargo, aún pueden presentar interrupciones imprevistas.



- **Tier III:**

Su disponibilidad es del 99,98%.

No se ven afectados por interrupciones no programadas. Es decir, sólo cuando se van a llevar a cabo acciones de mantenimiento, los servidores afectados de dicho tipo de Data Center interrumpirán su servicio. Están conectados a diferentes redes eléctricas y cuentan con un sistema de refrigeración avanzado.

- **Tier IV:**

Son el tipo más avanzado, ofrecen una disponibilidad de 99,995%.

Esto significa que sólo se detienen durante 26 minutos a lo largo de todo año.

Se trata del nivel más alto de disponibilidad. Son altamente tolerantes a fallos.

Cuentan con un alto nivel de redundancia, sistemas de refrigeración de alta eficiencia. Disponen también de redes de fibra complementaria y sistemas de suministro eléctrico alternativo.

6.1. El Estándar TIA 942

La Telecommunication Industry Association (ANSI-TIA: American National Standards Institute – Telecommunications Industry Association) aprueba y publica su estándar TIA-942 en abril de 2005.

El estándar TIA 942, provee una serie de recomendaciones y directrices (Guide Lines), para el diseño e instalación de infraestructuras de Data Centers. El objetivo es unificar criterios en el diseño de comunicaciones, especificaciones para cableado etc.

Al diseñar los centros de datos conforme a la norma, se obtienen ventajas fundamentales, como son:

- Nomenclatura estándar.
- Funcionamiento a prueba de fallos.
- Aumento de la protección frente a agentes externos.
- Fiabilidad a largo plazo, mayores capacidades de expansión y escalabilidad.

Áreas funcionales de un CPD

También siguiendo las indicaciones del estándar, un CPD deberá incluir varias áreas funcionales:

- Una o varias entradas al centro.
- Área de distribución principal.
- Una o varias áreas de distribución principal.



- Áreas de distribución horizontal.
- Área de equipo de distribución.
- Zona de distribución.
- Cableado horizontal y backbone.

Subsistemas de un CPD

De acuerdo con el estándar TIA-942, la infraestructura de soporte de un CPD estará compuesta por cuatro subsistemas:

- **Telecomunicaciones:** Cableado de armarios y horizontal, accesos redundantes, cuarto de entrada, área de distribución, backbone, elementos activos y alimentación redundantes, patch panels y latiguillos, documentación.
- **Arquitectura:** Selección de ubicación, tipo de construcción, protección ignífuga y requerimientos NFPA 75 (Sistemas de protección contra el fuego para información), barreras de vapor, techos y pisos, áreas de oficina, salas de UPS y baterías, sala de generador, control de acceso, CCTV, NOC (Network Operations Center – Centro operativo).
- **Sistema eléctrico:** Número de accesos, puntos de fallo, cargas críticas, redundancia de UPS y topología de UPS, puesta a tierra, EPO (Emergency Power Off- sistemas de corte de emergencia) baterías, monitorización, generadores, sistemas de transferencia.
- **Sistema mecánico:** Climatización, presión positiva, tuberías y drenajes, CRACs y condensadores, control de HVAC (High Ventilating Air Conditionning), detección de incendios y sprinklers, extinción por agente limpio (NFPA 2001), detección por aspiración (ASD), detección de líquidos.

El estándar TIA 942, indica una clasificación a los CPD, indicando así su nivel de fiabilidad en función del nivel de disponibilidad. Esta clasificación se establece en 4 niveles denominados TIER.

6.1.1. El concepto de TIER

El estándar TIA 942, en su anexo G (informativo) y basado en recomendaciones del Uptime Institute, establece cuatro niveles (tiers) en función de la redundancia necesaria para alcanzar niveles de disponibilidad de hasta el 99.995%.



+ Info

Los cuatro niveles de Tiers que plantea el estándar, se corresponden con cuatro niveles de disponibilidad, teniendo que a mayor número de Tier mayor disponibilidad, lo que implica también mayores costos constructivos.



El nivel de fiabilidad de un centro de datos viene indicado por uno de los cuatro niveles de fiabilidad llamados TIER, en función de su redundancia. A mayor número de TIER, mayor disponibilidad, y por tanto mayores costes de construcción y mantenimiento.

TIER	% Disponibilidad	% Parada	Tiempo anual de parada
TIER I	99,67%	0,33%	28,82 horas
TIER II	99,74%	0,25%	22,68 horas
TIER III	99,98%	0,02%	1,57 horas
TIER IV	100,00%	0,01%	52,56 minutos

TIER I- Nivel 1 Básico (Sistema de cobre):

- Disponibilidad del 99,671 %.
- Sensible a las interrupciones, planificadas o no.
- Un solo paso de corriente y distribución de aire acondicionado, sin componentes redundantes.
- Sin exigencias de piso elevado.
- Generador independiente.
- Plazo de implementación: 3 meses.
- Tiempo de inactividad anual: 28,82 horas.
- Debe cerrarse completamente para realizar mantenimiento preventivo.

TIER II- Nivel II (Componentes redundantes):

- Disponibilidad del 99,741 %.
- Menor sensibilidad a las interrupciones.
- Un solo paso de corriente y distribución de aire acondicionado, con un componente redundante.
- Incluye piso elevado, UPS y generador.
- Plazo de implementación: 3 a 6 meses.
- Tiempo de inactividad anual: 22,68 horas.
- El mantenimiento de la alimentación y otras partes de la infraestructura requieren de un cierre de procesamiento.



TIER III- Nivel III (Mantenimiento concurrente):

- Disponibilidad 99,982 %.
- Interrupciones planificadas sin interrupción de funcionamiento, pero posibilidad de problemas en las no previstas.
- Múltiples accesos de energía y refrigeración, por un solo encaminamiento activo. Incluye componentes redundantes (N+1).
- Plazo de implementación: 15 a 20 meses.
- Tiempo de inactividad anual: 1,6 horas.

TIER IV- Nivel IV (Tolerante a errores):

- 99,995 % de disponibilidad.
- Interrupciones planificadas sin interrupción de funcionamiento de los datos críticos. Posibilidad de sostener un caso de imprevisto sin daños críticos.
- Múltiples pasos de corriente y rutas de enfriamiento. Incluye componentes redundantes. Incluye componentes redundantes (2(N+1))- 2 UPS cada uno con redundancia (N+1).
- Plazo de implementación: 15 a 20 meses.
- Tiempo de inactividad anual: 0,4 horas.

Esta clasificación es aplicable en forma independiente a cada subsistema de la infraestructura (telecomunicaciones, arquitectura, eléctrica y mecánica). Hay que tener en cuenta que la clasificación global del Data Center será igual a la de aquel subsistema que tenga el menor número de Tier.

Por tanto, si un Data Center tiene todos los subsistemas Tier IV excepto el eléctrico que es Tier III, la clasificación global será Tier III.

Si se quiere actualizar un Data Center que tiene una clasificación global de Tier III, para que tenga un Tier IV, hay que tener en cuenta, que en ocasiones hay limitaciones físicas difíciles de salvar en los emplazamientos edificios actuales. (como en lugares como América Latina). Por ejemplo, es muy difícil lograr la provisión de energía de dos subestaciones independientes o poder lograr las alturas que requiere el estándar en los edificios existentes (3 m mínimo sobre piso elevado y no menor de 60 cm entre el techo y el equipo más alto).

En general, para lograr un Data Center Tier IV hay que diseñarlos desde cero siguiendo el estándar como guía.



6.1.2. Novedades en el cableado

El estándar TIA 942 (A), introduce también modificaciones en el campo del cableado, tanto en fibra como en cobre.

Si bien se trata de una normativa de origen USA, el estándar ANSI/TIA-942, editado en 2005, puede ser considerado como "un sistema genérico de cableado para los Data Centers y su ámbito de influencia" (Página IX de la normativa).

6.1.3. Actualizaciones del Estándar TIA 942

La Telecommunication Industry Association, realiza revisiones y actualizaciones en su estándar TIA 942, a medida que avanza el desarrollo de las comunicaciones (velocidad, cableado, etc.).

Actualización 2013

En su actualización de 2013 se incorporan las siguientes novedades:

- La utilización en los DC de fibras multimodo queda reservada a los tipos OM3 y OM4 (50/125), y equipos con emisores LASER 850 nm. Quedando prohibida la utilización de fibras de los tipos OM1 y OM2 anteriormente empleados.
- Para los cableados de cobre, se recomienda el empleo de Cat6 (mínimo) y Cat6A apantallados. En este campo se coincide con ISO/IEC 24764, que reconoce únicamente enlaces Clase EA (Cat 6^aA).
- Queda suprimida la limitación de 100 m. de longitud en cableados horizontales, para la fibra óptica, quedando la definición de este concepto a la responsabilidad del fabricante.
- Conectores ópticos: queda reducida la selección a los tipos LC Dúplex, para cables dúplex, y MPO para más de 12 fibras.
- Se recomienda el uso de arquitecturas centralizadas y jerárquicas, por ser más flexible que los enlaces directos.
- Queda reestructurada la organización de los entornos DC, incluyendo tres tipos de áreas: MDA (Main Distribution Area), IDA (Intermediate Distribution Area), HDA (Horizontal distribution Area) y ZDA (Optional Zone Distribution Area); algunas de las cuales pueden precisar de cableados supletorios. Con ello, instalaciones amplias pueden precisar de varias ubicaciones y varios IDAs, con cableados redundantes.

Actualización 2017

En 2017 el estándar TIA 942 se actualizó con la **revisión B**, y los cambios más destacados son:

- Añade soluciones *fabric* para proporcionar la máxima funcionalidad.
- Incorporación del uso de conectores MPO.



- Utilización de la categoría 8 de par trenzado.
- Añade la fibra multimodo de banda ancha (OM5).



+ Info

Dell Active Fabric Controller:

Nuevo software para aprovisionamiento y orquestación automatizado de funciones y servicios de red virtualizados que, permite de manera simple y segura, configurar y desplegar funciones de red para entornos de nube y XaaS.

Presentación de Tier 5

El nuevo Tier 5 se ha presentado por la compañía americana Switch, que da servicio a los Data Centers (suele decirse que proporciona servicios "a la americana", que significa a lo grande).

Las aportaciones del Tier 5 frente al Tier IV de Uptime, en principio son las siguientes:

- En el **sistema de refrigeración**, se añaden las exigencias:
 - El CPD tenga capacidad de funcionar siempre sin agua.
 - El CPD tenga capacidad de detección de contaminantes en el exterior y pueda ser capaz de protegerse contra ellos.
- En el **sistema eléctrico**:
 - Durante el 90% del mantenimiento, las dos ramas A y B permanecen operativas.
 - El sistema de almacenamiento de energía tiene una redundancia N+1 y siempre está monitorizado.
 - La monitorización de los circuitos debe ser desde el SAI a los cuadros de distribución.
 - Se exige que los CPD tengan tres grupos generadores, que deben estar en tres instalaciones independientes, totalmente funcionales y operativas, monitorizando el sistema y también tres sistemas de conmutación.



- **Servicios de CARRIER** (proveedor de servicios de comunicaciones):
 - 10 carriers disponibles para cada cliente.
 - 6 entradas de comunicaciones que deben tener acceso al menos por dos zonas de acometida distintas.
 - Servicios de mitigación de DDoS (prevención de ataques) para todos los clientes.
- **Seguridad física:**
 - Los accesos de personal deben tener un sistema de identificación por foto y un control que registre los tiempos de acceso/fechas/usuario durante 180 días.
 - En todas las entradas, el control de acceso para personas debe controlarse con esclusas (compartimento con puerta de entrada y de salida cuyo objetivo es controlar el acceso a áreas de seguridad).
 - El control de acceso debe autenticar a cada titular de la tarjeta por PIN/biométrico/Two Person Integrity.
 - Debe haber video vigilancia monitorizada y activada por movimiento para las entradas y los espacios del servicio. El sistema debe ser de 15 imágenes/segundo y una grabación mínima de 90 días.
 - Debe estar securizado el acceso a los activos y redes de los sistemas críticos: seguridad, telecomunicaciones, refrigeración y potencia.
 - El Programa de Control de Acceso regula el acceso a las zonas operativas.
 - En cada rack debe haber dispositivos de protección.
 - Cada compartimentación de la sala debe de ser segura de forma independiente. Y no puede haber ningún material inflamable en las salas de computación.
 - Las paredes exteriores de la instalación deben ser no inflamables, sin ventanas.
 - Las puertas exteriores deben estar reforzadas, en un bastidor de acero que está completamente lleno de lechada y, en caso de no haber personal de seguridad, no deben tener bisagras visibles.
 - El edificio debe tener limitación en el acceso de vehículos y/o personal con, al menos, una valla perimetral. Esta valla debe ser de 7 pies de altura y 18 pulgadas de grosor como mínimo, y tener una protección superior de alambre de púas de 3 hilos o similar con 45 grados de orientación hacia el exterior.
 - En una situación de aislamiento, el edificio debe poder mantener las operaciones de seguridad durante 100 horas.
 - Debe haber estándares auditables para los datos lógicos alojados.



- Como mínimos semestralmente, el equipo de seguridad realizará evaluaciones de amenazas de seguridad de acuerdo con los métodos cuantitativos y cualitativos establecidos para la instalación.
- No puede haber instalaciones vecinas de alto riesgo (materiales peligrosos, inflamables, explosivos o riesgos nucleares).
- Las operaciones de seguridad emplearán las más estrictas herramientas de seguridad física permitidas por la ley.
- **Protección contra el agua:**
 - El tejado deberá ser de doble capa con un sistema reparable/reemplazable de manera independiente.
 - El DPC debe estar localizado fuera de un área declarada cómo inundable en los 100 años anteriores.
 - Toda el agua del sistema de refrigeración debe de estar fuera de la envolvente del edificio (no en salas o ubicada encima de las mismas).
 - El responsable de la empresa suministradora debe proporcionar una carta de garantía firmada.
- **Sostenibilidad y Eficiencia:**
 - La energía debe de ser 100% renovable.
 - Proyectos locales, nuevos y renovables operativos.
 - PUE promedio (12 meses) inferior a 1,3.

El PUE es el resultado de dividir los consumos eléctricos totales en un CPD entre el consumo exclusivo de los sistemas IT (aislado de tierra).

Cableado de fibra óptica de alta densidad MTP / MPO

Puesto que el crecimiento de datos transmitidos es cada vez mayor, se van desarrollando nuevos cableados. A pesar de la utilización en los CPD de cables de fibra tradicionales, puede haber momentos en que el centro esté saturado.

Por ello, han aparecido los cables MTP / MPO, que unen 8, 12 o 24 fibras en una sola interfaz.

Los conectores MPO están disponibles en una versión hembra (sin clavijas) o en una versión macho (con clavijas). La conexión asegura una alineación exacta, y evita que las caras finales de las fibras puedan estar desplazadas.



6.2. Condiciones del edificio y de la sala

Estas salas requieren unas especificaciones y requerimientos particulares para garantizar la continuidad de la actividad informática, la disponibilidad de los servicios de información y proteger tanto la información como los equipos.

El conjunto de las medidas preventivas ante posibles riesgos y las acciones alternativas se plasma en un conjunto de procedimientos llamado plan de contingencias.

6.2.1. Situación y accesos

- Debe estar ubicado en una zona alejada de cualquier riesgo o peligro potencial:
 - Polución de aire.
 - Humedad excesiva.
 - Riesgo de inundación.
 - Focos de calor.
 - Vibraciones.
 - Zonas de trabajo pesado.
 - Zonas con excesivo tráfico de personas y materiales.
 - Zonas donde se almacene o se puedan acumular materiales combustibles o gases explosivos.
 - Fuentes de interferencia de radio o radar.
- Con acceso adecuado para la entrega y el movimiento normal de suministros y máquinas:
 - El muelle de carga, los pasadizos, los pasillos, las puertas y los montacargas deben permitir el movimiento de elementos pesados y de grandes dimensiones.
 - Se definirá una ruta libre de obstáculos desde el muelle de carga hasta el CPD.

6.2.2. Dimensiones

- El suelo debe soportar el peso del:
 - Equipo informático.
 - Resto de los elementos a instalar, incluidos los cables y el falso suelo.



- La superficie total requerida queda determinada por:
 - Los equipos informáticos.
 - Las zonas de paso.
 - Mobiliario.
 - Almacenamiento de cintas, discos, documentos y otros suministros.
 - Espacio adicional para aire acondicionado, instalación eléctrica y equipos de protección contra incendios.
 - Previsión de futuras ampliaciones.
- La altura útil de trabajo entre suelo y techo de la sala (no la del edificio, ya que probablemente habrá falso techo y/o suelo) debe ser suficiente para:
 - Abrir la cubierta de los equipos y de las máquinas para su mantenimiento.
 - Permitir la circulación de aire.

Los materiales combustibles se almacenarán en áreas convenientemente diseñadas y protegidas.

6.2.3. Falso suelo

El falso suelo es un espacio entre el suelo del edificio (forjado) y el suelo de trabajo de la sala, y puede ser utilizado para:

- Aportar aire a la sala.
- Mejorar el aislamiento.
- Aportar flexibilidad a la sala con vistas a posteriores cambios de ubicación de equipos.
- Realizar la distribución rápida de:
 - Cables eléctricos.
 - Cables de comunicaciones.
 - Cables de aire acondicionado.
 - Conductos de agua.

El falso suelo se realiza mediante paneles de material incombustible y tiene resistencia mecánica para soportar el peso de los equipos y de la actividad de la sala.



6.2.4. Iluminación

- El nivel de iluminación general de la sala debe ser de 300 a 500 lux para evitar fatiga de los ojos.
- Se aconseja que las áreas de trabajo se pinten de un color claro, con el techo blanco para reflejar la luz.
- Deslumbramiento: las ventanas no estarán en el campo de visión de los usuarios ni se reflejarán sobre las pantallas del ordenador.
- Las pantallas de los ordenadores y de los puestos de trabajo deben estar alineadas y paralelas, dejando a sus lados las líneas en las que se disponen las luces fluorescentes, formando una T con la línea de las luces.
- La iluminación de emergencia se debe alimentar y mantener para que pueda ser vista y tenga la intensidad luminosa suficiente para garantizar una salida segura en caso de emergencia.

6.2.5. Acústica

El nivel de ruido puede reducirse de varias formas:

- Con la separación y orientación de los equipos emisores de ruidos.
- Empleando materiales absorbentes en suelo y techo.
- Las paredes se deben construir desde el suelo al techo del edificio (no de la sala).
- Las puertas deben cerrarse correctamente.

6.2.6. Especificaciones ambientales

Las especificaciones ambientales que debe cumplir una sala de ordenadores son:

- Temperatura de 18 a 24 °C (nominal 21 °C).
- Variación de la temperatura 3 °C/hora, como máximo.
- Humedad relativa del 40% al 60% (nominal 50%).
- Variación de la humedad relativa 6%/hora, como máximo.

Se recomienda el uso de medidores y registradores de temperatura y de humedad relativa en la sala, debidamente distribuidos, que pueden incorporar una señal audible o visual si alguno de los límites se sobrepasa, así como activar procesos automáticos de apagado del sistema y desconexión de la alimentación eléctrica.



6.2.7. Contaminación y limpieza del aire

Dependiendo de la contaminación en el aire, se deberán utilizar filtros especiales, mecánicos o electrostáticos, apropiados contra ellos.

El polvo contribuye a problemas asociados a los medios de soporte magnéticos (cintas y discos). La protección contra el polvo se puede conseguir:

- Verificando el correcto cierre de las ventanas y manteniendo las puertas cerradas.
- Limitando el acceso a la sala y el almacenamiento de material.
- Recirculando el aire de la sala mediante el equipo de aire acondicionado, con una mínima renovación de aire fresco del exterior que vendrá filtrado.
- Colocando la sala con una cierta sobrepresión respecto al exterior.
- Armarios para guardar y almacenar discos y cintas.
- Inspección periódica del falso suelo y techo, y su limpieza periódica con aspirador.

En las operaciones de limpieza, los aspiradores no se deben conectar en las bases de enchufes de los circuitos de alimentación eléctrica de los equipos informáticos, sino que debe existir al menos un circuito eléctrico propio y diferenciado.

6.2.8. Sistema de protección contra incendios

En la sala del CPD se deben usar materiales ignífugos o resistentes al fuego en la construcción. El sistema de protección contra incendios debe constar de:

- Un sistema de detección del fuego:
 - En la sala de ordenadores.
 - En la zona de almacenamiento de datos.
- Un sistema de extinción con elementos:
 - Fijos: para incendios de grandes dimensiones.

Se debe instalar con él un sistema de alarma que entre en funcionamiento con el sistema de extinción.

Debido al hecho de que se produce la descarga de un gran volumen de agua, es necesario prever en el suelo del edificio un sistema de drenaje y desagüe para evacuar el agua y evitar la acumulación en el falso suelo.



Son los siguientes:

- » Rociadores automáticos de agua a presión o *sprinkles* distribuidos en el techo de la sala y que se abren automáticamente por la acción del calor.

Son alimentados por un sistema de tuberías que están constantemente llenas de agua a presión (sistemas de tubería húmeda) y son mantenidas por un depósito o abastecimiento de agua fiable.

Si en alguna parte del sistema de tuberías existe peligro de heladas, el agua se sustituye por aire o nitrógeno presurizado (sistemas de tubería seca).

- » Sistemas de extinción por inundación total: consiste en introducir a presión en la sala un gas inerte que desplace al oxígeno, evitando así la combustión y propagación del incendio.

Se debe asegurar el cierre hermético de la sala y un procedimiento para garantizar el desalojo de todo el personal.

- Portátiles: extintores. Deben ser visibles, accesibles y claramente identificados en el área de trabajo. Su misión es la extinción del fuego incipiente.
- Un sistema automático para realizar la secuencia de apagado de los ordenadores y de corte de suministro eléctrico.

6.3. Suministro eléctrico y tierras

La instalación eléctrica de alimentación a la sala debe tener en cuenta el Reglamento Electrotécnico para Baja Tensión y sus instrucciones técnicas complementarias.

6.3.1. Toma de tierra

El sistema deberá estar unido a la tierra del edificio en un solo punto con la menor impedancia posible (menor a 10Ω), por el camino más corto.

Si hay terminales físicamente distantes pueden ser alimentados a partir de cuadros eléctricos diferentes siempre y cuando:

- La toma de tierra sea la misma que la del ordenador.
- La tensión tierra-neutro debe ser inferior a 1,5 V.
- La toma de tierra deberá ser revisada periódicamente.



6.3.2. Acometida eléctrica

La acometida eléctrica de la sala será independiente y vendrá directamente desde el cuadro de entrada del edificio.

La alimentación debe de tener unas características mínimas de calidad. Si la tensión de la red sufre alteraciones fuera de los límites especificados o sufre microcortes o pérdidas de tensión, será necesaria la instalación de un sistema de alimentación ininterrumpida (SAI).

6.3.2.1. SAI

Un SAI, siglas de Sistema de Alimentación Ininterrumpida también denominado comúnmente UPS (por sus siglas del inglés Uninterruptible Power Supply) es conjunto de circuitos eléctricos y electrónicos más un acumulador de corriente continua (batería) que es capaz de proporcionar tensión y corriente alterna de características controladas en presencia o ausencia de red.

Su uso tiene dos objetivos:

- Proporcionar energía durante un determinado tiempo para que sea posible guardar los datos, cerrar programas y apagar el equipo de forma correcta.

Esto se logra mediante su sistema de baterías de corta duración que se activan al detectar que no hay suministro eléctrico en la toma principal, emitiendo un pitido de aviso.

- Proporcionar al equipo una electricidad de forma constante, sin picos y bajos de intensidad que pueden dañar elementos de hardware (normalmente la fuente de alimentación del ordenador, pudiendo dañarse también la placa base si esos picos son elevados).

Por tanto, un SAI proporciona protección ante cortes de energía, Picos y caídas de tensión o suministro inestable de energía, distorsión de la señal de la corriente (50 Hz @ 230 V) y sobretensiones prolongadas.

Los SAI deben contar con un sistema de conversión entre corriente alterna y corriente continua, ya que las baterías siempre irán alimentadas en continua, y la fuente de alimentación de nuestro PC se alimentará en corriente alterna.

Tipos de SAI:

- **SAI offline.**

Únicamente protege de cortes de corriente, mediante una batería, y puede en algunos casos proteger de picos de tensión y sobretensiones puntuales, pero no protege de sobretensiones prolongadas ni filtra la señal de corriente que llega a nuestro PC.



- **SAI de línea interactiva.**

Protege de los cortes de corriente, de picos de tensión y también de infratensiones o sobretensiones prolongadas y ruidos en la señal eléctrica.

Utiliza un transformador dinámico como si fuera un filtro para estabilizar la corriente que llega al SAI antes de enviarla hacia el ordenador, corrigiendo así la señal de entrada, eliminando los picos en caso de que se produzcan.

El sistema de almacenaje de corriente es el mismo que en los offline, utilizando un sistema de baterías y un inversor para convertir esa corriente continua en alterna.

- **SAI online.**

Es el que ofrece mayor protección, con las protecciones que proporcionan los tipos anteriores añade la protección de distorsiones de onda alterna, variaciones de frecuencia y de microcortes de corriente.

Utilizan un sistema de conversión completa de la corriente de entrada, primero la electricidad es transformada en corriente continua para que se almacene en las baterías, y luego vuelve a ser transformada en corriente alterna para ser suministrada al equipo (PC...) conectado.

Este tipo es el utilizado, por tanto, a nivel profesional.

A la hora de elegir un SAI ha de tenerse en cuenta:

- La potencia necesaria: es una norma aconsejada elegir un SAI con una potencia nominal igual o superior al 150% de la potencia consumida por la carga o la instalación que se desea alimentar.
- Las características eléctricas: deben ajustarse o superar a las que necesitan las cargas críticas conectadas.
- La fiabilidad: para cargas muy críticas hay que exigir un SAI con un tiempo medio de fallos del orden de 100.000 horas/fallo y para cargas poco críticas de unas 20.000 horas/fallo.

6.3.3. Cuadro eléctrico y circuitos internos

- El cuadro eléctrico debe ser exclusivo para los equipos informáticos.
- Es recomendable instalar sistemas automáticos de alarma y corte de la alimentación eléctrica para casos de emergencia.
- El sistema de aire acondicionado debe tener su propio circuito eléctrico desde el cuadro de entrada del edificio.
- Se aconseja instalar al menos dos bases de enchufe de 230 V libres y próximas al ordenador, pertenecientes a un circuito diferente al que lo alimenta, para el servicio de limpieza y mantenimiento.
- En los sistemas eléctricos que estén situados en el falso suelo, los cables deben tener la longitud suficiente para estar apoyados sobre el suelo del edificio, evitando así que el cable soporte tensiones mecánicas.



6.3.4. Interferencias electromagnéticas

La electricidad estática puede ser causa de interrupciones en el normal funcionamiento de los sistemas, así como del deterioro de la información o del propio equipo (principalmente componentes lógicos).

Los materiales aislantes, como el material que recubre el suelo, son los principales responsables de la acumulación de electricidad estática como resultado del movimiento de personas, carros, sillas, etcétera.

Para evitarla es conveniente:

- Cuidar la humedad relativa del aire, evitando que sea muy seco.
- Utilizar moquetas para el suelo y tejidos para las sillas que tengan baja resistividad eléctrica.
- Se debe evitar poner goma y rodamientos aislantes al mobiliario.
- Al manipular el interior de equipos informáticos es recomendable tocar las masas del equipo (partes metálicas) de forma periódica.
- Siempre que se utilicen destornilladores, alicates o utensilios metálicos puntiagudos deberán estar revestidos de material aislante.

6.3.5. Compatibilidad electromagnética

Los equipos eléctricos y electrónicos producen interferencias de alta frecuencia en sus proximidades que se propagan por los cables (emisiones conducidas), ya sean de alimentación eléctrica, de señal o de tierra, o por el aire (emisiones radiadas) que pueden afectar al funcionamiento de los equipos informáticos e incluso dañarlos, así como causar deterioros permanentes en la información almacenada en memorias, discos y cintas.

La compatibilidad electromagnética estudia y limita las emisiones producidas por los equipos eléctricos y electrónicos, y se establece condiciones de inmunidad de los equipos a los campos en función del ambiente electromagnético en el que se instalan.

En líneas generales, se recomienda que los sistemas estén instalados en áreas cuyo campo electromagnético no sea superior a 2 V/m para frecuencias comprendidas entre 10 kHz y 1 GHz.

6.4. Recomendaciones en el uso de la sala

- Minimizar el tráfico de personal.
- No superar la temperatura recomendada de operación, estableciendo un valor nominal de 21 °C.
- No comer, beber o fumar en la sala.



- No guardar ni almacenar papeles ni cajas de cartón.
- Situar todas las impresoras fuera del CPD en una sala especialmente acondicionada para ello.
- Los equipos, discos y cintas deben situarse fuera de focos de calor, de la exposición directa de los rayos del sol y de fuertes campos electromagnéticos.
- Guardar el material sensible en cámaras ignífugas o con una resistencia adecuada al fuego y a los aumentos excesivos de temperatura.

6.5. Seguridad de los equipos y de la información

Para proteger la información y los equipos es recomendable:

- Instalación de dispositivos detectores de fuego, y de sistemas de extintores automáticos.
- Instalación de un sistema de control de acceso de entrada para evitar la manipulación de equipos por personal no autorizado.
- Las copias de seguridad deben estar almacenadas fuera de la sala (e incluso del edificio) y en contenedores especiales protegidos contra la humedad, temperaturas excesivas, fuego, sabotaje, etcétera.
- En zonas de fuerte actividad tormentosa es necesario que, si no existen sistemas de protección adecuados, se interrumpa el funcionamiento de los equipos y se desconecten de la red.
- Es conveniente utilizar sistemas de control de doble puerta, denominados MAN-TRAP, es un sistema de control de acceso de seguridad física que comprende un pequeño espacio con dos juegos de puertas que se enclavan, de modo que el primer juego de puertas debe cerrarse antes de que se abra el segundo juego. También sirven para prevenir el *piggybacking*.



+ Info

Piggybacking es un término referido al acceso a una red inalámbrica de Internet con el propio ordenador del intruso dentro de la red de otra conexión inalámbrica, sin el permiso o el conocimiento explícito de suscriptor.



- Evidentemente, la instalación debe disponer en su instalación eléctrica de "Interruptores Diferenciales", que protegen a las personas de electrocución por un eventual contacto con algún dispositivo con problemas de aislamiento, como por ejemplo cables pelados.
- Se debe evitar almacenar los soportes magnéticos en lugares donde existan o sean susceptibles existir campos magnéticos.
- Entrenar al personal en operaciones de emergencia para casos de fuego, caídas de tensión, ausencia del responsable del sistema y en los procesos de parada programada.

7. Sistemas de gestión de incidencias

Un sistema de gestión de incidencias es un software cuyo objetivo es corregir toda interrupción o reducción de la calidad de un servicio, denominada incidencia, restaurando cuanto antes la operativa normal del servicio, minimizando el impacto negativo ocasionado, y además facilitar la gestión de un cambio en el proceso de forma que esa incidencia sea poco probable que se repita.

Una incidencia se entiende como cualquier evento anómalo que afecte o pudiera afectar al normal funcionamiento de una organización.

La gestión de incidencias tiene como objetivo reiniciar el funcionamiento normal tan rápido como sea posible, con el menor impacto para el sistema y con el menor coste posible, ocupándose de que no vuelva a ocurrir en el futuro.

Una incidencia es aquel fallo en la operativa normal que se encuentra dentro de los límites del SLA.



+ Info

Un SLA (Service Level Agreement o Acuerdo de Nivel de servicio) es un documento contractual vinculante que establecen proveedor de servicios y cliente.

Un contrato que especificará las responsabilidades de cada parte y a qué se comprometen y se atienen de no cumplir con estas obligaciones.

Una parte fundamental del SLA son los SLO: service level objective (objetivos de nivel de servicio) o niveles de rendimiento y disponibilidad y respuesta.

Los SLO establecen unos objetivos específicos mensurables y cuantificables a cumplir para definir el nivel de rendimiento que se espera alcanzar en un servicio o proceso particular.



Por parte del proveedor de servicios por ejemplo mantener la disponibilidad del servicio, solucionar las incidencias en un tiempo determinado, comunicar al cliente modificaciones en el servicio, etc.

Por parte del cliente, pagar la tarifa del servicio, reportar incidencias detectadas, etc.

Así pues objetivos (cuantificables), obligaciones/responsabilidades para con los mismos y las consecuencias de no ser cumplidos formarán el grueso de un acuerdo de nivel de servicio o SLA entre las partes.

Un SLO puede determinar un tope de tiempo en la resolución de una incidencia (dato objetivo y mensurable), e indicar pormenorizadamente el itinerario a seguir si esto no sucede como por ejemplo la gravedad, escalabilidad y asunción de responsabilidades de la misma.

Una incidencia puede ser externa, producida en el servicio a clientes y/o proveedores, etc., e incidencia interna que se produce con los propios empleados de la empresa u organización.

Un buen sistema de gestión de incidencias debe ser capaz de gestionar ambos tipos y establecer acciones a realizar dependiendo de cada clasificación.

Vamos a ver la importancia de unos conceptos en la gestión de incidencias:

- **Escala de Tiempos.**

Debemos usar herramientas de gestión para el cálculo y la asignación de estas escalas de tiempo, así como para utilizar alertas y escalados para facilitar la respuesta/resolución de las incidencias dentro del tiempo máximo definido.

Las incidencias suelen establecer unos tiempos límite establecidos para su resolución. Estos son:

- **Tiempos medios**, histórico que presenta el rendimiento real basado en datos históricos y permite establecer los tiempos objetivos.
- **Tiempos objetivos**, se establecen como meta, con garantías.
- **Tiempos estimados**, proyección y predicción basada en los datos con que se cuenta.

- **Modelos de incidencia.**

Los modelos de incidencia permiten optimizar el proceso de resolución.

Existen incidencias que no son nuevas, sino que ya se han producido anteriormente y que se volverán a producir en el futuro. Muchas empresas encuentran útil la definición de modelos de incidencia que se puedan aplicar a incidencias recurrentes del servicio.

Un modelo de incidencia debería incluir:

- Los pasos a seguir para la resolución de la incidencia.
- El orden cronológico de estos pasos y sus dependencias si las hubiera.



- Responsabilidades: quién debe hacer qué.
- Plazos para la realización de las actividades.
- Procedimientos de escalado: quién debería ser contactado y cuando.
- **Incidencias graves.**

Cada servicio debe definir cuáles son los criterios para que una incidencia se considere o no grave.

Las incidencias graves deben tener asociado su propio procedimiento de resolución y escalado, y tener una escala de tiempos menor que el resto. La actividad de priorización, que veremos más adelante, debe tener en cuenta estos criterios.

Pasos a seguir en la gestión de incidencias

- **Detección.** Debe realizarse inmediatamente, por lo que es importante monitorizar los recursos para detectar incidencias y normalizar el servicio lo antes posible.
- **Registro del incidente.** La información que hay que registrar incluye normalmente:
 - Identificación de forma unívoca.
 - Categorización.
 - Urgencia, impacto y prioridad.
 - Fecha y hora.
 - Persona/grupo que registra la incidencia.
 - Canal de entrada.
 - Datos de usuario.
 - Síntomas.
 - Estado.
 - CI (*configuration items*, elementos de configuración asociados).
 - Persona/grupo asignado para la resolución.
 - Fecha y hora de la resolución.
 - Categoría del cierre.
 - Fecha y hora del cierre.

Por lo general se utiliza un sistema de solicitud de tickets (*ticket request system o help desk*).



- **Categorización.** Se establece el tipo exacto de incidencia:
 - Incidencias de red.
 - Incidencias de *software*.
 - Incidencias que implican *software y hardware*.
- **Priorización.** Es aconsejable calcular la prioridad en base a reglas.

Depende de:

 - Urgencia: rapidez con que la incidencia necesita ser resuelta.
 - Impacto. Se determina por:
 - » El número de usuarios afectados.
 - » La criticidad o aspectos adversos para la organización.
- **Diagnóstico inicial.** El personal de soporte de primer nivel diagnostica basándose en síntomas y resuelve la incidencia si está capacitado para ello.
- **Escalado.** Mecanismo para agilizar la solución oportuna que puede darse en cualquier etapa del proceso. Existen dos tipos de escalado:
 - Funcional: el soporte de primer nivel se ve incapaz de resolver la incidencia y la asigna al grupo resolutor correspondiente.
 - Jerárquico: en caso de que se den ciertas circunstancias (incidencias críticas, etcétera) estas se deben notificar a los responsables del servicio correspondiente.

A pesar del escalado, la incidencia sigue perteneciendo al *Service Desk* y es responsable de su seguimiento y de informar a los usuarios hasta su cierre.

- **Resolución.** Si se encuentra una solución potencial, se aplica y se testea.

Todas las acciones realizadas para resolver el problema se deben registrar en su historial. Una vez comprobada la solución, la incidencia se da por resuelta y se asigna al equipo de *Service Desk* para su cierre.

Se puede agregar la solución a la base de conocimiento (*Knowledge Base-KB*), que ayudará a disminuir los tiempos de respuesta cuando se repita una incidencia igual o similar.
- **Cierre.** Antes de cerrar la incidencia se debe comprobar:
 - Que el usuario está satisfecho.
 - Que el cierre ha sido categorizado.
 - Que se han cumplimentado todos los datos.
 - Decidir si es un problema recurrente. En ese caso, generar un problema.



7.1. ITIL

Las siglas **ITIL** significan **Information Technology Infrastructure Library**, que se puede traducir como Biblioteca de Infraestructura de Tecnologías de Información.

ITIL es un conjunto de conceptos y mejores prácticas referentes a la gestión de servicios TI (tecnologías de la información), y describe detalladamente un extenso conjunto de funciones y procesos ideados para ayudar a las organizaciones a lograr calidad y eficiencia en las operaciones de TI.

El principal objetivo de la gestión de incidencias es restaurar cuanto antes la operativa normal del servicio, minimizando el impacto negativo en las operaciones de negocio.

La Gestión de Incidencias (Incident Management) es un proceso ITIL enmarcado en la fase de Operación del Servicio que se presta.

Vamos a ver los principales conceptos y principios de las buenas prácticas ITIL.

- **Las TI con el negocio.**

La razón de ser de las tecnologías de la información o TI es la de apoyar al negocio en la consecución de sus objetivos.

Este es el concepto principal de ITIL y prueba de ello es que introduce procesos cuya única misión es mantener alineado lo que TI entrega (o entregará) con lo que el negocio necesita (o necesitará).

- **Servicio.**

ITIL agrupa lo que TI puede ofrecer al negocio en el concepto Servicios.

Un Servicio es un medio para entregar valor a los clientes, facilitando los resultados que los clientes quieren lograr y sin que éstos tengan que asumir los costes y riesgos asociados a la consecución de dichos resultados.

La palabra clave aquí es resultado, que es lo que permitirá al negocio alcanzar sus metas. Los clientes pagan por unos resultados, es decir, QUÉ obtienen y no el CÓMO.

Un Servicio ha de proporcionar una utilidad y una garantía. Por ejemplo, el servicio de tramitación de pedidos debe permitir introducir pedidos a través de la web corporativa (utilidad) en horario 8×5 ininterrumpidamente (garantía).

La Gestión de Servicios es un conjunto de capacidades organizativas para la provisión eficiente de valor a los clientes en la forma de Servicios.



- **Funciones, Procesos y Roles ITIL.**

Normalmente, las organizaciones se estructuran en funciones.

"Una función es una unidad especializada en la realización de una cierta actividad y es la responsable de su resultado. La función engloba tanto al equipo de personas que la compone como a los medios que el equipo utiliza para llevarla a cabo".

Las funciones suelen ser eficientes en su desempeño gracias a la especialización, pero esta especialización puede llegar a ser un problema si las funciones no trabajan de forma coordinada para la consecución de los objetivos globales de la organización.

Para evitar este problema se utilizan los procesos, que mejoran la coordinación y el control sobre las funciones.

Un proceso es un conjunto de actividades interrelacionadas orientadas a cumplir un objetivo específico.

Todos los procesos presentan las siguientes características:

- Tienen unas entradas, unas salidas y unos resultados específicos.
- Se inician como respuesta a un evento.
- Son medibles.
- Tienen un receptor del resultado del proceso.

Un rol es un conjunto de responsabilidades, actividades y autorizaciones asignadas a una persona o un equipo. En ITIL se definen una serie de roles para cada proceso con la finalidad de garantizar que se realizan todas las tareas necesarias dentro del proceso.

Una persona puede tener varios roles asignados.

- **Medir para poder gestionar.**

La medición es un concepto fundamental dentro de ITIL, ya que nos sirve tanto para identificar áreas de mejora, como para validar si una mejora ha cumplido las expectativas, como para avisarnos con antelación de un problema potencial.

- No se puede gestionar lo que no se puede controlar.
- No se puede controlar lo que no se puede medir.
- No se puede medir lo que no se puede definir.



7.1.1. Help Desk

Un help desk, se define generalmente, como un equipo centralizado dentro de una empresa que atiende a empleados o clientes de forma masiva, utilizando un producto de software para organizar las conversaciones.

Se utiliza como soporte de TI, tanto para atender a clientes externos como internos (empleados) que necesiten soporte técnico.

En función del uso que realiza cada empresa, la definición puede variar, ya que algunas empresas lo amplían a un concepto más general para un equipo de atención al cliente, del servicio de atención al cliente o de defensa del cliente.

Un help desk también puede hacer referencia al software con el que interactúa un cliente cuando recibe soporte.



+ Info

Según Chris Gross-pietsch, gerente sénior de operaciones de defensa de Zendesk...

"Un help desk puede significar muchas cosas, en función del tipo de negocio. Pero todo se reduce al principio central de ayudar a las personas y de servir como lugar en el que buscar ayuda".

Diferencia entre un help desk y un service desk

Algunas empresas utilizan el término service desk en vez de help desk.

Otras sostienen que la diferencia entre un help desk y un service desk es que un service desk es la evolución de un help desk al centrarse en atender a los usuarios finales de forma rápida y personalizada.

Beneficios de uso de un help desk

Un help desk puede beneficiar a cualquier tipo de empresa u organización, ya que permite que el consumidor, ya sea un usuario interno de la misma empresa u organización, o externo, pueda recibir respuesta rápida a aquellas preguntas o reclamaciones que pueda realizar.



Esto se puede resumir estructurándolo en las siguientes ventajas:

- Mejora la satisfacción de los clientes (externos).
- Impulsa la satisfacción de los empleados.

Un mejor soporte para los empleados (sus clientes internos), mejora la resolución de problemas en las tareas que tiene que realizar el empleado, y, por tanto, la calidad de su trabajo y también su satisfacción con la empresa, lo que repercute directamente con el servicio que recibirá el cliente externo.

- Facilita el crecimiento de la empresa u organización.

La satisfacción de los empleados y de los clientes hace que se logre el éxito de la empresa.

Un help desk favorece que una empresa crezca y escale en función de las necesidades de sus clientes, tanto internos como externos.

Componentes esenciales de un help desk

Los help desks se pueden dividir en dos enfoques diferentes:

- Los agentes del help desk que están en primera línea, hablando con los clientes externos directamente.
- El compromiso de la empresa de dotar a estos agentes de las herramientas necesarias para que puedan hacer bien su trabajo.

En ambos enfoques es necesario unos componentes clave:

- **Las personas adecuadas.**

Los miembros del equipo deben saber empatizar con el cliente, y disponer de otras habilidades interpersonales necesarias para un servicio de atención al cliente.

- **Un sistema sólido de tickets.**

Para apoyar a los empleados, es necesario el uso de una buena herramienta de ticketing, permitiendo:

- Que se pueda monitorear el progreso de resolución de las solicitudes de los clientes.
- Que varios agentes colaboren en tareas complejas y proporcionen una visión contextual de la experiencia de cada cliente.



- **Un rastreador de problemas eficaz.**

Es una herramienta clave para un help desk de TI, ya que permite registrar los problemas y los errores que experimentan los clientes con un producto de software.

Podemos asegurar que se realiza un seguimiento del problema hasta que se haya resuelto satisfactoriamente, y también se va informando al usuario de cómo evoluciona esa resolución.

- **Autoservicio.**

Permite que los clientes encuentren la respuesta que buscan en una sección bien organizada, sencilla e intuitiva. (a través de preguntas frecuentes, foros, etc.)

- **Análisis.**

Si a un help desk se le incorpora una herramienta de análisis, se puede obtener una gran cantidad de datos valiosos sobre los clientes.

Esto proporciona a los administradores del help desk información exhaustiva de diferentes tipos:

- El rendimiento de sus propios equipos.
- La satisfacción de los clientes.
- Se visualizan cuáles son los puntos débiles de los clientes.
- Se detectan qué áreas del producto necesitan de mejoras o de un mayor desarrollo.

- **Comentarios de los clientes.**

Si el software de help desk incorporar la opción de comentarios, se permite al equipo de soporte un contacto con los clientes después de solucionar un problema para evaluar su satisfacción con el trabajo realizado, mejorando la satisfacción de los clientes.

- **Automatización, aplicaciones e integraciones.**

En función de cada empresa, será necesaria la automatización, las aplicaciones y las integraciones de diferentes servicios, haciendo posibles cosas como:

- La asignación de un agente a una conversación basada en la experiencia.
- El cierre de los tickets después de un marco de tiempo específico.
- La cumplimentación de los tickets con respuestas predefinidas llamadas macros.

El sistema de help desk debe integrarse con el resto de herramientas internas necesarias en función de la empresa, por ejemplo, si se quiere ofrecer servicio en varios idiomas, es necesario que el help desk admita aplicaciones de traducción.



7.1.2. Service Desk

Un **Service Desk** (mesa de servicio) es una función de TI principal dentro de la disciplina de la gestión de servicios de TI (ITSM) según lo define ITIL.

Su objetivo es proporcionar un único punto de contacto ("SPOC") para satisfacer las necesidades de comunicación tanto de los usuarios como del personal de TI y también para satisfacer los objetivos del cliente y del proveedor de TI.

"Usuario" se refiere al usuario real del servicio, mientras que "Cliente" se refiere a la entidad que paga por el servicio.

El enfoque de ITIL considera que el **Service Desk** es el punto central de contacto entre los proveedores de servicios y los usuarios / clientes en el día a día. También es un punto focal para informar incidentes (interrupciones o posibles interrupciones en la disponibilidad o calidad del servicio) y para los usuarios que realizan solicitudes de servicios (solicitudes de servicios de rutina).

ITIL considera un centro de llamadas, un centro de contacto o una mesa de ayuda, como tipos limitados de mesa de servicio, que proporcionan solo una parte de lo que una mesa de servicio puede ofrecer.

Una mesa de servicio (service desk) tiene un enfoque centrado en proporcionar un único punto de contacto entre todos los participantes de la gestión de servicios (TI).

Una mesa de servicio busca:

- Facilitar la integración de los procesos comerciales en la infraestructura de gestión de servicios.
- Monitorear y apropiarse activamente de incidentes y preguntas de los usuarios.
- Proporcionar el canal de comunicación para otras disciplinas de administración de servicios con la comunidad de usuarios.
- Proporciona una interfaz para otras actividades como solicitudes de cambio de clientes, terceros (por ejemplo, contratos de mantenimiento) y licencias de software.

7.1.3. Actividades principales de la Gestión de Incidencias según ITIL

Según ITIL, tenemos las siguientes actividades principales, que enumeramos y comentaremos a continuación, en la gestión de incidencias:

- **Detección.**

Cuanto antes sea detectada una incidencia, antes se podrá subsanar y por tanto menor será su impacto.

Monitorizar los recursos permite la detección precoz de incidencias, pudiendo normalizar el servicio antes de que se produzca un impacto negativo, o logrando que este sea mínimo.



- **Registro.**

Todas las incidencias del servicio deben ser registradas de forma independiente.

Se incluirán diferentes datos que serán rellenados durante las diferentes etapas desde su detección a su cierre, incluyendo generalmente:

- Identificador único.
- Datos de entrada:
 - » Fecha y hora, canal de entrada y datos del usuario, y quién registra la incidencia.
 - » Síntomas.
 - » Categorización.
 - » Problema/Known error asociado.
 - » Urgencia, impacto y prioridad.
- Estado.
- CIs (Configuration Items, elementos de configuración) asociados.
- Resolución:
 - » Quién debe resolverla.
 - » Actividades realizadas para la resolución.
 - » Fecha y hora de la resolución.
- Cierre y su fecha y hora.

- **Categorización.**

En esta actividad se establece el tipo exacto de la incidencia.

Se establece una categorización multinivel con dependencias entre niveles, cuyo número dependerá del nivel de detalle con que deseemos tipificar las incidencias.

En el momento del cierre de una incidencia hay que asegurarse de que está bien categorizada, ya que puede haberse hecho mal en el momento del registro.



- **Priorización.**

Se deben establecer unas reglas de prioridad que el equipo debe conocer, y que la herramienta, teniéndolas en cuenta, podrá calcular la prioridad de forma automática.

La prioridad de la incidencia indicará la forma en que hay que gestionarla, teniendo en cuenta dos factores:

- La urgencia:

Dependiendo del perjuicio que esté causando la incidencia, se determina la rapidez con que necesita ser resuelta.

- El impacto:

Puede valorarse según el número de usuarios afectados o según el impacto negativo que tiene en la organización o negocio.

- Quién las sufre:

En la prioridad también se tiene en cuenta a qué departamento o usuario (VIP) está afectando la incidencia.

- **Resolución:**

Si es posible, el personal que recibe la incidencia la resolverá, y si no realizará una asignación con dos tipos de escalado:

- Funcional:

Asigna la resolución a una persona o equipo.

- Jerárquico:

En incidencias con riesgo de incumplimiento del SLA, se notificará a los responsables del servicio correspondiente y cargos ejecutivos.

En este caso, el equipo de Service Desk también continuará con el seguimiento de la incidencia hasta su cierre.

Cuando se produce un fallo en el sistema, hay que saber la causa, para además de que solucionarlo, evitar que se produzca de nuevo.

Es importante analizar si ha sido como consecuencia de una modificación o implementación en el sistema.

Se debe concretar bien que es lo que no funciona para resolverlo con la mayor precisión y rapidez, pudiendo buscar en la base de datos si ya se ha producido con anterioridad, y buscar posibles soluciones (workarounds).



- **Cierre.**

Para cerrar la incidencia, el equipo del Service Desk debe comprobar que el usuario esté satisfecho, y que todos los datos se hayan realizado correctamente.

7.1.4. Definición del Ciclo de vida por ITIL

Si bien el marco general para abordar las necesidades específicas de un proyecto considera 7 fases: justificación, diseño, construcción, pruebas, despliegue, mejora y retirada. En la gestión TI propiamente dicha, ITIL propone 5 fases: estrategia, diseño, transición, operación y mejora continua del servicio.

Las fases del ciclo de vida son las siguientes:

- **Estrategia:**

Promueve la visión de la gestión de servicios como un activo estratégico. Entre otras funciones, define las políticas a seguir e identifica, selecciona y prioriza los servicios que se ofrecerán a los clientes.

- **Diseño:**

Su principal objetivo es diseñar los servicios, de forma alineada con los objetivos de negocio y las políticas establecidas en la Estrategia.

- **Transición:**

Es la responsable de construir, probar y desplegar en el entorno productivo los servicios diseñados.

- **Operación:**

Realiza todas las actividades necesarias para mantener los servicios ejecutándose dentro de los parámetros de calidad acordados con el cliente. Es la fase del ciclo de vida donde se realiza el valor de los Servicios.

- **Mejora continua:**

Trabaja con el resto de fases del ciclo de vida, y es la responsable de garantizar que estamos continuamente mejorando.



7.2. ITSM. Gestión de servicios de Tecnologías de la Información

La gestión de servicios de tecnologías de la información (en inglés IT Service Management, ITSM) es una disciplina basada en procesos, enfocada en alinear los servicios de TI proporcionados con las necesidades de las empresas, poniendo énfasis en los beneficios que puede percibir el cliente final.



+ Info

Probablemente, hayas participado en servicios de ITSM en un centro de servicio al usuario de TI o departamento de ayuda, respondiendo a preguntas sobre un servicio determinado, como por ejemplo una compra online, o una reclamación sobre el contrato del servicio de internet, luz... Esto son ejemplos de ITSM.

ITSM propone cambiar el paradigma de gestión de TI, por una colección de componentes enfocados en servicios de punta a cabo usando distintos marcos de trabajo con las "mejores prácticas", como por ejemplo la Information Technology Infrastructure Library (ITIL) o el eSCM (enabled Service Capability Model).



Recuerda

Un servicio TI, es un servicio de tecnologías de la información, un conjunto de actividades que buscan responder a las necesidades de un cliente por medio de un cambio de condición en los bienes informáticos (llámese activos), potenciando el valor de estos y reduciendo el riesgo inherente del sistema.

La Gestión de Servicios de TI requiere de una integración correcta de tres factores:

- Personas.
- Procesos.
- Tecnología.



Los proveedores de los servicios de TI deben considerar la calidad de los servicios que proveen y enfocarse en sus relaciones con los clientes.

Generalmente, la gestión de servicios de TI involucra el uso de:

- **Outsourcings.**

El outsourcing o subcontratación se define como un modelo de negocio en el cual, las empresas subcontratan a personas para que realicen actividades específicas. (No podrá comprender tareas iguales o similares a las que realizan el resto de los trabajadores al servicio de la persona que contrata).

Es, por tanto, el proceso económico empresarial en el que una sociedad mercantil transfiere los recursos y las responsabilidades referentes al cumplimiento de ciertas tareas a una sociedad externa, empresa de gestión o subcontratista, que precisamente se dedica a la prestación de diferentes servicios especializados.

Para ello, estas últimas, pueden contratar solo al personal, caso en el cual los recursos los aportará el cliente (instalaciones, hardware y software), o contratar tanto el personal como los recursos.

- **Insourcing.**

El insourcing es definido como la internalización de un servicio que se realizaba de forma externa.

Para efectos de la subcontratación laboral, no es otra cosa más que manejar de manera interna la administración de la nómina a través de una empresa que se diseñó de forma exclusiva para ofrecer estos servicios a las diferentes compañías de un grupo, que comparten en común una sociedad.

De esta manera, utilizar los servicios del insourcing entre filiales del grupo puede resultar beneficioso, ya que lo que se busca con esta figura es realizar una actividad especializada para estos efectos, y con ello, vigilar el correcto cumplimiento. Así se puede generar una mayor certeza y seguridad en todas las obligaciones fiscales de la subcontratación laboral, y como consecuencia, se crea una mayor fidelización en los empleados al pertenecer al mismo grupo.

Esta figura no evita el cumplimiento normativo de la subcontratación laboral y tampoco significa que el outsourcing sea una figura que se deba de evitar. Cada empresa debe realizar un exhaustivo análisis que lo lleve a validar cada una de las aristas de su actividad y la preponderancia del enfoque de su naturaleza per se y, con la ayuda de especialistas, definir la estrategia que más se alinea a cada necesidad.

- **Servicios compartidos.**



+ Info

Según explicó Guadalupe Sánchez, directora del Grupo EAP, empresa especialista en administración de personal, para una entrevista en Entrepreneur:

"La diferencia fundamental es que los outsourcing son empresas independientes dedicadas a la contratación de personal para diferentes empresas. Por su parte, las insourcing son empresas creadas por una compañía más grande para encargarse de la nómina. Así pueden simular que se trata de una outsourcing y obtener todas las ventajas que esto conlleva".

<https://www.entrepreneur.com/article/360776>

Una buena gestión de servicios TI debe tener ofrecer:

- Gestión de la calidad.
- Aumento de la eficiencia.
- Alinear los procesos de negocio y la infraestructura TI.
- Reducir los riesgos asociados a los Servicios TI.
- Generar negocio.

Las relaciones y comunicaciones entre el proveedor de TI y los clientes (internos y/o externos) de TI deben ser realizadas a través de un sistema que garantice la optimización de los procesos de entrega y soporte de servicios a través de la consolidación de Gestión de Servicio TI, con el objetivo de proporcionar una rápida respuesta a los clientes (usuarios).



+ Info

El Servicio TI se basa en la promoción y soporte de aplicación de las mejores prácticas, marcos referenciales y estándares de aceptación internacional, tales como ISO/IEC 20000, ITIL, ITSCMM, COBIT, MOF, ISO/IEC -17799 – 2700X y otras.



7.2.1. Gobernanza de las Tecnologías de la Información

La Gobernanza de TI, traducción del conjunto de mejores prácticas establecidas como ITSM del inglés (Information Technology Service Management) acuñado a partir de la creación e implementación de los principios y fundamentos ingleses promovidos en el conjunto de prácticas documentadas en ITIL (Information Technology Infrastructure Library).

Gobierno de TI es el alineamiento de las Tecnologías de la información y la comunicación (TI) con la estrategia del negocio.

El Gobierno de TI consiste en un completo marco de estructuras, procesos y mecanismos relacionales.

Las estructuras implican la existencia de funciones de responsabilidad, como los ejecutivos y responsables de las cuentas de TI, así como diversos comités de TI. Los procesos se refieren a la monitorización y a la toma de decisiones estratégicas de TI. Los mecanismos relacionales incluyen las alianzas y la participación de la empresa/organización de TI, el diálogo en la estrategia y el aprendizaje compartido. (Jan van Bon, 2010)

El gobierno de las Tecnologías de la Información (TI) se ha desarrollado enormemente desde la aparición del estándar ISO/IEC -38500. Sin embargo, las organizaciones suelen experimentar dificultades a la hora de la implementación del estándar, ya que los principales interesados pueden llegar a ser excluidos del marco de gobierno, provocando la ausencia de su necesaria implicación. (Angel Cobo Ortega)

Se entiende por Gobierno TI, el conjunto de acciones que realiza el área de TI en coordinación con la alta dirección para movilizar sus recursos de la forma más eficiente en respuesta a requisitos regulatorios, operativos o del negocio. (TCP, 2014), con las siguientes características:

- Constituye una parte esencial del gobierno de la empresa en su conjunto y aglutina la estructura organizativa y directiva necesaria para asegurar que TI soporta y facilita el desarrollo de los objetivos estratégicos definidos.
- Garantiza que:
 - TI está alineada con la estrategia del negocio.
 - Los servicios y funciones de TI se proporcionan con el máximo valor posible o de la forma más eficiente.
 - Todos los riesgos relacionados con TI son conocidos y administrados y los recursos de TI están seguros.



+ Info

Gestión de la Tecnología Gestión de TI es el proceso de supervisión de todos los asuntos relacionados con las operaciones y recursos de tecnología de la información dentro de una organización de TI. (Rouse, 2014).

La gestión de TI asegura que todos los recursos tecnológicos y los empleados asociados son utilizados correctamente y de una manera que proporciona valor para la organización.

La gestión de TI efectiva permite a una organización optimizar los recursos y la dotación de personal, mejorar los procesos de negocio y de comunicación y aplicar las mejores prácticas.

Existen diferentes propuestas que permiten guiar a las organizaciones en la estructuración de un gobierno de TI:

- AS8015-2005:

Estándar australiano para el gobierno corporativo de la tecnología de la información y la comunicación.

AS8015 fue la base para ISO/IEC 38500.

- ISO/IEC 38500:2008 Corporate Governance of Information Technology, (basado en AS8015-2005):

Define un marco de trabajo para el gobierno de TI que permite apoyar a la alta dirección en cuanto a los aspectos legales, éticos y normativos relacionados con el uso de TI; así como en el uso efectivo, eficiente y misional de la tecnología de la información dentro de la organización.

ISO/IEC 38500 es aplicable a organizaciones de cualquier tamaño, incluyendo organizaciones públicas o privadas, entidades gubernamentales u organizaciones sin ánimo de lucro.

- Control Objectives for Information and related Technology (COBIT):

Es un modelo de referencia que describe 34 procesos relacionados con TI y que son comunes a todas las organizaciones. Cada proceso está descrito en detalle, incluyendo entradas y salidas, actividades clave, objetivos, indicadores de desempeño y un modelo básico de madurez. Fue creado por la organización ISACA, pero en la actualidad es mantenido por ITGI (Instituto de Gobernanza de TI).



7.3. Gestion de problemas

Según ITIL, un problema es la causa o posible causa de varios incidentes.

Los problemas pueden surgir por incidentes mayores que afectan a muchos usuarios, o incidentes recurrentes, y, además, se pueden identificar los problemas en los sistemas de diagnóstico de infraestructura antes de que los usuarios se vean afectados.

Los incidentes afectan la productividad empresarial, y proporcionar soluciones rápidas ayuda a garantizar la continuidad ininterrumpida de las operaciones comerciales. Sin embargo, cuando ocurren varios incidentes a la vez o el mismo incidente ocurre varias veces, no es posible avanzar proporcionando soluciones de remiendo u ofreciendo las mismas resoluciones una y otra vez.

La gestión de problemas de ITIL es un procedimiento para minimizar los incidentes causados por las operaciones de infraestructura de TI al profundizar en los incidentes para determinar la causa raíz y encontrar soluciones, y también para reducir la gravedad de los incidentes al documentar los problemas existentes y proporcionar soluciones alternativas.

La gestión de problemas es un enfoque metódico para identificar la causa de un incidente y gestionar el ciclo de vida de todos los problemas.

El objetivo del proceso de gestión de problemas de ITIL es minimizar el impacto de los incidentes y eliminar los incidentes recurrentes.

Si bien ITIL no establece ninguna técnica específica para realizar la gestión de problemas, recomienda las siguientes tres fases, que se estudiarán más adelante:

- Identificación del problema.
- Control del problema.
- Control de errores.

La gestión reactiva se ocupa de los incidentes que actualmente afectan a los usuarios, mientras que la gestión proactiva aborda los problemas que podrían surgir como incidentes en el futuro en caso de que no se solucionen.

Un proceso de gestión de problemas fiable podría reducir significativamente la afluencia de tickets de incidentes, lo cual ahorra tiempo y esfuerzo al personal de la mesa de servicio de TI, esta es una ventaja que se suma a otros beneficios, como:

- La reducción del tiempo medio para reparar (MTTR).
- Una mayor satisfacción del cliente.
- Una sólida base de datos de errores conocidos.



- Un menor costo de los servicios y problemas de TI.
- Además, es probable que una organización que implemente la gestión proactiva de problemas encuentre un gran valor al identificar y eliminar los problemas antes de que interrumpan los procesos comerciales.

La gestión de problemas vista como una práctica de ITIL es más útil cuando se usa con otras prácticas de ITIL en la cadena de valor general del servicio.

La información se intercambia entre las diversas prácticas de ITIL, es decir, la gestión de incidentes, la gestión de cambios, la gestión de activos de TI la gestión del conocimiento y la mejora continua del servicio.

Esta información intercambiada entre las partes acumula valor a medida que avanza a través de cada práctica de ITIL creando a su vez un óptimo proceso de gestión de servicios de TI.

Vamos a ver unas definiciones para comprender mejor el contexto:

- **Solución alternativa:**

Soluciones temporales que restauran los servicios y garantizan la continuidad del negocio. Una solución alternativa reduce el impacto de un incidente o problema.

- **Análisis de causa raíz (RCA):**

La causa raíz es la problemática subyacente del problema. El RCA son las técnicas de investigación que ayudan a descubrir la causa raíz de un problema.

- **Error conocido:**

Problemas que han ocurrido antes y cuya solución alternativa o causa raíz son conocidas.

- **Base de datos de errores conocidos (KEDB):**

Una base de datos creada al documentar los errores conocidos usando la gestión de incidentes y la gestión de problemas.

Examinaremos cada aspecto de la gestión de problemas en detalle, proporcionándole todo el conocimiento que necesita sobre cómo implementar la gestión de problemas.

7.3.1. Gestión de incidentes frente a gestión de problemas

En ITIL, los términos incidente y problema pueden parecer sinónimos, pero ambos se diferencian por el papel que desempeñan para lograr una excelente calidad de servicio.

Es importante saber cómo interactúan entre sí la gestión de incidentes y la gestión de problemas y en qué se diferencian, especialmente dónde termina un incidente y comienza un problema.



Gestión de incidentes

Un incidente es una interrupción no planificada de un servicio completo o solo un componente de éste.

Ejemplo: hay una reunión importante en 15 minutos, es necesario imprimir un informe y la impresora del departamento no funciona. Habrá que emitir un ticket rápidamente para aplicar una solución alternativa e imprimir los informes. Este es un incidente.

El proceso de gestión de incidentes se trata de manejar los incidentes y restaurar el servicio lo antes posible.

En nuestro ejemplo, el personal de la mesa de servicio conecta rápidamente la computadora portátil a la impresora del departamento contiguo para que el usuario pueda tener los informes a tiempo para la reunión. Por lo tanto, el objetivo de la gestión de incidentes es garantizar que la interrupción o incidente se resuelva lo más rápido posible con una solución definitiva o una solución alternativa.

Gestión de problemas

La gestión de problemas no se trata de restaurar los servicios o resolver las problemáticas, sino de determinar y eliminar la causa.

El problema se registra en una mesa de servicio cuando hay incidentes recurrentes que tienen problemáticas comunes, o si ocurre un incidente mayor que afecta a muchos usuarios.

En nuestro ejemplo, no funciona la única impresora en el departamento y todos los usuarios en ese departamento se vieron afectados, lo cual fue registrado como un problema por el personal de la mesa de servicio para encontrar la causa y la solución.

Se puede cerrar un incidente cuando se proporciona una solución alternativa, pero se registra un problema para arreglar la impresora de forma permanente, de modo que no vuelva a ocurrir esta problemática.

En nuestro ejemplo, la problemática de la impresora se someterá a un RCA para encontrar una solución permanente, y se supervisará como un ticket de problema mientras el negocio continúa funcionando con la solución alternativa en su lugar.

Si el equipo de gestión de problemas no puede encontrar una solución definitiva, se documenta la solución alternativa y se agrega la problemática en la KEDB, de esta manera, la gestión de problemas no solo consiste en eliminar los incidentes al encontrar la causa raíz subyacente, sino también en determinar la solución más factible que se pueda implementar para minimizar las interrupciones.



A veces, a pesar de conocer la causa raíz, la solución más factible es implementar una solución alternativa y documentarla como un error conocido.

A pesar de ser diferentes, la gestión de incidentes y la gestión de problemas se complementan entre sí y están estrechamente alineadas:

- La gestión de incidentes garantiza la continuidad en las operaciones comerciales.
- Mientras que la gestión de problemas se ocupa de los problemas y problemáticas subyacentes.

7.3.2. Gestión de problemas reactiva frente a gestión de problemas proactiva

Vamos a ver que es la gestión de problemas reactiva y proactiva:

- **Gestión de problemas reactiva.**

Reactiva reacciona a los incidentes que surgen y luego continúa con el proceso de gestión de problemas.

El enfoque reactivo para la gestión de problemas tiene como objetivo encontrar y eliminar las causas raíz de los errores conocidos y únicamente trata el problema si aparece como incidentes mayores o recurrentes.

- **Gestión de problemas proactiva.**

Busca las problemáticas, las fallas y los errores conocidos en los sistemas de TI con base en los incidentes pasados, los logs de datos del monitor de red y otras fuentes de información, luego procede a resolverlos permanentemente antes de que surjan como incidentes. Este proceso hace parte de la mejora continua del servicio. La gestión de problemas proactiva también tiene como objetivo resolver todos los errores conocidos de la KEDB si es posible hacerlo.

Ambos tipos de gestión de problemas siguen las mismas fases de resolución de problemas una vez que se presenta un problema:

- Identificación del problema.
- Control del problema y control de errores.

La única diferencia es el enfoque para identificar el problema, y ambos procesos ofrecen distintas ventajas a la gestión de servicios y requieren recursos únicos para funcionar.



Elegir entre los enfoques de gestión de problemas reactivos y proactivos

Las organizaciones que apenas están comenzando a usar la gestión de problemas deben centrar sus esfuerzos en implementar un proceso de gestión de problemas reactivo.

El personal existente de la mesa de servicio que tiene experiencia en la resolución de problemas con incidentes diarios proporciona una valiosa experiencia antes de implementar una gestión de problemas proactiva.

A medida que madura la prestación de servicios de una organización, debe avanzar hacia un proceso de gestión de problemas proactivo.

Este avance la debe realizar un equipo con un buen conjunto de habilidades analíticas, y competente en la infraestructura de TI y en las herramientas y tecnología que utiliza la empresa u organización.

7.3.3. Beneficios de la gestión de problemas de TI

Es importante incluir a todos los interesados en el proceso de gestión de problemas, se explica cómo proporcionan valor a las diferentes facetas de la organización.

Estos beneficios incluyen:

- Elimina las fallas en los servicios de una organización a través de una documentación adecuada.
- Mejora el diseño del servicio al identificar y resolver los puntos débiles, garantizando la ruta más efectiva y eficiente para la entrega del servicio.
- Aumenta la tasa de corrección a la primera vez en las fallas del servicio al proporcionar soluciones permanentes para los incidentes en lugar de limitarse a las soluciones alternativas.
- Disminuye el impacto de los incidentes que afectan a varios usuarios o a un solo usuario en un momento crucial.
- Previene la mayoría de los incidentes y problemas que afectan a una organización con el tiempo, lo que aumenta la productividad del usuario.
- Fortalece la confianza que los usuarios tienen en los servicios de TI de la organización.
- Disminuye el tiempo que lleva recuperarse de los fallos a través del mantenimiento sistemático de una KEDB.
- Previene los incidentes recurrentes a través de correcciones únicas, ahorrando valiosos esfuerzos a la mesa de servicio para su resolución.
- Fomenta la maduración de los servicios de TI ya que la organización se desarrolla aprendiendo de los problemas resueltos.
- Desarrolla el talento de TI dentro de la organización a través de la concienciación técnica y conocimientos valiosos.



7.3.4. Roles y responsabilidades de la gestión de problemas de TI

Los roles de un equipo de gestión de problemas están directamente relacionados con la estructura organizativa existente.

La edad, la cultura, la tecnología y el número de ubicaciones de la organización en todo el mundo afectan la composición de su equipo de gestión de problemas.

En el caso de las pequeñas empresas de TI, las responsabilidades del equipo pueden estar combinadas, o en el caso de las grandes empresas multinacionales, pueden estar especializadas.

Depende de la conveniencia y flexibilidad del equipo de TI diseñar un entorno que garantice que los problemas se aborden de manera eficiente en términos de las recomendaciones de ITIL.

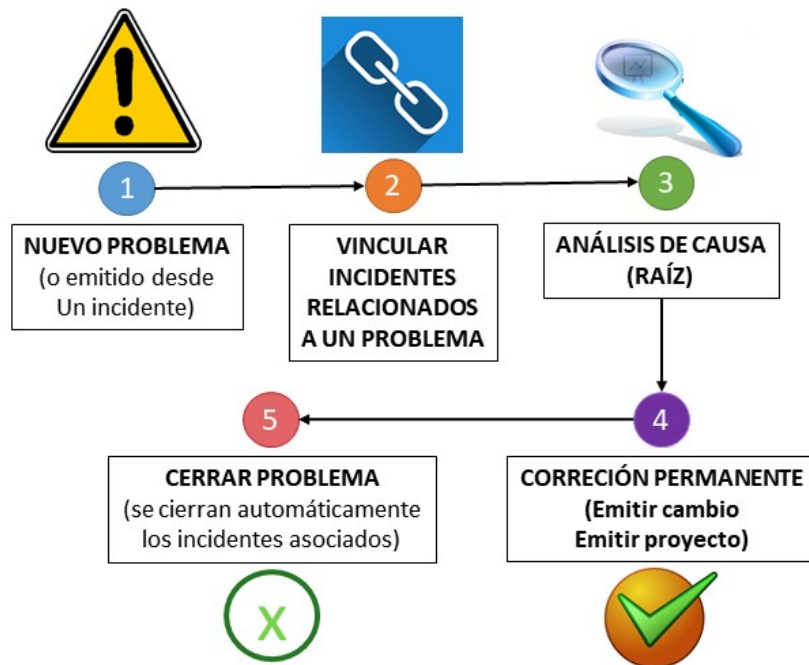
Es aconsejable conocer la estrategia general de la organización para iniciar la formación del equipo, y ser precavido con los recursos que la organización puede asignar para el desarrollo de un equipo de gestión de problemas.

Los roles y responsabilidades del equipo deben extenderse, divergir y madurar a medida que crece la tecnología de la organización.

Rol	Responsabilidad
Gestor de problemas	Responsable de la efectividad y eficiencia de toda la práctica. Similar al líder del equipo.
Propietario del problema	Responsable del ciclo de vida de cualquier ticket de problema que se le asigne.
Agente del problema	Responsable de las tareas asociadas al ticket de problema.
Equipo de diagnóstico	Un grupo de personas con diversos conocimientos, responsables del RCA de un problema.

7.3.5. Flujo del proceso de gestión de problemas de TI

Al igual que una organización crea valor para sus clientes, la gestión de servicios de TI crea valor para sus usuarios a través de las mejores prácticas e indirectamente ayuda a crear valor para la organización. Para crear este valor, debe haber un proceso con entradas y salidas definidas. Cuando se implementa una mesa de servicio lista para ITIL el flujo simplificado del proceso de problema se ve así:



Según ITIL, se pueden implementar procesos de gestión de problemas con cualquier tecnología que se considere adecuada para una determinada empresa u organización.

La tecnología implementada debe tener funcionalidades que permitan establecer las tres fases de la gestión de problemas de ITIL.

Las tres fases, que veremos a continuación con más detalle, son:

- **Identificación del problema:** Identificar el problema y regístralo en una herramienta de gestión de problemas.
- **Control del problema:** Priorizar, investigar y analizar los problemas registrados.
- **Control de errores:** Gestionar los errores conocidos de la KEDB periódicamente.

Identificación del problema

La fase de identificación del problema identifica y registra los problemas en una herramienta de gestión. Una herramienta de mesa de servicio asociada con varias prácticas de gestión de servicios, incluida la gestión de incidentes, la gestión activos, la **CMDB** y la gestión de cambios, brinda a las organizaciones una ventaja en esta fase.

Mientras que el personal de la mesa de servicio normalmente reportaría los problemas después de recibir una oleada de incidentes, un enfoque proactivo para la gestión de problemas identifica los problemas:

- Analizando las tendencias de incidentes, aprovechando los sistemas de monitoreo de red y utilizando otro software de diagnóstico.
- Detectando los riesgos de los incidentes que podrían repetirse.



- Evaluando la información recibida de socios y proveedores.
- Evaluando la información de los desarrolladores de software, ingenieros y equipos de prueba internos.

Es importante contar con un sistema para que los problemas se reporten, identifiquen, prioricen y registren para su posterior investigación y diagnóstico.

Dependiendo de la estructura, el dominio y la cultura de su organización, incluso podría haber otros métodos para identificar los problemas.

Control del problema

La gestión de problemas es un esfuerzo de colaboración, por lo que para que los resultados sean efectivos, varios departamentos y partes interesadas deben participar en la fase de control del problema.

El control del problema incluye actividades como la priorización, la investigación, el análisis y la documentación de errores conocidos y soluciones alternativas.

Existen numerosas técnicas que ayudan en la priorización y el análisis de problemas.

Una buena regla general es abordar primero los problemas que, una vez solucionados, reducen significativamente la interrupción de los servicios en la organización.

También hay que tener en cuenta la viabilidad para abordar los problemas, solucionar un problema de forma permanente puede requerir más recursos que una solución alternativa, por tanto, hay que realizar en ocasiones un análisis rápido de costo-beneficio para determinar si se debe proceder con una solución permanente o no.

Las soluciones alternativas se documentan en los registros de problemas.

En general, si un problema persiste por más tiempo, es aconsejable implementar una solución alternativa rápida, que incluso puede ser parte de la resolución de la gestión de incidentes, teniendo en cuenta que, el equipo de gestión de problemas debe revisar la solución alternativa y perfeccionar la resolución si es necesario.

Una solución alternativa efectiva para los incidentes puede convertirse en una solución permanente para algunos problemas.

Control de errores

Esta fase gestiona los errores conocidos de la **KEDB** al revisar periódicamente las posibles soluciones permanentes si pasan el análisis de costo-beneficio.

Una vez que se analiza un problema, se documenta como un error conocido.

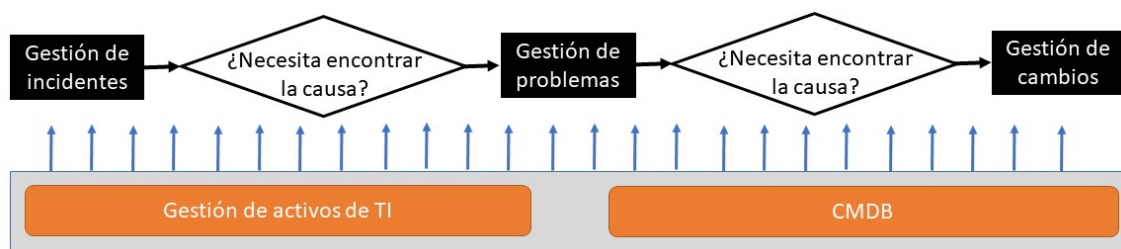
Estos errores conocidos se vuelven a evaluar periódicamente para tener en cuenta el impacto que crean y para probar la eficacia de las soluciones alternativas.



7.3.6. Relación entre la gestión de problemas y los procesos de ITIL

Un sistema integrado que implementa las mejores prácticas de prestación de servicios mejora los servicios empresariales y las capacidades de los servicios de TI.

Un proceso de gestión de problemas eficiente interactúa con otros procesos de ITI.



Gestión de incidentes

La gestión de incidentes es el proceso metódico que consiste en registrar, categorizar, priorizar, asignar y resolver las problemáticas en una organización.

El objetivo de la gestión de incidentes es reiniciar los servicios interrumpidos lo antes posible, lo que a menudo significa que se implementa una solución alternativa en lugar de una solución permanente.

Cada actividad en esta práctica se documenta detalladamente y se envía al equipo de gestión de problemas, que inicia el **RCA** para desarrollar una solución permanente.

Gestión de cambios

El objetivo de la gestión de cambios es aumentar la tasa de éxito de los cambios implementados en la organización.

Un cambio se refiere a cualquier modificación realizada en la infraestructura de TI de la organización, los procesos, los servicios, los productos, las aplicaciones, los proveedores o cualquier otra cosa que implícita o explícitamente afecte la prestación de servicios de la organización.

De acuerdo con el marco de ITIL la responsabilidad de la gestión de problemas concluye al determinar la causa raíz que conduce a la solución de un problema y, de hecho, la solución se implementa con el control de cambios.

Implementar un cambio puede implicar gestionar el riesgo en varias unidades de negocio, requiriendo de un proceso separado para garantizar un manejo eficiente, el equipo de gestión de problemas debe participar en la revisión posterior a la implementación de un cambio para garantizar que la solución del problema y el cambio implementado asociado sean coherentes.



Gestión de activos de TI

La gestión de activos de TI es la práctica de gobernar el ciclo de vida de un activo en una organización.

Sus actividades incluyen derivar el valor máximo de los activos, controlar los costos de los activos y gestionar los riesgos de los activos, que pueden estar en términos de cumplimiento, selección de proveedores, políticas de uso y prácticas de eliminación.

Las prácticas de gestión de activos y gestión de problemas se pueden cruzar cuando surgen problemas con los activos de hardware y software utilizados por la organización.

Cuando la causa raíz de un problema parece estar relacionada con un producto o servicio, el registro detallado del inventario de la gestión de activos de TI agiliza el proceso de resolución de problemas, y también la gestión de activos de TI ayuda a la gestión de problemas a estudiar el impacto de un incidente, examinar los efectos de implementar una solución y proporcionar información cuando sea necesario a través del RCA.

Veamos un ejemplo a continuación.

Supuesto:

- Zylker es un proveedor de fotografías de archivo de rápido crecimiento en India.
- Un gerente en Mumbai ha tenido problemas para generar los informes mensuales desde el servidor SQL en Nueva Delhi.
- Se reporta el incidente y el personal de la mesa de servicio notifica a los técnicos en Nueva Delhi.

Como solución temporal:

- Los informes se generan localmente y luego se envían para garantizar la continuidad del negocio.

El equipo de gestión de problemas proactiva de Zylker decide realizar un análisis de tendencia de los incidentes ocurridos en los últimos seis meses:

- Encuentran varios incidentes relacionados con el servidor en Nueva Delhi.

Esto los lleva a iniciar un ticket de problema y proceder con el análisis de investigación utilizando los datos recopilados de todos los incidentes documentados.

El técnico en Nueva Delhi ve que el servidor SQL está utilizando diferentes tipos de protocolos, incluidos iSCSI y el protocolo de canal de fibra, para vincular las instalaciones de almacenamiento de datos:

- Dado que ambos protocolos funcionan en una red Ethernet, hay dudas sobre si configuró el switch de bloque local para funcionar con la transferencia de datos de paquetes grandes:
 - El técnico recibe datos del equipo de gestión de activos de TI y concluye que el switch no fue el causante.

Esto se comprueba con la evidencia que demuestra que no había problemas para generar informes localmente.



Lo siguiente es analizar la red de área amplia (WAN), ya que un gerente de Mumbai tiene problemas para generar el informe mensual:

- El técnico, debido a su experiencia en problemas de red, tiene dudas sobre el flujo de tráfico al final de cada mes, por lo que:
 - Instala un software en los routers y switches de la compañía para analizar el tráfico que pasa a través de ellos y agregar los datos estadísticamente.

El software genera gráficos y diagramas que muestran los principales protocolos que se utilizaron, junto con el ancho de banda que cada protocolo consumió durante un mes.

Esto revela un uso del ancho de banda significativamente alto al final del mes aproximadamente al mismo tiempo que se genera el informe mensual.

Después de realizar un examen detallado, se descubre que las copias de seguridad de la imagen completa del sistema se programaron aproximadamente al mismo tiempo que el informe mensual y esto causó un cuello de botella en la WAN.

Ahora que se identificó la causa raíz del problema, el técnico emite un ticket de cambio para reprogramar la copia de seguridad de la imagen a las primeras horas de la mañana fuera del horario comercial, lo cual nivelará el tráfico en la red.

Este es un resumen general de los pasos realizados en este ejemplo:

Actividad	Práctica involucrada
El gerente en Mumbai tuvo problemas para generar los informes mensuales desde el servidor SQL en Nueva Delhi. Se reportó el incidente y los informes se generaron localmente y luego se enviaron al gerente. Se cerró el ticket.	Gestión de incidentes
El equipo de gestión de problemas proactiva realizó un análisis de tendencias de los incidentes ocurridos en los últimos seis meses. Se encontraron varios incidentes relacionados con el servidor en Nueva Delhi.	Gestión de problemas, gestión de incidentes
El técnico de Nueva Delhi examinó la red y el protocolo del servidor SQL, y no estaba seguro de si el switch de bloque local estaba configurado o no para funcionar con la transferencia de datos de paquetes grandes.	Gestión de problemas, gestión de activos de TI
El técnico recibió datos del equipo de gestión de activos de TI y concluyó que el switch no era el causante.	Gestión de problemas, gestión de activos de TI
El técnico tenía sospechas sobre el flujo de tráfico al final de cada mes, e instaló un software en los routers y switches para analizar el tráfico y agregar los datos estadísticamente.	Gestión de problemas, gestión de activos de TI



Actividad	Práctica involucrada
Después de realizar un examen detallado, se descubrió que las copias de seguridad de la imagen completa del sistema se programaron aproximadamente al mismo tiempo que la generación del informe y esto causó un cuello de botella en la WAN.	Gestión de problemas
El técnico emitió un ticket de cambio para reprogramar la copia de seguridad de la imagen a las primeras horas de la mañana fuera del horario comercial.	Gestión de problemas, gestión de cambios

Todas las prácticas de ITIL tienen una relación intrincada con otras prácticas de ITIL.

A medida que la gestión de problemas madura en la prestación de servicios, hay que asegurarse de mejorar la forma en que interactúa con otras prácticas para garantizar una prestación de servicios adecuada y orientada a los negocios.

7.3.7. Cinco pasos del análisis de problemas

El análisis de problemas es la única parte que concierne a la gestión de problemas de ITIL y consta de los 5 pasos siguientes:

7.3.7.1. Definir el problema

Identificar cuál es realmente el problema puede ser un problema en sí mismo. Dado que la gestión de problemas es inherentemente un esfuerzo de colaboración, definir el problema de manera exhaustiva elimina las nociones preconcebidas que podría tener algún participante, lo cual ahorra mucho tiempo.

Por ejemplo, si la copia de seguridad automática de datos de una organización en un servidor ha fallado, el problema se puede definir como: *"Copia de seguridad fallida en el servidor"*.

Esta definición de hecho describe la situación inusual, pero requiere de más preguntas e información. Un buen modelo de definición debe ser inequívoco y fácil de entender.

Para eliminar la ambigüedad, la definición se puede modificar de la siguiente manera: *"La copia de seguridad de datos del 15 de noviembre falló en el servidor #17-P"*.

Esta definición proporciona más claridad y evita que los empleados formulen preguntas redundantes, pero puede mejorarse aún más. Si imaginamos que la causa de la falla de la copia de seguridad de datos se puede atribuir a un evento como la aplicación de un nuevo parche; entonces el análisis inicial del problema indudablemente conduciría a este evento.

Para ahorrar tiempo y esfuerzo, se modificaría la definición de la siguiente manera: *"La copia de seguridad de datos del 23 de octubre falló en el servidor #18-P después de que el ingeniero José aplicara el parche 4.1"*.



Esta definición detallada evita las preguntas redundantes y proporciona una buena cantidad de información sobre dónde podría estar el problema.

Estos minutos adicionales dedicados a la definición inicial ahorran tiempo y esfuerzos muy valiosos, proporcionan un sentido lógico de dirección para el análisis y eliminan cualquier noción preconcebida sobre el problema.

7.3.7.2. Describir el problema

El siguiente paso es establecer una descripción detallada del problema. El método K-T proporciona las preguntas que se deben formular sobre cualquier problema para ayudar a identificar las posibles causas.

Las siguientes preguntas ayudan a describir cuatro partes de cualquier problema:

- ¿Cuál es el problema?
- ¿Dónde ocurrió el problema?
- ¿Cuándo ocurrió el problema?
- ¿Cuál es el alcance del problema?

Cada una de estas preguntas exige dos tipos de respuestas:

- **ES:**
Como en "¿Cuál es el problema?" o "¿Dónde ocurrió el problema?"
- **Y PODRÍA SER, pero NO ES:**
Como en "¿Dónde podría estar el problema, pero no lo está?"

Este ejercicio ayuda a comparar y resaltar el qué, dónde, cuándo y cómo de la desviación que está ocurriendo en el rendimiento normal de los procesos comerciales.

7.3.7.3. Establecer las posibles causas

La comparación entre el rendimiento normal y el rendimiento anormal del paso anterior ayuda a crear una lista de las posibles causas del problema.

Hacer una tabla con toda la información en un solo lugar puede ser útil para hacer la comparación.



	Es	Podría ser pero no es	Diferencias	Cambios
Qué	La copia de seguridad del servidor #17-P falló después del parche 3.2	Copias de seguridad fallidas en otros servidores con el parche 3.2	El nuevo ingeniero (José) aplicó el parche	Nuevo procedimiento de parche seguido
Dónde	Servidor del cuarto piso	Servidores del sótano	Normalmente lo realizan los ingenieros de nivel 3	El ingeniero de nivel 1 lo aplicó
Cuándo	15 de noviembre, 12:32 am	En otro momento	Ninguno identificado	
Alcance	Solo en el servidor #17-P	Cualquier otro servidor	Ninguno identificado	

Las nuevas causas posibles se hacen evidentes cuando la información se analiza en conjunto. En el ejemplo, la causa raíz se puede reducir a:

- Error de procedimiento causado por la transferencia de conocimiento inadecuada por parte de los ingenieros.
- Cualquiera que sea el problema, se puede realizar un análisis detallado de las posibles causas con base en la comparación relevante.

7.3.7.4. Probar la causa más probable

En este paso, hay que hacer una pequeña lista de las causas probables y someterlas a prueba antes de sacar una conclusión.

Cada causa probable se debe probar con esta pregunta:

Si _____ es la causa raíz de este problema, ¿explica cuál **ES** el problema y cuál **PODRÍA SER** el problema, pero **NO ES**?

Es más sencillo completar toda la información en una tabla.

Posible causa raíz	Cierto si	¿Posible causa raíz?
El servidor # 34-C tiene un problema	Solo el servidor # 34-C ha sido afectado	Tal vez
Procedimiento incorrecto	El mismo procedimiento afecta a otro servidor	Probablemente
Error del ingeniero	El problema no volvió a ocurrir con el mismo procedimiento	Probablemente no



7.3.7.5. Comprobar la verdadera causa

Por último, hay que eliminar todas las causas improbables y buscar evidencia para las causas más probables.

Con esta verificación, se propone una solución al problema.

Si no hay evidencia de la posible causa raíz, no se debe intentar implementar la solución.

7.3.8. Técnicas de gestión de problemas de TI utilizadas en ITIL

El proceso de gestión de problemas se puede establecer con una buena herramienta de mesa de servicio, pero las técnicas utilizadas para la investigación y el diagnóstico deben variar según la organización.

Es recomendable que las técnicas de investigación sean flexibles en función de las necesidades de la organización en lugar de ser demasiado estrictas.

Dado que los problemas pueden tener cualquier forma o tamaño, es imposible apegarse a una sola técnica para encontrar todas las soluciones; se obtendrán mejores resultados si se combinan varias técnicas. (Un simple problema de conectividad LAN podría resolverse con una sesión rápida de brainstorming, pero un problema de red o VoIP podría necesitar un análisis más profundo).

Enumeramos y explicamos a continuación, algunas técnicas que se puede aplicar en el proceso de gestión de problemas de una organización:

- Brainstorming.
- Método KEPNER-TREGOE.
- Análisis de ISHIKAWA.
- Análisis de PARETO.
- Técnica de los 5 PORQUÉS.
- Otras técnicas.

7.3.8.1. Brainstorming (Tormenta de ideas)

Al conversar con varios departamentos, puede obtener diversas perspectivas y nueva información, generando muchas soluciones potenciales.

Para tener una sesión de **brainstorming** productiva, necesita un moderador.



El moderador se encarga de lo siguiente:

- Dirigir la reunión.
- Documentar la información obtenida.
- Destacar las medidas que se van a tomar.
- Dar seguimiento al entregable discutido.
- Evitar que la sesión se prolongue demasiado.

Las sesiones de **brainstorming** son más productivas cuando se utilizan técnicas colaborativas de resolución de problemas, como el análisis de Ishikawa y el método de los cinco porqués.

7.3.8.2. Método Kepner-Tregoe

El método Kepner-Tregoe (K-T) es una técnica de resolución de problemas y toma de decisiones que se utiliza en muchos campos debido a su enfoque paso a paso para resolver un problema de manera lógica.

Es ideal para resolver problemas complejos tanto en la gestión de problemas proactiva como reactiva.

El método sigue cuatro procesos:

- **Evaluación de la situación:**
Evaluar y aclarar el escenario.
- **Análisis del problema:**
Relacionar la causa con el efecto.
- **Análisis de decisiones:**
Sopesar las opciones alternativas.
- **Análisis de problemas potenciales:**
Anticipar el futuro.

7.3.8.3. Análisis de Ishikawa, o análisis de diagrama de causa y efecto

El análisis de Ishikawa utiliza el diagrama de causa y efecto (también llamado «diagrama de espina de pescado») para enumerar la causa y los efectos de un problema y se puede combinar con las sesiones de lluvia de ideas y el método de los cinco porqués.



Aunque parece simple, el diagrama de Ishikawa al realizar un RCA, resulta muy útil para manejar problemas complejos.

Para comenzar el análisis, hay que:

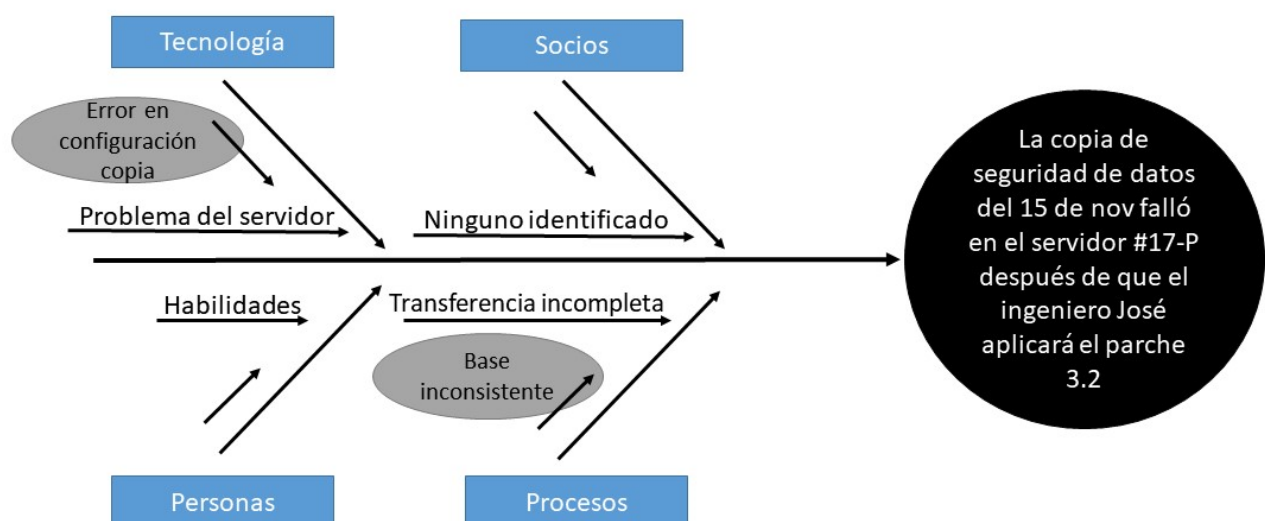
- Definir el problema y usarlo como la «cabeza del pescado» en el diagrama.
- Dibujar la «columna vertebral» y agregar las categorías desde las cuales podría originarse el problema ilustrándolas como las «espinas» del diagrama de pescado.

En general, es más fácil comenzar las categorías con las 4 dimensiones de la gestión de servicios:

- Socios.
- Procesos.
- Personas.
- Tecnología.

Estas 4 categorías pueden ser cualquier cosa que sea relevante para su problema, entorno, organización o industria.

Una vez que estas categorías forman las espinas del pescado, se comienza a asociar las posibles causas de cada categoría. Cada posible causa también se puede ramificar para detallar la razón de esa ocurrencia. Esto podría convertirse en un diagrama complejo con cuatro a cinco niveles de causas y efectos, que posteriormente se derivan en la causa raíz del problema.



Resulta más cómodo dividir las espinas densas en espinas adicionales según sea necesario, y también, combinar las espinas vacías con otras espinas relacionadas así se ordenan y comprende mejor el diagrama.



Hay que asegurarse de que las espigas están llenas de causas, no solo síntomas del problema.

Este análisis también es un esfuerzo de colaboración y requiere un moderador que dirija las sesiones de lluvia de ideas de manera efectiva, todos los participantes tienen la oportunidad de proporcionar una visión integral del problema.

7.3.8.4. Análisis de Pareto

El principio de Pareto es una observación que sugiere que aproximadamente el 80 por ciento de los efectos provienen de aproximadamente el 20 por ciento de las causas.

Esta observación se aplica a una amplia gama de temas, incluida la gestión de problemas.

Cuando se trata de reducir la cantidad de incidentes que ocurren en una organización, es muy útil aplicar el análisis de Pareto antes de comenzar a resolver los problemas, ya que prioriza las causas de los incidentes y ayuda a gestionar los problemas en función de su impacto y probabilidad.

Este análisis se lleva a cabo generando un diagrama de Pareto a partir de una tabla de Pareto, que consiste en el recuento acumulativo de la clasificación de todos los problemas.

Un diagrama de Pareto es un gráfico de barras que muestra el porcentaje acumulativo de la frecuencia de varias clasificaciones de problemas.

Para crear un diagrama de Pareto, hay que seguir los siguientes pasos:

- Recopilar datos de los tickets de problema de la herramienta de mesa de servicio.
- Remodelar los datos en categorías basadas en varios atributos.
- Crear una tabla de Pareto para determinar la frecuencia de los problemas en cada clasificación durante un período de tiempo específico.
- Calcular la frecuencia de la ocurrencia de los problemas en cada categoría.
- Generar el porcentaje de frecuencia acumulativo en orden decreciente.
- Graficar los datos en un gráfico de Pareto.

El paso más importante es remodelar los datos en un conjunto contable de clasificaciones y atributos.

Clasificación y sus atributos:

- **Impacto:**
 - Afecta al negocio.
 - Afecta al departamento.
 - Afecta al usuario.



- **Prioridad:**
 - Baja.
 - Alta.
 - Urgente.
- **Categoría:**
 - Red.
 - Activos de hardware.
 - Activos de software.
- **Duración:**
 - Dentro del SLA.
 - Fuera del SLA.
 - Sin SLA.

En función de estos datos, se genera un diagrama.

Este diagrama ayuda a identificar los problemas que se deben resolver primero para reducir significativamente la interrupción del servicio.

Este análisis complementa los métodos de Ishikawa y Kepner-Tregoe al proporcionar una forma de priorizar la categoría de los problemas, mientras que los otros métodos analizan la causa raíz.

No hay que olvidar que la regla 80/20 sugiere las causas probables y a veces podría equivocarse.

7.3.8.5. Técnica de los 5 porqués

La técnica de los cinco porqués es una técnica sencilla para el RCA.

Define una declaración del problema, luego pregunta repetidamente por qué hasta que se descubre la causa raíz subyacente del problema.

El número de porqués no necesariamente se limita a cinco, sino que puede basarse en el problema y la situación.

La técnica de los 5 porqués complementa muchas otras técnicas de resolución de problemas como el método Ishikawa, el análisis de Pareto y el método K-T.



Retomando el ejemplo de la falla de la copia de seguridad de los datos en un servidor, apliquemos la técnica de los 5 porqués.

- ¿Por qué falló la copia de seguridad de datos en el servidor #32-C?

Debido a la actualización del parche 4.2.

- ¿Qué sucedió con ese parche 4.2?

Se utilizó un procedimiento diferente.

- ¿Por qué se utilizó un procedimiento diferente?

Lo realizó un técnico de nivel 2.

- ¿Por qué lo realizó un técnico de nivel 2?

Todos los técnicos de nivel 1 (que deberían haber realizado la tarea) estaban ocupados.

- ¿Por qué estaban ocupados todos los técnicos de nivel 1?

Por mala gestión de horarios de personal o mala organización de tareas.

Este proceso iterativo revela que no existe un formato estandarizado, lo que ha causado el problema de la falla de la copia de seguridad de datos.

En nuestro contexto, el ejemplo anterior es una ejecución simple del método. En un escenario real, la siguiente pregunta depende de la respuesta a la pregunta anterior, por lo que es imprescindible colaborar con las partes interesadas que tienen un conocimiento detallado del dominio en el que reside el problema.

Al adoptar partes del método K-T junto con la técnica de los cinco porqués, como proporcionar evidencia a cada respuesta antes de validarla con una pregunta de respuesta, puede garantizar la precisión del análisis durante las sesiones de resolución de problemas.

7.3.8.6. Otras técnicas

Existen muchas otras técnicas, cada una con sus propias fortalezas. Algunas de ellas son las pruebas cronológicas, el análisis del árbol de fallas, el método de aislamiento de fallas, las pruebas de hipótesis y el análisis de puntos débiles.

Normalmente se utiliza una combinación de técnicas en función de cada situación.



7.3.9. Mejores prácticas de la gestión de problemas de TI

Hemos visto el proceso y los diversos métodos para practicar la gestión de problemas, pero también hay que tener en cuenta algunas cosas que ayudan a evitar pequeños contratiempos en la gestión de problemas, planteándose que se debe hacer y que no se debe hacer.

- **Lo que se debe hacer.**

- Establecer la diferencia entre un incidente y un problema de manera precisa:

Los procesos de ITIL solo funcionan si existe una distinción clara y reconocida entre la gestión de incidentes y la gestión de problemas, por ello hay que establecer una distinción que funcione para cada organización.

- Reconocer que el gestor de problemas es un rol no técnico:

El gestor de problemas es el pegamento que mantiene unido a todo el equipo. La parte técnica del proceso será realizada por expertos, pero el gestor de problemas es quien permite que esto suceda.

- Establecer los objetivos para los esfuerzos de gestión de problemas:

Avanzar con objetivos a corto y largo plazo para que el enfoque no se vea afectado fácilmente.

Por ejemplo, considerar que los objetivos a corto plazo son algo así como resolver los diez problemas principales que afectan el negocio, y los objetivos a largo plazo son reducir los gastos de soporte.

- Buscar soluciones permanentes en lugar de soluciones temporales:

Aprovechar los verdaderos beneficios de la gestión de problemas buscando soluciones permanentes, incluso si se trata de una solución alternativa permanente.

- Valorar a las personas que desafían el estado de las cosas:

Apreciar a los miembros que cuestionan el estado actual de las cosas puede ser el origen de mejorar el sistema de su organización.

- **Lo que no se debe hacer.**

- Intentar lograr la perfección desde el principio:

La gestión de problemas es una experiencia de aprendizaje y es única para cada organización, intentar ser perfecto desde el principio es prepararse para el fracaso.

Nadie se convierte en una estrella de rock el primer día que comienzan a tocar la guitarra.



- Complicarse con enfoques reactivos y proactivos:

Hay que comenzar con calma, algunos problemas no se pueden pasar por alto debido a su gravedad y otros se deben encontrar a través del análisis.

- Medir la gestión de problemas como un proceso individual:

Los procesos de ITIL® están diseñados para cooperar entre sí y facilitar el manejo de la prestación de servicios de TI.

Tanto los buenos como los malos resultados de la gestión de problemas pueden derivarse de la gestión de incidentes, la gestión de cambios o incluso la gestión de proyectos.

7.3.10. Indicadores clave de rendimiento para la gestión de problemas de TI

Los indicadores clave de rendimiento (**KPI**) deberían proporcionar valor a los usuarios, técnicos y partes interesadas por igual.

Si bien estas métricas actúan como una herramienta de autoexamen, se recomienda limitar las métricas a siete u ocho para el proceso de gestión de problemas, ya que demasiadas métricas podrían proporcionar una percepción sesgada del proceso en sí.

Podría haber problemas a nivel operativo, pero las diferentes métricas podrían llegar a una conclusión diferente al trabajar juntas.

Los KPI pueden variar según la forma en que funciona una organización, por lo que no hay una sola lista de métricas aplicables para todas las organizaciones. Para determinar cuáles KPI se deben monitorear, se debe pedir a los interesados que evalúen y decidan qué sería mejor.

A continuación, se muestran los KPI más aplicables para el proceso de gestión de problemas.

KPI	Fórmula	Comentario
Tiempo promedio para iniciar el RCA	El tiempo promedio desde la identificación de un problema hasta el inicio del RCA.	Esto muestra la eficiencia del equipo de diagnóstico de problemas.
Número total de problemas incompletos	El recuento de problemas que aún no se han sometido al RCA.	Esto difiere de un problema no resuelto. Los problemas incompletos se registran, pero aún no se ha comenzado a trabajar en ellos.
Porcentaje de aumento / disminución de incidentes mayores	Porcentaje de aumento / disminución de incidentes mayores.	Esta métrica puede ayudar a identificar tendencias, como la frecuencia de ocurrencia de los problemas.



KPI	Fórmula	Comentario
Número total de registros de problemas reportados	El número total de problemas registrados a partir de incidentes.	A medida que madura su práctica de gestión de problemas, deberían disminuir los problemas reportados a partir de incidentes.
Tiempo promedio de resolución de problemas	El tiempo promedio transcurrido desde la identificación hasta la resolución de un problema.	Los problemas pueden tardar mucho tiempo en resolverse. Para acelerar el proceso, se recomienda medir los esfuerzos de mejora en el RCA y el proceso de gestión de problemas.
Número total de errores conocidos	El recuento de errores conocidos en la KEDB.	Esto resalta los esfuerzos de documentación de su organización. Si la relación entre el número de problemas registrados y los errores conocidos es baja, es una buena señal.
Número total de problemas sin resolver	El recuento de problemas no resueltos en la mesa de servicio.	Los problemas no resueltos son aquellos cuyo RCA está en curso.
Número total / promedio de incidentes asociados con problemas	El recuento de todos los incidentes con un ticket de problema asociado.	Cuando intente ampliar sus actividades de diagnóstico proactivo, asegúrese de que esta métrica se disminuya gradualmente al mínimo.
Porcentaje de problemas con una causa raíz identificada	El número de problemas que tienen una causa raíz clara e identificada, en comparación con los problemas registrados en general.	Ambas métricas complementan otras métricas, como la efectividad de la práctica de gestión de problemas, y ayudan con la toma de decisiones, como las decisiones monetarias.
Porcentaje de problemas con una solución	El número de problemas que tienen una solución alternativa en lugar de una solución permanente, en relación con los problemas registrados en general.	

7.3.11. Mejores funciones para el software de gestión de problemas

Resulta más fácil aprovechar el software para formular su proceso de gestión de problemas en lugar de tratar de desarrollarlo desde cero.

Existen numerosas soluciones de software para la gestión de problemas, que deben incluir como mínimo, las siguientes funciones:



Lista de funciones		Valor
Creación y registro del problema	Crear problemas a partir de un incidente, y plantillas de problemas	Identificar incidentes de un problema subyacente que requieren una investigación exhaustiva y asociar cambios
	Marcar un problema como un error conocido	Mantener una KEDB
Análisis del problema	Identificar roles para los problemas y técnicos	Identificar el propietario del problema
	Incluir análisis, impacto y RCA para cada problema	Analizar el impacto, los síntomas y la causa raíz del problema, y documentarlos
	Marcar los servicios afectados y activos involucrados	Definir con precisión cada problema y cuantificar el impacto en el negocio
Solución del problema	Agregar tareas con dependencias dentro de un problema	Asignar la implementación de la solución a técnicos específicos con fechas de vencimiento
	Marcar las soluciones alternativas como soluciones y asociar un cambio con el problema	Proporcionar una solución temporal con una solución alternativa o permanente para el problema. La gestión de problemas funciona junto con otros procesos de ITSM
Cierre del problema	Registrar la solución del problema (soluciones) y crear notificaciones	Evitar actividades redundantes y garantizar registros consistentes en todos los tickets. Establecer mecanismos de notificación para mantener informados a los interesados
	Cerrar todos los incidentes asociados automáticamente al cerrar el problema	Ahorrar tiempo y esfuerzo a los técnicos
	Crear registros de trabajo para registrar el costo, el esfuerzo y el tiempo necesario para resolver el problema	Obtener KPI detallados con respecto al costo y el tiempo necesario para resolver los problemas

7.3.12. Resumen

El marco de gestión de problemas de ITIL es una guía para todas las organizaciones encaminadas hacia un enfoque proactivo para el diagnóstico y la resolución de problemas.

La gestión de problemas y sus prácticas se adaptan a todas las organizaciones, independientemente del tamaño, la distribución geográfica, la industria y la tecnología utilizada para funcionar todos los días.



Las organizaciones con una gestión de incidentes robusta deben aspirar a establecer un entorno básico de gestión de problemas mediante la implementación de un canal separado para registrar y gestionar problemas y mantener una **KEDB**.

A medida que la experiencia del equipo de gestión de problemas crece junto con la organización, el proceso también debe madurar.

Para una organización que ya practica la gestión de problemas, sus aspiraciones deberían consistir en reducir los incidentes a un mínimo histórico. Esto se puede lograr más fácilmente a través de un enfoque proactivo para la gestión de problemas.

Para implementar el proceso de gestión de problemas, un primer paso consiste en utilizar una herramienta de mesa de servicio con los módulos correctos para garantizar la integridad de las operaciones de la mesa de servicio de TI y un control centralizado para los tickets, incidentes y problemas.

Optimizar el proceso de gestión de problemas en su organización es un proyecto a largo plazo que dará sus frutos a medida que crezca su negocio y su infraestructura de TI.

7.4. Herramientas de Ticketing

Las herramientas de ticketing son aplicaciones de software, que permiten organizar mediante generación de tickets con una clasificación de datos, las demandas de los usuarios, optimizando el tiempo de resolución de los problemas y mejorando la experiencia del cliente.

Con las herramientas de ticketing, se consigue:

- Centralizar los canales de servicio de atención al cliente.

Se optimiza el servicio, utilizando una sola forma de comunicación, es decir de comunicación del usuario solicitando la resolución a una determinada incidencia.

- Categorizar las consultas de los usuarios.

Sabiendo, ya a priori una clasificación de las distintas peticiones del usuario, se mejora la organización del trabajo y por tanto la respuesta y resolución del problema.

- Localizar e identificar consultas recurrentes.

Si se repiten el mismo tipo de dudas o problemas, se detecta rápidamente la necesidad de hacer una corrección en el origen, de modo que esas incidencias podrán desaparecer en un futuro.

- Permitir al usuario seguir la evolución de su ticket.

La satisfacción del cliente o usuario es mayor, si puede hacer un seguimiento de su incidencia, si está en proceso de resolución etc.

- Detectar y clasificar usuario.

Si se detectan diferentes perfiles de usuarios, se puede realizar una mejor atención personalizada.



+ Info

El 49% de los clientes clasifica como buena experiencia de atención aquella donde se resuelve su consulta con rapidez.

Por ello, la rapidez es uno de los factores claves en cualquier proceso de atención.

El funcionamiento básico de una herramienta de ticketing es generar un ticket por cada consulta que se realiza en el servicio de atención, y categorizarlo para que sea enviado al técnico o agente más adecuado para su resolución.

Lo hace de forma que el sistema procesa, clasifica, administra, gestiona, automatiza y organiza las entradas y, cuando ya se ha resuelto la incidencia, se cierra la consulta.

Las acciones concretas que se realizan en una empresa son:

- Convertir automáticamente los emails recibidos en tickets.
Cuando un cliente envía un nuevo ticket, se genera una notificación automáticamente.
- Automatizar la asignación de los tickets al técnico adecuado.
- Detectar las consultas más comunes para poder generar un sistema de preguntas frecuentes o respuestas automáticas que solucionen el reclamo del cliente.
- Fomentar la omnicanalidad del servicio de atención, centralizando los múltiples canales de atención al cliente.
- Permitir a los agentes encargados de solucionar las incidencias recibidas, simplificar la búsqueda de tickets, agilizando así el tiempo de resolución.

La principal ventaja del uso de una herramienta de ticketing, es mejorar los procesos de control de atención al cliente y su nivel de satisfacción con el servicio que recibe, para ello se utiliza:

- Información centralizada.

Los datos de los tickets se almacenan en el sistema para hacer un informe final con la evaluación de la situación.

- Visión global.

Permite identificar rápidamente incidencias de la empresa, reconocer aquellas que son similares y generar un diagnóstico que reconozca las problemáticas más recurrentes.



- Repartición de servicios.

Posibilita la administración de las solicitudes entrantes y para definir correctamente a qué trabajador o equipo se le asigna.

- Acceso a informes y estadísticas para un fácil seguimiento de los servicios.

7.4.1. Ejemplos de Herramientas de Ticketing

Ya hemos visto como estas herramientas han cambiado radicalmente la forma en la empresa interactúa con los usuarios y/o clientes, y facilitan la solución a los problemas en un tiempo mínimo.

Vamos a ver a continuación algunos de los softwares existentes en el mercado con sus características principales.

- **Freshdesk.**

Esta plataforma se encuentra en la Nube, y proporciona un plan de suscripción.

Una de sus características más destacadas es la omnicanalidad, pues permite la interacción con el cliente desde cualquier vía y lugar.

La omnicanalidad, es una estrategia de comunicación utilizado para estar en contacto con los clientes o prospectos a través de diferentes canales (email, redes sociales, sitio web, etc.). En vez de usar los canales por separado, se utilizan de forma unificada para llegar a los consumidores.

También, ofrece bases de conocimientos, registro de gestiones, integración de RRSS y una cantidad ilimitada de operadores para el servicio al cliente.

- **C-Desk.**

La licencia de uso de C-Desk es gratuita.

Su funcionalidad consiste en la aplicación de cuestionarios y encuestas para medir la satisfacción del cliente, manejo de chat interno, centro de ayuda para agentes y la gestión estratégica de proyectos, etc. por ejemplo.

- **Request Tracker.**

Comúnmente abreviado como RT, es un programa para ticketing open source o de código abierto, que se distribuye bajo la licencia pública general de GNU escrito en *perl*.

Su flexibilidad deja que pueda personalizarse para las necesidades de cada empresa, por lo que la instalación puede resultar un poco complicada.

Se utiliza para coordinar tareas y gestionar solicitudes entre una comunidad de usuarios, como:

- Hacer seguimiento de las incidencias con la clientela.
- Enviar notificaciones automáticas.



- Diseñar el workflow (flujo de trabajo) del equipo de operadores.

Workflow es la automatización de las tareas de una empresa, de tal manera que todo queda incluido dentro de un orden y jerarquía preestablecidos.

- **Jira Service Desk.**



Fuente: <https://commons.wikimedia.org/wiki/File:JIRA.png>

Jira Service Desk es uno de los mejores productos software de help-desk, además de ser uno de los más conocidos.

Es una de las herramientas de ticketing pensadas para grandes de empresas con servicios al cliente de mucho tráfico, desarrollada por Atlassian.

Sus funciones se reparten en módulos estratégicos que facilitan la evaluación sobre el rendimiento de cada agente, mantener un registro exhaustivo de tickets o hacer comentarios y cambios en gestiones específicas. Jira Service Desk brinda distintos planes de pago, cuyas herramientas se limitan según lo que requiere tu organización.

Este *software* fue presentado en el último trimestre de 2013 por la empresa australiana Atlassian, y fue creado como *add-on* de Jira (aplicación web centrada en el seguimiento de incidencias y procesos de gestión).

Dentro de todas sus características podríamos destacar las siguientes:

- Es sencillo de usar, muy intuitivo.
- Permite obtener informes en tiempo real.
- Colas personalizables para organizar el trabajo.
- Apertura de *tickets* vía correo electrónico.
- Automatización de tareas repetitivas, aligerando cargas de trabajo.
- *Call center* y CRM.
- Multicanal.
- Es *software* propietario.



- **Zendesk.**



*Imagen cortesía de Sarah Worthy (fuente:
<https://www.tendenci.com/photos/552/in/19/>)*

Zendesk Support es otro de los *help-desk* más usados y conocidos. Nace en Copenhague con la idea de crear un *software* sencillo y personalizable.

Al contrario que JIRA, que estaba orientado a grandes empresas, Zendesk funciona mejor en pequeños entornos.

Está diseñada para pequeñas áreas de atención al cliente, dispone de un plan de suscripción pago que puede ir implementándose en función del avance de la empresa. El dashboard es muy visual y simple de utilizar por primera vez.

Los puntos más destacables, y algunas de sus funciones son:

- Es sencillo de usar y de instalar. Es un *software* visualmente atractivo y cuenta con un gran número de vídeos que nos ayudan a conseguir nuestros objetivos.
- Cuenta con un buen *dashboard*.
- Es un producto maduro, con un gran número de usuarios, por lo que posee una gran comunidad en la que poder solucionar problemas y dudas.
- Tiene soporte en España.
- Es multicanal.
- Es *software* propietario.
- Generar informes estadísticos.
- Brindar comunicación en varios idiomas.
- Ofrecer un portal solo para el cliente.
- Puede integrarse con otras plataformas y apps.



- **OsTicket.**

OsTicket es una aplicación de **código abierto** simple, escrita principalmente usando el lenguaje de programación PHP.

Una de las características que lo diferencia es que permite adjuntar material multimedia para la resolución de cada *ticket* o aplicar filtros para determinar el canal de origen de las incidencias.

Permite preestablecer respuestas automáticas, simplificando más el trabajo de los operadores.

OsTicket es un sistema automatizado de soporte al cliente, fácil de usar y de administrar, que integra discretamente todos los *tickets* creados vía correo electrónico o por formulario web, dentro de una interfaz web simple. Administra, organiza y archiva fácilmente todas las solicitudes de soporte. En ambos casos, los clientes, al abrir una consulta, recibirán un correo electrónico de autorrespuesta.

Los clientes podrán ver el estado de los *tickets* que han abierto y su historial en línea, utilizando para ello su número de consulta.

Es una alternativa atractiva a otros sistemas de soporte al cliente que son mucho más costosos y complejos, ya que OsTicket es simple, ligero y fácil de instalar y usar. Además, es gratuita.

- **ngDesk.**

Integra múltiples funciones de uso gratuito y sin límites en la cantidad de sus usuarios.

En su dashboard se puede visualizar los días de mayor tráfico, gráficos estadísticos sobre la productividad o los procesos de derivación de las incidencias, y es capaz de emitir notificaciones offline a los agentes acerca del progreso de sus tickets en tiempo real.

- **Xperta.**

Xperta es una herramienta ideada para apoyar a los servicios técnicos en la gestión de incidencias. Se trata de una herramienta basada en web que nace orientada a los departamentos de soporte, para realizar el control y seguimiento de las incidencias que comunican los clientes o usuarios a su cargo.

Es una aplicación que no requiere instalar nada en el ordenador, solamente requiere un navegador web y una conexión a Internet. Es un *software* propietario.

- **BMC Remedy.**



Fuente:
<https://en.wikipedia.org/wiki/File:RemedyCorp.png>



BMC Remedy ITSM, es un Desktop Service (Gestor de Atención al Usuario) ofrece un soporte integrado para las mejores prácticas de ITIL, que permite a las organizaciones obtener valor de esta herramienta en un plazo de tiempo inferior. Es *software* propietario.

- **Freshservice.**

Freshservice es un servicio de asistencia TI en línea con un toque nuevo. Ofrece una experiencia de usuario refrescante además de potentes funciones de administración de activos y *tickets*, como el descubrimiento automático de nuevos recursos, una administración de configuración potente y un análisis de impacto mejorado.

- **Integria IMS.**

Integria IMS pertenece a Ártica ST, empresa española creada en 2005. Surge para cubrir las carencias que el equipo había encontrado en otros productos de *help-desk*. Está indicada para pequeñas, medianas y grandes empresas.

Características:

- Sencillo de usar e intuitivo. Es una herramienta de solución rápida.
- Sin módulos adicionales, lo que es un punto muy importante, ya que integra todas las funcionalidades sin necesidad de pagar más.
- Es flexible y cuenta con campos personalizables (*custom fields*).
- Tiene la posibilidad de refrescar automáticamente la búsqueda y memoriza estas búsquedas para facilitar nuestro trabajo.
- Tiene una excelente base de conocimiento, pudiendo añadir los *tickets* con información, convertir en base de conocimiento, etcétera, al contrario que Jira o Zendesk.
- Dispone de API.
- Cuenta con un potente sistema de inventario para hacer más fácil nuestro trabajo.
- No hay carencias en los flujos de trabajo o *workflows*, fluye adecuadamente.
- Se va actualizando de manera gratuita, añadiendo herramientas que pueden facilitar el trabajo. Si tiene alguna carencia, la soluciona.
- Opción de descargar y compartir archivos.
- Es *software* propietario.



- **Bugzilla.**



Fuente: <https://commons.wikimedia.org/wiki/File:Bugzilla.jpg>

Bugzilla es una herramienta basada en web de seguimiento de errores (*Bug Tracking System* o BTS, por sus siglas en inglés), originalmente desarrollada y usada por el proyecto Mozilla. Está bajo la licencia pública de Mozilla.

Bugzilla permite organizar en múltiples formas los defectos de *software*, permitiendo el seguimiento de múltiples productos con diferentes versiones, a su vez compuestos de múltiples componentes. Permite, además, categorizar los defectos de *software* de acuerdo con su prioridad y severidad, así como asignarles versiones para su solución.

7.4.2. GLPI

GLPI es una herramienta ITSM que ayuda a manejar y controlar los cambios en la infraestructura informática de manera sencilla, resolver problemas emergentes de manera eficiente y hace posible el control fiable sobre el presupuesto y gastos que realiza una compañía en IT.

Características:

- Permite la segmentación por entidades con su respectivas políticas administrativas y gastos permitidos.
- Visualiza la condición de cada activo de TI en tu compañía en tiempo real con nuestro inventario multiplataforma automático incorporado en GLPI.
- Controla el seguimiento del ciclo de vida de tus activos, supervisa su obsolescencia y se obtiene en tiempo real el estatus de las licencias y la obsolescencia del software.

Detecta con anticipación renovaciones o actualizaciones de software o hardware a ser ejecutados.

- Es compatible con ITIL® V2.



- Mejora el enfoque y la respuesta de los técnicos de TI a usuarios en necesidad de asistencia.
 - Administra los servicios solicitados, incidentes, problemas y cambios en la infraestructura con el estándar y las mejores prácticas más aceptadas en el mundo para gestión de servicio.
- Inventario automático de TI.

7.4.2.1. Principales características de la versión GLPI 9.4

- **Search engine: nested criteria.**

El motor de búsqueda disponible en todas las listas de elementos ahora permite construir consultas muy complejas.

Existe un nuevo botón de grupo para separar un conjunto de criterios de otros.

Se puede configurar un operador diferente para todo el grupo, y la consulta resultante estará rodeada por paréntesis.

Otros cambios:

- Los cambios ahora se pueden filtrar con reglas globales.
- Revisión de la interfaz para aclarar diferentes acciones.

- **UX : Knowbase and FAQ.**

La pestaña Examinar en la base de conocimientos se ha actualizado, ahora se muestra un árbol para las categorías y cada una muestra una credencial que cuenta el número de artículos asociados a la categoría.

- **Timeline for Changes and Problems.**

Con Curtis Conard, se puede agregar seguimientos a los cambios y problemas de ITIL y estos objetos ahora tienen una pestaña de línea de tiempo para reagrupar sus seguimientos, tareas, documentos y soluciones.

- **Followups split and Tickets merge.**

Con Curtis Conard, los boletos ahora tienen 2 nuevas acciones:

- Divida un seguimiento: cree un nuevo ticket copiando un seguimiento (se mantiene un enlace en el ticket anterior).
- Combine un ticket como un nuevo seguimiento en un ticket existente con la opción de acciones masivas.



- **Assets rules engine.**

Se proporciona un nuevo motor de reglas para actualizar automáticamente algunos campos cuando se crea o actualiza un activo. Por ejemplo, puede asignar un técnico específico cuando una computadora se convierte en parte de una entidad.

- **Centralized command line tool.**

La carpeta de scripts proporcionada en los archivos GLPI tenía muchos archivos dispersos. Con esta versión, iniciamos una consola (disponible mediante el comando `php bin / console`), que centraliza los scripts antiguos. No se han migrado todos los scripts, es algo que se espera que se realice en futuras versiones.

- **Misc.**

- Bloqueo de la pestaña de personalización del usuario.
- Nueva acción en las reglas de negocios para tickets dirigidos al campo de nombre completo (antes, solo puede orientar el nombre corto de las categorías).
- Nuevo tipo de dispositivo para activos: Modem.
- Soporte de autenticación CAS 3.
- Opción de texto enriquecido eliminada (GLPI ahora solo está en texto enriquecido en objetos ITIL).
- Un nuevo campo en el formulario de usuario: responsable (puede sincronizarlo con el servidor ldap).

- **Under the hood.**

Esta versión de GLPI es más estable y confiable, con lo siguiente:

- Cobertura de código para pruebas unitarias, desde la versión 9.2, con la adición de pruebas unitarias, se avanza en la cobertura de todo el código fuente.
- SQL Iterator, el marco GLPI proporciona una clase para abstraer la generación de consultas SQL.

Se reemplazan muchas consultas de MySQL en bruto, con el objetivo final (todavía no implementado en esta versión) de permitir el uso de otros motores SQL (como Postgres).

- SCSS pasa a ser el formato oficial de GLPI para hojas de estilo.

Se proporciona un compilador automático para desarrolladores, también para complementos.

- Sesión como caché, como en la versión en 9.3, se almacena más y más en caché para proporcionarle una herramienta ITSM rápida.



+ Info

Puedes consultar más información y descargar versión demo de GLPI en su web oficial:

<https://glpi-project.org/es/>

7.5. TIC. Las TIC en la educación

Las llamadas TIC, Tecnologías de la Información y la Comunicación son los recursos y herramientas que se utilizan para el proceso, administración y distribución de la información a través de elementos tecnológicos, como: ordenadores, teléfonos, televisores, etc.

A través del paso del tiempo la utilización de este tipo de recursos se ha incrementado y actualmente presta servicios de utilidad como el correo electrónico, la búsqueda y el filtro de la información, descarga de materiales, comercio en línea, entre otras.

Entre los beneficios que aportan podemos mencionar:

- Permite el desarrollo de la salud y educación.
- Desarrollo de profesionales a través del intercambio de información.
- Apoyo a pequeños empresarios para la promoción de productos.
- Permite el aprendizaje interactivo.

El gran desarrollo de la tecnología y la búsqueda de formas de comunicación cada vez más eficientes, hace que las TIC se hayan posicionado como uno de los pilares básicos de la sociedad.

Las TIC en La Educación

Las herramientas TIC ayudan a responder a las necesidades del alumnado, reuniendo aspectos fundamentales como:

- **Flexibilidad:**

Tanto el alumno como el profesor pueden decidir el uso del material informático o dispositivo electrónico que se adapta a sus necesidades para realizar una tarea en concreto.



- **Versatilidad:**

Con las herramientas digitales te permite realizar diferentes tareas o actividades en diferentes formatos, como, por ejemplo, la producción, edición o transformación de un vídeo.

- **Interactividad:**

Con el uso de las herramientas digitales, los alumnos pueden interactuar y descubrir una serie de contenidos que les facilite el logro en la consecución de las tareas.

- **Conectividad:**

Los alumnos pueden comunicarse, compartir e intercambiar información por medio del uso de redes sociales o de plataformas virtuales en las cuales pueden aportar y ofrecer sus puntos de vista referidos a un tema en específico.

Hay que destacar la importancia de una serie de condiciones que deben seguirse para asegurar que con el uso de las herramientas digitales en las diferentes tareas de clase aportan esa ayuda necesaria para que el proceso de enseñanza-aprendizaje del alumnado sea favorable, teniendo en cuenta los siguientes aspectos:

- Adecuación de las exigencias al nivel del desarrollo del alumno y de sus capacidades personales.
- Adecuación de los contenidos a los conocimientos previos de los alumnos como iniciadores en la construcción de los nuevos aprendizajes.
- Adecuación de los materiales para que se permitan la manipulación, descubrimiento y la transformación creativa.
- Adecuación de las tareas por medio de trabajos cooperativos para afianzar las relaciones sociales dentro del aula.

Diferentes estudios indican que el uso de las TIC en el ámbito educativo depende de varios factores (formación, materiales, actitudes, etc.), entre los cuales destaca el interés y formación por parte de los miembros del profesorado, tanto a nivel instrumental como pedagógico.

Un estudio llevado a cabo por Apple Classrooms of Tomorrow (1985), en el cual se analiza cómo los profesores introducen las TIC en las aulas, explica la evolución que se produce por medio de 5 etapas:

- **Acceso:**

Aprendizaje del uso básico de la tecnología.

- **Adopción:**

Utilización de la tecnología como apoyo a los estilos tradicionales de la enseñanza.

- **Adaptación:**

Integración de la tecnología en la práctica de actividades tradicionales del aula, aportando mayor productividad y éxito en la consecución de las tareas.



- **Apropiación:**

Utilizan la tecnología para favorecer los estilos de enseñanza cooperativos, colaborativos, creativos e interdisciplinares, por medio de un aprendizaje basado por proyectos.

- **Invencción:**

Se descubren nuevos usos de la tecnología y se combinan con otros usos de forma creativa.

7.5.1. Las claves del uso de las TIC en el aula

El uso de los TIC en las aulas debe aportar el máximo de beneficios posibles, para lo que hay que tener en cuenta los siguientes aspectos:

- **Planificación.**

No basta con facilitar Tablet u ordenadores a los alumnos, es necesario realizar una planificación sobre cómo comenzar a introducir la tecnología en el aula, analizando sus implicaciones (infraestructura necesaria, formación, ayudas, etc...), para poder poner en práctica un proceso gradual de implementación de las TIC.

- **Creación de experiencias de aprendizaje.**

Para poder utilizar las TIC en el aula, se deberán planificar experiencias de aprendizaje con las que los alumnos puedan adquirir los conocimientos y las habilidades deseadas, como, por ejemplo: búsqueda de información, comunicación virtual, resolución de problemas, trabajos en equipo, creación de información, etc.

- **Autonomía del alumno.**

Las tecnologías utilizadas deben de promover la participación de los alumnos en su aprendizaje de forma autónoma y responsable. Existen nuevos modelos que se van implementando poco a poco con gran éxito como es el caso por ejemplo del aula invertida.

- **Tener presente el objetivo.**

Las TIC no deberían de ser vistas como un fin en sí mismas, sino como una herramienta más para conseguir los objetivos educativos, que nunca deben perderse de vista. De hecho, la idea es que las TIC se integren a las estrategias que ya se utilicen dentro del aula, y no ser una actividad ajena a lo que se realiza normalmente dentro de la escuela.

- **Capacitación de los profesores.**

Como último punto, cabe resaltar la importancia de que, para poder implementar adecuadamente las TIC dentro del aula, los profesores deberán estar debidamente capacitados en el uso de la tecnología. De hecho, esta es la verdadera clave del éxito de este proceso, que tanto el centro educativo como los profesores conozcan y sepan usar estas tecnologías para ponerlas en práctica con eficacia.



7.5.2. Impacto de las TIC en la sociedad

El impacto de las TIC en la sociedad se puede observar desde tres diferentes ángulos:

- **La Economía.**

Encontramos una mejora en los procesos y rendimientos del sector productivo.

- **La Administración Pública.**

Permite una mejor compartición y difusión de la información y gestión administrativa a la sociedad, así como facilitar su acceso y utilización.

- **La Sociedad (Universidad).**

Donde la universidad tiene la misión de formar al ciudadano que será el futuro de la sociedad en muchos aspectos. La Universidad tiene la responsabilidad de formar al ciudadano del mañana, que deberá desenvolverse con soltura habiendo adquirido las competencias necesarias en la sociedad digital.

Estos ciudadanos serán también los empleadores, directivos, emprendedores, formadores, o los trabajadores del conocimiento del mañana y, como tal, la universidad debe dotarlos de las competencias y capacidades adecuadas.

También debe focalizarse y considerar la transferencia tecnológica, por su doble impacto, tanto por el volumen de negocio cuantificable que evidentemente repercute en la propia institución, como en la mejora de los procesos o la mejora de las técnicas, que repercute directamente en el tejido empresarial y por ende en la economía.

7.5.3. La Gestión de Servicios de TIC en la universidad

La gestión ITSM en las universidades son las actividades que realizan para diseñar, planificar, entregar, operar y controlar los servicios de tecnología de la información y comunicación (TIC) que se ofrecen a su personal y alumnos.

A diferencia de los enfoques de gestión de TIC más orientados a la tecnología, como la gestión de redes y la gestión de sistemas, la gestión de servicios de TIC se caracteriza por adoptar un enfoque de proceso hacia la gestión, centrándose en las necesidades de los usuarios y los servicios de TIC para estos y enfatizando la continuidad mejora.

Los marcos de gestión de servicios de TIC han sido influenciados por otras normas y han adoptado conceptos de ellas, por ejemplo, CMMI, ISO 9000 o ISO / IEC 27000.

La ejecución de los procesos en una organización, especialmente aquellos procesos que están más impulsados por el flujo de trabajo pueden beneficiarse significativamente de contar con el apoyo de herramientas de software especializadas.



HERRAMIENTAS

Las herramientas ITSM a menudo se comercializan como suites ITSM, que admiten un conjunto completo de procesos ITSM.

En su núcleo, suele haber un sistema de gestión de flujo de trabajo para manejar incidentes, solicitudes de servicio, problemas y cambios.

Por lo general, también incluyen una herramienta para una base de datos de gestión de la configuración.

La capacidad de estas suites para permitir un enlace fácil entre incidentes, solicitudes de servicio, problemas y registros de cambios entre sí y con registros de elementos de configuración de la **CMDB**, puede ser una gran ventaja.

Las herramientas ITSM también se conocen comúnmente como herramientas ITIL.



+ Info

La **CMDB** (Configuration Management DataBase) es un concepto que introduce ITIL – ISO 20000 para facilitar la gestión de los servicios TI.

Se define como una base de datos donde administrar y gestionar todos los elementos de la compañía (Configuration Items o CI) que son necesarios para la prestación de servicios.

Más de 100 herramientas son herramientas autoproclamadas ITSM o ITIL. Proveedores de software como Axios Systems, OTRS y Marval (software), cuyas herramientas ITSM cumplen con requisitos funcionales definidos para respaldar un conjunto de procesos ITIL, pueden obtener la aprobación oficial, lo que les permite utilizar las marcas comerciales de Axelos y un logotipo "compatible con el proceso ITIL", bajo el esquema de respaldo de software ITIL de Axelos.



8. Control remoto de puestos de usuario

No hay que confundir el Control remoto de puestos de usuario con el arranque remoto de un ordenador, que está apagado (aunque debe estar con señal de corriente eléctrica, y otras características para poder realizar el encendido remoto).

Existen servicios que nos permiten conectarnos de forma remota a otros equipos, (ya encendidos y en funcionamiento con un determinado software) de forma que podemos trabajar con un ordenador que está en una ubicación física diferente a la que estamos nosotros.

El **acceso remoto** (o escritorio remoto) es la capacidad de acceder a una computadora o dispositivo desde cualquier lugar **remoto**.

Con un software de acceso remoto instalado en un ordenador, se tiene la libertad de conectarte a él con otro dispositivo desde cualquier lugar.

Una vez conectado, se puede tener un control total sobre el dispositivo al que se está accediendo remotamente, de forma que se puede ejecutar cualquier aplicación, o abrir cualquier archivo etc. incluso transferir un archivo al dispositivo desde el que estás accediendo remotamente (portátil, Tablet, Smartphone), o bien enviarlo desde el programa de correo electrónico.



Atención

El Centro Criptológico Nacional (CCN), indica unas medidas de seguridad para acceso remoto.

<https://www.ccn-cert.cni.es/informes/abstracts/4880-medidas-de-seguridad-para-acceso-remoto/file.html>

Cada solución de acceso remoto es diferente, pero en general, todas funcionan de manera similar.

Primero está el software, es necesario descargar e instalar las aplicaciones necesarias en cualquier computadora a la que se desea acceder y en el dispositivo móvil desde donde hay que conectarse.

Una vez instaladas las aplicaciones, en el dispositivo desde el que estás accediendo remotamente se abre dicha aplicación instalada y hay que elegir a que ordenador se desea acceder, que, por supuesto deberá estar encendido, con acceso a Internet y con la aplicación de acceso remoto en ejecución.



Cada solución de acceso remoto funcionará de forma ligeramente diferente y tendrá su propio conjunto de características y versiones de prueba, de uso doméstico o de pago.

Veremos las diferentes formas y requisitos para arrancar un ordenador apagado de forma remota.

8.1. Conceptos previos

Para entender bien el Acceso remoto, vamos a indicar los siguientes conocimientos previos necesarios:

- Fabricas OEM o ODM.
- Administración fuera de banda o en banda.
- Intel Management Engine.
- Interfaz de gestión de plataforma inteligente (IPMI).

8.1.1. Fabricas OEM O ODM

Hay que tener en cuenta que existe 2 tipos de fábricas que suministran componentes o piezas finales:

- **ODM (Original Design Manufacturer).**

Fabricante de diseño original (marcas propias).

Son aquellos fabricantes que diseñan y producen su marca, pero permiten que sean comercializadas por terceros, es decir tu puedes comprar a un fabricante su producto con su marca y comercializarla sin restricciones.

Características:

- Los diseños son propiedad del fabricante y solo se pueden comercializar con su marca.
En ocasiones puede haber un mismo modelo disponible en versión OEM y ODM a la vez.
- El fabricante asume la responsabilidad con el control de calidad para proteger su imagen.
- Los diseños pueden variar en períodos cortos de tiempo.
- Generalmente no se puede realizar la personalización del producto, o es de forma muy limitada.
- Generalmente no te permiten realizar modificaciones técnicas que disminuyan el costo del producto.

Esto afecta a la durabilidad del producto.



- Muchos de sus diseños están patentados.
- Esta opción de producción es utilizada por grandes fabricantes chinos que ya tienen un posicionamiento internacional, una marca registrada y determinados volúmenes de exportación. (Marcas como LENOVO, HTC, etc.).
- **OEM (Original Equipment Manufacturer).**

Fabricante de equipos originales (marcas blancas).

Son aquellos fabricantes que dan la opción de producir sus diseños en blanco (sin marca) para que puedan ser usados por ti y personalizarlos con tu marca.

Características:

- Los diseños son usados por cualquier marca que quiera contratarlos.

Por ello puede haber en el mercado el mismo producto con diferentes marcas, sobre todo en líneas económicas.

- Los diseños perduran en el tiempo.

Se puede realizar una planificación, un esquema de compra, distribución y asistencia técnica a largo plazo.

- Tienes la opción de personalizar todo el producto: Colores, empaques, tipos de partes, accesorios, funcionalidades, etc.
- La responsabilidad del control de la calidad es tuya. Algo muy importante.
- Es posible que adecues los costos a tus intereses.
- Esta es la variante más extendida de producción en China en fábricas de cualquier categoría.



+ Info

Existe una tercera opción de tipos de marcas a producir que son las llamadas CM, (contract manufacturer, en español, fabricante por contrato), que, aunque está presente en todo el mundo, es muy poco comentada.



Son aquellas compañías que diseñan un producto propio y encargan la producción a un fabricante con sus requisitos específicos. Ni estos productos ni su marca pueden ser comercializados a no ser que tengas los permisos de distribución y venta del propietario.

Estas son las marcas reconocidas internacionalmente que están presentes en todos los mercados.

Supongamos que ha surgido una idea genial en tu cerebro y decides llevarla a la práctica, deberás elegir entre OEM y ODM, en función de tu idea y conocimientos:

- Si eres un profesional y tienes todo el desarrollo de tu "idea", elegirás OEM (Original Equipment Manufacturer):

En este tipo de fábricas entregas tus especificaciones, requisitos, detalles y vistas particulares y ellos empiezan a fabricar tu producto partiendo de cero con tus ideas.

Te permitirán (y aconsejan) modificaciones y actualizaciones en tu diseño hasta conseguir y producir tu modelo final.

Luego entregaran la mercancía en donde se haya acordado y a partir de ese punto ellos han terminado. La distribución, venta, máquetin, etc... es cosa tuya.

- Si eres un "genio", pero la parte técnica te aburre, elegirás **ODM** (Fabricante de diseño original):

Aquí te ofrecerán dos opciones:

- Ellos te muestran ideas de productos, tú proporcionas modificaciones, mejoras y nuevas funcionalidades y ellos adaptan sus productos para sugerirte un producto final.
- Tienes la idea muy clara, aunque no sabes cómo producirla. La fábrica te proporciona lo necesario para llevar a la práctica tu idea.

Hay que tener en cuenta que una fábrica ODM se atribuirá parte del crédito por el diseño de tu producto (lo que además es cierto), y puesto que en parte es propietaria del diseño final, puede llegar a tener derechos de venta a otros compradores. Además, si es un diseño de nuevo cuño, pueden existir problemas de durabilidad, calidad, etc...



8.1.2. Administración fuera de banda o en banda

En la administración de sistemas, la administración puede realizarse de dos formas:

- **En banda.**

Es el envío de información de control dentro de la misma banda o canal utilizado para datos como voz o video.

Las señales dentro de banda a menudo pueden ser escuchadas.

Al contrario que en fuera de banda, la administración en banda a través de VNC, SSH o incluso puertos serie se basa en la conectividad y el software en banda que debe instalarse en el sistema remoto que se está administrando y solo funciona después de que se haya iniciado el sistema operativo.

Esta solución puede ser más económica, pero no permite el acceso a la configuración del firmware (BIOS o UEFI), no permite reinstalar el sistema operativo de forma remota y no se puede utilizar para solucionar problemas que impiden que el sistema se inicie.

En redes, no permite la gestión de componentes de red remotos independientemente del estado actual de otros componentes de red.

- **Fuera de banda (Smart Out-of-Band, OOB).**

Se envía a través de un canal diferente, o incluso a través de una red separada.

Implica el uso de interfaces de administración, (o puertos seriales), para administrar y conectar equipos en red.

Las señales fuera de banda son inaccesibles para el usuario.

La gestión fuera de banda permite que un administrador del sistema supervise y gestione servidores y otros equipos conectados a la red mediante control remoto, independientemente de si la máquina está encendida, instalada o funcional.

La administración tanto dentro como fuera de banda (OOB) se realiza generalmente a través de una conexión de red, pero una tarjeta de administración fuera de banda puede usar un conector de red físicamente separado si se prefiere. Una tarjeta de administración remota generalmente tiene al menos una fuente de alimentación parcialmente independiente y puede encender y apagar la máquina principal a través de la red.

Los sistemas modulares / blade con módulos de administración dedicados a menudo ofrecen un puerto Ethernet OOB dedicado o un puerto de administración Lights out.



La gestión fuera de banda

Permite al operador de red establecer límites de confianza al acceder a la función de gestión para aplicarla a los recursos de la red y también se puede utilizar para garantizar la conectividad de gestión (incluida la capacidad de determinar el estado de cualquier componente de la red) independientemente del estado de otros componentes de la red en banda.

Una forma de administración fuera de banda a veces se denomina administración **de luces apagadas (LOM)** e implica el uso de un canal de administración dedicado para el mantenimiento del dispositivo.

La gestión fuera de banda permite un completo sistema de administración remota:

- Permite el reinicio, apagado y encendido remotos.
- Monitoreo de sensores de hardware (velocidad del ventilador, voltajes de potencia, intrusión en el chasis, etc.)
- Transmisión de salida de video a terminales remotos.
- Recepción de entrada desde teclado y mouse remotos (kvm sobre ip).
- También puede acceder a medios locales como una unidad de dvd o imágenes de disco desde la máquina remota.



+ Info

La administración remota se puede utilizar para ajustar la configuración del BIOS que puede no ser accesible después de que el sistema operativo ya se haya iniciado.

La configuración de los tiempos de RAM o RAID de hardware también se puede ajustar ya que la tarjeta de administración no necesita discos duros ni memoria principal para funcionar.

Como la gestión a través de un puerto serie ha sido tradicionalmente importante en los servidores, un sistema de gestión remota completo también permite interactuar con el servidor a través de un cable serie sobre LAN.

Se puede acceder al sistema remoto a través de una interfaz de línea de comandos SSH, software de cliente especializado o mediante varias soluciones basadas en navegador web. El software del cliente generalmente está optimizado para administrar múltiples sistemas fácilmente.



También hay varias versiones reducidas, hasta dispositivos que solo permiten el reinicio remoto al apagar y encender el servidor. Esto ayuda si el sistema operativo "se cuelga" pero solo necesita reiniciar para recuperarse.

Señalización en banda

Tiene diversas aplicaciones:

- **Telefonía:**

Al marcar desde un teléfono fijo, el número de teléfono se codifica y se transmite a través de la línea telefónica en forma de señalización multifrecuencia de doble tono (DTMF).

- **Voz sobre IP:**

Las señales DTMF se transmiten dentro de banda mediante dos métodos. Cuando se transmite como tonos de audio en el flujo de voz, la codificación de voz debe utilizar un codificador sin pérdidas.

La señalización en banda es insegura porque expone señales de control, protocolos y sistemas de gestión a los usuarios finales, lo que puede resultar en falsificaciones.



+ Info

En las décadas de 1960 y 1970, los llamados phreaks telefónicos usaban cajas azules para falsificaciones deliberadas, en las que los tonos apropiados para el enrutamiento se generaban intencionalmente, lo que permitía a la persona que llamaba abusar de funciones destinadas a pruebas y uso administrativo y realizar llamadas gratuitas de larga distancia.

En programación informática, un ejemplo de señalización en banda son los números mágicos, que se utilizan para señalar formatos de archivo.

El término número mágico tiene múltiples significados en programación, por ejemplo:

- Valores únicos con significado inexplicable u ocurrencias múltiples que podrían (preferiblemente) reemplazarse con constantes nombradas.



- Un valor numérico o de texto constante que se utiliza para identificar un formato de archivo o protocolo; para archivos, consulte Lista de firmas de archivos.
- Valores únicos distintivos que es poco probable que se confundan con otros significados (ejemplo: Identificadores únicos globales).

Cuando la comunicación fuera de banda no está disponible, se puede utilizar una de dos técnicas para preservar la transparencia de la red: encapsulación o relleno de bits.

Intel Management Engine

Intel Management Engine, es la gestión del motor Intel (ME), también conocido como el Motor de manejabilidad Intel.

Es un subsistema autónomo que ha sido incorporado en prácticamente la totalidad de Intel's procesador conjuntos de chips desde 2008. Está ubicado en el Platform Controller Hub de las placas base Intel modernas.

El subsistema consiste principalmente en firmware propietario que se ejecuta en un microprocesador separado que realiza tareas durante el arranque, mientras la computadora está funcionando y mientras está inactiva. Siempre que el chipset o SoC (chip, o circuito integrado) esté conectado a la corriente (a través de la batería o fuente de alimentación), continúa funcionando incluso cuando el sistema está apagado, es decir, Intel Management Engine siempre se ejecuta mientras la placa base esté recibiendo energía, incluso cuando la computadora está apagada.

Esto se puede evitar con la implementación de un dispositivo de hardware, que puede desconectar la alimentación de red, evitando así que la placa reciba corriente eléctrica.



Atención

Intel ME es un objetivo atractivo para los piratas informáticos, ya que tiene acceso de nivel superior a todos los dispositivos y evita por completo el sistema operativo.

La Electronic Frontier Foundation ha expresado su preocupación por Intel ME y algunos investigadores de seguridad han expresado su preocupación de que sea una puerta trasera.



Diferencia de Intel AMT y Intel Management Engine (ME)

El motor de administración Intel Management Engine (ME) se confunde a menudo con Intel AMT (tecnología de administración activa de Intel), hay que saber diferenciarlo:

- **AMT:**
 - Se ejecuta en ME.
 - Solo está disponible en procesadores con vPro.

(La tecnología Intel vPro es un término de marketing general utilizado por Intel para una gran colección de tecnologías de hardware informático.)
 - Ofrece a los propietarios de dispositivos la administración remota de su computadora, como encenderla o apagarla y reinstalar el sistema operativo.
 - El propietario puede desaprovechar AMT.
- **ME:**
 - El ME en sí está integrado en todos los conjuntos de chips de Intel desde 2008, (no solo en aquellos con AMT).
 - No existe una forma oficial y documentada de desactivar el ME.

8.1.3. Interfaz de gestión de plataforma inteligente (IPMI)

La Interfaz de administración de plataforma inteligente (IPMI) es un conjunto de especificaciones de interfaz de computadora para un subsistema de computadora autónomo que proporciona capacidades de administración y monitoreo independientemente de la CPU, el firmware (BIOS o UEFI) y el sistema operativo del sistema host.

Algunos usos de IPMI:

- Define un conjunto de interfaces que utilizan los administradores de sistemas para la gestión fuera de banda de los sistemas informáticos, y seguimiento de su funcionamiento.
- Proporciona una forma de administrar una computadora que puede estar apagada o que no responde mediante el uso de una conexión de red al hardware en lugar de a un sistema operativo o shell de inicio de sesión.
- Instalación remota de un sistema operativo personalizado.

Sin IPMI, la instalación de un sistema operativo personalizado puede requerir que un administrador esté físicamente presente cerca de la computadora, inserte un DVD o una unidad flash USB que contenga el instalador del sistema operativo y complete el proceso de instalación usando un monitor y un teclado.

Con IPMI, un administrador puede montar una imagen ISO, simular un DVD de instalación y realizar la instalación de forma remota.



+ Info

La especificación está dirigida por Intel y se publicó por primera vez el 16 de septiembre de 1998.

Cuenta con el respaldo de más de 200 proveedores de sistemas informáticos, como Cisco, Dell, Hewlett Packard Enterprise, Intel, OnLogic, Marvell Semiconductor, NEC Corporation, SuperMicro y Tyan.

El sucesor de IPMI es Redfish, es un estándar diseñado para brindar una administración simple y segura de DMTF.

Funcionalidad

El uso de una interfaz y un protocolo estandarizados permite que el software de administración de sistemas basado en IPMI administre múltiples servidores dispares.

Como especificación de interfaz a nivel de hardware basada en mensajes, IPMI funciona independientemente del sistema operativo para permitir a los administradores gestionar un sistema de forma remota en ausencia de un sistema operativo o del software de gestión del sistema. Por tanto, las funciones de IPMI pueden funcionar en cualquiera de estos tres escenarios:

- Antes de que se inicie un sistema operativo (lo que permite, por ejemplo, la supervisión remota o el cambio de la configuración del BIOS).
- Cuando el sistema está apagado.
- Después de una falla del sistema operativo o del sistema: la característica clave de IPMI en comparación con la administración del sistema en banda es que permite el inicio de sesión remoto en el sistema operativo mediante SSH.

SSH o Secure Shell es un protocolo de red criptográfico para operar servicios de red de forma segura en una red no segura.

Los administradores del sistema pueden usar la mensajería IPMI para:

- Monitorear el estado de la plataforma (como temperaturas del sistema, voltajes, ventiladores, fuentes de alimentación e intrusión en el chasis).
- Para consultar información de inventario.



- Para revisar los registros de hardware de las condiciones fuera de rango.
- Para realizar procedimientos de recuperación.

Como, por ejemplo, emitir solicitudes desde una consola remota a través de las mismas conexiones, por ejemplo, apagar y reiniciar el sistema, o configurar temporizadores de vigilancia.

Un temporizador de vigilancia (a veces llamado computadora que funciona correctamente o temporizador de COP, o simplemente vigilancia) es un temporizador electrónico o de software que se utiliza para detectar y recuperarse de fallas de funcionamiento de la computadora, son utilizados ampliamente en los ordenadores para facilitar la corrección automática de fallas temporales de hardware y para evitar que el software errante o malévolo interrumpa el funcionamiento del sistema.

Durante el funcionamiento normal, la computadora reinicia regularmente el temporizador de vigilancia para evitar que se agote o "se agote el tiempo". Si, debido a una falla de hardware o un error del programa, la computadora no reinicia, el temporizador pasará y generará una señal de tiempo de espera, que se utiliza para iniciar acciones correctivas, las cuales generalmente incluyen colocar el ordenador y el hardware asociado en un estado seguro e invocar un reinicio del ordenador.

El estándar también define un mecanismo de alerta para que el sistema envíe una trampa de eventos de plataforma (PET) de protocolo de administración de red simple (SNMP).

El sistema monitoreado puede estar apagado, pero debe estar conectado a una fuente de energía y al medio de monitoreo, generalmente una conexión de red de área local (LAN).

IPMI también puede funcionar después de que se haya iniciado el sistema operativo y expone las estructuras y los datos de gestión al software de gestión del sistema.

IPMI prescribe solo la estructura y el formato de las interfaces como estándar, mientras que las implementaciones detalladas pueden variar.

Una implementación de IPMI versión 1.5 puede comunicarse a través de una red de área local (LAN) directa fuera de banda o una conexión en serie o mediante una conexión de red de área local (LAN) de banda lateral a un cliente remoto. La conexión LAN de banda lateral utiliza el controlador de interfaz de red de la placa (NIC), siendo esta solución, menos costosa que una conexión LAN dedicada, pero también tiene un ancho de banda limitado.

Los sistemas que cumplen con la versión 2.0 de IPMI también pueden comunicarse vía serie a través de LAN, por lo que la salida de la consola serie se puede ver de forma remota a través de la LAN. Los sistemas que implementan IPMI 2.0 generalmente también incluyen KVM sobre IP, medios virtuales remotos y funcionalidad de interfaz de servidor web integrada fuera de banda, aunque estrictamente hablando, estos se encuentran fuera del alcance del estándar de interfaz IPMI.



+ Info

DCMI (Data Center Manageability Interface) es un estándar similar basado en IPMI, pero diseñado para ser más adecuado en la gestión de Data Center.

Utiliza las interfaces definidas en IPMI, pero minimiza el número de interfaces opcionales e incluye control de limitación de energía, entre otras diferencias.

Además de utilizar una conexión LAN de administración dedicada separada, IPMI también permite la implementación de una conexión LAN de administración de "banda lateral", que utiliza una interfaz de bus de administración del sistema (SMBUS) entre el BMC (controlador de administración de placa base) y el controlador de interfaz de red (NIC) de la placa, que tiene la ventaja de reducir los costos, pero también proporciona un ancho de banda limitado, suficiente para la redirección de la consola de texto, pero no para la redirección de video. (Por ejemplo, cuando una computadora remota está inactiva, el administrador del sistema puede acceder a ella a través de IPMI y utilizar una consola de texto).

Esto es suficiente para algunas funciones vitales, como verificar el registro de eventos, acceder a la configuración del BIOS y encender, apagar o apagar y encender, pero las funciones más avanzadas, como la reinstalación remota de un sistema operativo, pueden requerir un enfoque de administración fuera de banda completo utilizando una conexión LAN dedicada.

El sistema IPMI consta de un controlador principal, denominado controlador de gestión de placa base (BMC) y otros controladores de gestión distribuidos entre diferentes módulos del sistema que se denominan controladores satélite.

Una conexión en serie directa al BMC no está cifrada, ya que la conexión en sí es segura. La conexión al BMC a través de LAN puede utilizar o no cifrado según las preocupaciones de seguridad del usuario.

Existe una creciente preocupación sobre la seguridad general con respecto a las BMC como una infraestructura cerrada.



+ Info

OpenBMC es un proyecto BMC de código abierto colaborativo de Linux Foundation.



Seguridad

Datos Históricos:

- El 2 de julio de 2013, Rapid7, empresa de seguridad, publicó una guía para las pruebas de penetración de seguridad del último protocolo IPMI 2.0 y las implementaciones de varios proveedores.

Es propiedad de Rapid7, el Proyecto Metasploit de seguridad informática que proporciona información sobre vulnerabilidades de seguridad y ayuda en las pruebas de penetración y el desarrollo de firmas IDS.

Metasploit Framework de código abierto, es una herramienta para desarrollar y ejecutar código de explotación contra una máquina de destino remota.

El Proyecto Metasploit incluye herramientas anti-forenses y de evasión, algunas de las cuales están integradas en Metasploit Framework. Metasploit está preinstalado en el sistema operativo Kali Linux.

(Otros subproyectos importantes de Rapid7 incluyen la base de datos Opcode, el archivo shellcode y la investigación relacionada).

- Algunas fuentes en 2013 desaconsejaban el uso de la versión anterior de IPMI, debido a problemas de seguridad relacionados con el diseño y las vulnerabilidades de los controladores de gestión de la placa base (BMC).

Sin embargo, como para cualquier otra interfaz de administración, las mejores prácticas de seguridad dictan la ubicación del puerto de administración IPMI en una LAN o VLAN de administración dedicada restringida a administradores confiables.

Pero esto es solo valor histórico, la especificación de IPMI se ha actualizado con RAKP + y un cifrado más fuerte que es imposible de descifrar desde el punto de vista computacional. Los proveedores han proporcionado parches que corrigen las vulnerabilidades.

La organización DMTF ha desarrollado una especificación de interfaz segura y escalable llamada Redfish para trabajar en entornos de centros de datos modernos.

DMTF es una organización de estándares de la industria sin fines de lucro que crea estándares abiertos de capacidad de administración que abarcan diversas infraestructuras de TI tradicionales y emergentes, incluida la nube, la virtualización, la red, los servidores y el almacenamiento.

Las empresas miembros y los socios de la alianza DMTF colaboran en estándares para mejorar la gestión interoperable de las tecnologías de la información. Dispone de una web oficial: <https://www.dmtf.org/>

Redfish de DMTF es un estándar diseñado para brindar una administración simple y segura para TI híbrida y convergente y el Centro de datos definido por software (SDDC).

El trabajo técnico sobre el estándar Redfish se lleva a cabo en el Redfish Forum de DMTF (anteriormente conocido como Scalable Platforms Management Forum, o SPMF).



Soluciones potenciales fuera del estándar IPMI

Existen algunas soluciones potenciales fuera del estándar IPMI, dependiendo de las implementaciones propietarias.

El uso de contraseñas cortas predeterminadas o hackeos de "cifrado 0" se puede superar fácilmente con el uso de un servidor RADIUS para autenticación, autorización y contabilidad sobre SSL, como es típico en un centro de datos o en cualquier implementación de tamaño mediano a grande.

El servidor RADIUS del usuario se puede configurar para almacenar AAA de forma segura en una base de datos LDAP utilizando FreeRADIUS / OpenLDAP o Microsoft Active Directory y servicios relacionados.

El acceso basado en roles proporciona una forma de responder a problemas de seguridad actuales y futuros al aumentar las restricciones para roles superiores.

El acceso basado en roles es compatible con tres roles disponibles:

- **Administrador.**

La función de administrador se utiliza para configurar el BMC en el primer arranque durante la puesta en servicio del sistema cuando se instala por primera vez.

- **Operador.**

El rol de Operador se usa en el caso poco común de que un sistema se cuelgue, para generar un archivo de volcado de núcleo / bloqueo de NMI y reiniciar o apagar y encender el sistema. En tal caso, el operador también tendrá acceso al software del sistema para recopilar el archivo de volcado de memoria / caída.

- **Usuario.**

En general, la función de usuario tiene acceso de solo lectura al BMC y no tiene capacidad de control remoto, como el ciclo de energía o la capacidad de ver o iniciar sesión en la CPU principal en la placa base. Por lo tanto, cualquier pirata informático con el rol de Usuario no tiene acceso a información confidencial ni control sobre el sistema.

El rol de Usuario se usa generalmente para monitorear las lecturas del sensor, después de que el software de monitoreo de red SNMP haya recibido una alerta SNMP.

La mejor práctica prudente es deshabilitar el uso de los roles de operador y administrador en LDAP / RADIUS, y habilitarlos solo cuando los necesite el administrador de LDAP / RADIUS.



Ejemplo

En RADIUS un rol puede tener su configuración Auth-Type cambiada a:

Auth-Type: = Rechazar

Si lo hace, evitará que los ataques hash RAKP tengan éxito ya que el servidor RA-DIUS rechazará el nombre de usuario.

8.2. Servicio de acceso remoto

Existen servicios que nos permiten conectarnos de forma remota a otros equipos de dos formas:

- **En modo terminal.**

Podemos abrir una terminal en un equipo remoto a través de servicios como Telnet (Telecommunication Network) o SSH (Secure Shell).

- **En modo gráfico.**

Permite conectarnos a otro equipo de la red de forma que podemos ver su pantalla e interactuar con ella como si fuera nuestro propio ordenador, y también ver las acciones que realiza el usuario de dicho equipo.

8.2.1. Modo terminal

Son protocolos de administración remota que le permite a los usuarios controlar y modificar sus servidores remotos a través de Internet.

Son protocolos cliente-servidor basado en el intercambio de datos orientados a caracteres a través de conexiones TCP.

Permite el control remoto de los ordenadores por medio de entradas y salidas basadas en texto. Con este objetivo, se crea una conexión cliente-servidor a través del protocolo TCP, donde el dispositivo controlado ejerce de servidor y espera a los comandos pertinentes.

Podemos abrir una terminal en un equipo remoto a través de servicios como Telnet (Telecommunication Network) o SSH (Secure Shell).

Los protocolos más utilizados son TELNET y SSH.



8.2.1.1. Telnet

Telnet	
Familia	Familia de protocolos de Internet
Función	Protocolo cliente/servidor
Puertos	23/TCP
Ubicación en la pila de protocolos	
Aplicación	Telnet
Transporte	TCP
Red	IP
Estándares	
RFC 854 (esp. 1983)	
RFC 855 (opción 1983)	

Fuente: wikipedia

Telnet (Teletype Network) es el nombre de un protocolo de red que nos permite acceder a otra máquina para manejarla remotamente como si estuviéramos sentados delante de ella.

También es el nombre del programa informático que implementa el cliente. Para que la conexión funcione, como en todos los servicios de Internet, la máquina a la que se acceda debe tener un programa especial que reciba y gestione las conexiones. El puerto que se utiliza generalmente es el 23.

Funcionamiento de Telnet

Telnet sólo sirve para acceder en modo terminal, es decir, sin gráficos, pero es una herramienta muy útil para arreglar fallos a distancia, sin necesidad de estar físicamente en el mismo sitio que la máquina que los tenga.

También se usaba para consultar datos a distancia, como datos personales en máquinas accesibles por red, información bibliográfica, etc.

Aparte de estos usos, en general telnet se ha utilizado (y aún hoy se puede utilizar en su variante SSH) para abrir una sesión con una máquina UNIX, de modo que múltiples usuarios con cuenta en la máquina, se conectan, abren sesión y pueden trabajar utilizando esa máquina.

Es una forma muy usual de trabajar con sistemas UNIX.



Problemas de seguridad y SSH de Telnet

Su mayor problema es de seguridad, ya que todos los nombres de usuario y contraseñas necesarias para entrar en las máquinas viajan por la red como texto plano (cadenas de texto sin cifrar).

Esto facilita que cualquiera que espíe el tráfico de la red pueda obtener los nombres de usuario y contraseñas, y así acceder él también a todas esas máquinas.

Por esta razón dejó de usarse, casi totalmente, hace unos años, cuando apareció y se popularizó el SSH, que puede describirse como una versión cifrada de telnet, actualmente se puede cifrar toda la comunicación del protocolo durante el establecimiento de sesión si cliente y servidor lo permiten, aunque no se tienen ciertas funcionalidades extra disponibles en SSH.

Telnet en la actualidad

Hoy en día también se usa para acceder a los BBS, que inicialmente eran accesibles únicamente con un módem a través de la línea telefónica.

Para acceder a un BBS mediante telnet es necesario un cliente que dé soporte a gráficos ANSI y protocolos de transferencia de ficheros. Los gráficos ANSI son muy usados entre los BBS.

Con los protocolos de transferencia de ficheros (el más común y el que mejor funciona es el ZModem) se puede enviar y recibir ficheros del BBS, (programas o juegos) o el correo del BBS (correo local, de FidoNet u otras redes).



+ Info

Algunos clientes de telnet (que soportan gráficos ANSI y protocolos de transferencias de ficheros como Zmodem y otros) son:

mTelnet!, NetRunner, Putty, Zoc, etc.

Manejo básico de Telnet

Para iniciar una sesión con un intérprete de comandos de otro ordenador, puede emplear el comando telnet seguido del nombre o la dirección IP de la máquina en la que desea trabajar.

Por ejemplo:

- Para conectarse a la máquina docente.miestudio.masterd.com, deberá teclear telnet docente.miestudio.masterd.com y, para conectarse con la dirección IP 1.2.3.4, deberá utilizar telnet 1.2.3.4.
- Una vez conectado, se ingresará el nombre de usuario y contraseña remoto para iniciar una sesión en modo texto a modo de consola virtual.



La información que transmita (incluyendo la clave) no será protegida o cifrada y podría ser vista en otros computadores por los que transite la información (la captura de estos datos se realiza con un packet sniffer).

Una alternativa más segura que telnet, pero que requiere más recursos del computador, es SSH, que sí cifra la información antes de transmitirla, autentica la máquina a la cual se conecta y puede emplear mecanismos de autenticación de usuarios más seguros.

Actualmente hay sitios para hackers en los que se entra por telnet y se van sacando las password para ir pasando de nivel, ese uso de telnet aún es vigente.

Seguridad en Telnet

Hay 3 razones principales por las que el telnet no se recomienda para los sistemas modernos desde el punto de vista de la seguridad:

- Los dominios de uso general del telnet tienen varias vulnerabilidades descubiertas a lo largo de los años, y varias más que podrían aún existir.
- Telnet, por defecto, no cifra ninguno de los datos enviados sobre la conexión (contraseñas inclusive), así que es fácil interferir y grabar las comunicaciones, y utilizar la contraseña más adelante para propósitos maliciosos.
- Telnet carece de un esquema de autenticación que permita asegurar que la comunicación esté siendo realizada entre los dos anfitriones deseados, y no interceptada entre ellos.

En ambientes donde es importante la seguridad, por ejemplo, en el Internet público, telnet no debe ser utilizado.

Las sesiones de telnet no son cifradas. Esto significa que cualquiera que tiene acceso a cualquier router, switch, o gateway localizado en la red entre los dos anfitriones donde se está utilizando telnet puede interceptar los paquetes de telnet que pasan cerca y obtener fácilmente la información de la conexión y de la contraseña (y cualquier otra cosa que se mecanografía) con cualesquiera de varias utilidades comunes como tcpdump (que vemos un poco más abajo) y Wireshark.

Estos defectos han causado las críticas y el abandono del protocolo telnet, a favor de un protocolo más seguro y funcional llamado SSH, lanzado en 1995.

SSH provee de toda la funcionalidad presente en telnet, la adición del cifrado fuerte para evitar que los datos sensibles tales como contraseñas sean interceptados, y de la autenticación mediante llave pública, para asegurarse de que el computador remoto es realmente quién dice ser.

Los expertos en seguridad computacional, tal como el instituto de SANS, y los miembros del newsgroup de comp.os.linux.security recomiendan que el uso del telnet para las conexiones remotas debería ser descontinuado bajo cualquier circunstancia normal.



+ Info

Cuando el Telnet fue desarrollado inicialmente en 1969, la mayoría de los usuarios de computadoras en red estaban en los servicios informáticos de instituciones académicas, o en grandes instalaciones de investigación privadas y del gobierno.

En este ambiente, la seguridad no era una preocupación y solo se convirtió en una preocupación después de la explosión del ancho de banda de los años 90.

Con la subida exponencial del número de gente con el acceso al Internet, y por la extensión, el número de gente que procura crackear los servidores de otra gente, Telnet podría no ser recomendado para ser utilizado en redes con conectividad a Internet.

Tcpdump

Tcpdump es una utilidad gratuita y de código abierto usada por ingenieros de redes, administradores de sistemas, profesionales de la seguridad y hackers. Opera desde la línea de comandos y su función es la de analizar y capturar el tráfico de red. Tiene distintas versiones para los sistemas operativos más comunes, Linux, Windows y macOS.

Trabaja leyendo los datos de la capa de enlace de datos de la red. Los datos contienen las cabeceras de los paquetes de red, e incluyen información sobre origen, destino y contenido de los paquetes. Tcpdump tiene la capacidad de capturar datos de cualquier protocolo de red, como TCP, UDP, ICMP, etc.

Su función comprende la resolución de problemas de red (pérdidas de paquetes o congestión) y la ejecución de auditorías de seguridad (identificación de amenazas: malware, o tráfico malicioso).

Tcpdump es una herramienta poderosa que puede ser utilizada por administradores de sistemas, ingenieros de redes y profesionales de la seguridad.

Para usar el comando se pueden emplear distintas opciones o argumentos:

- -c especifica el número máximo de paquetes que se capturarán.
- -i especifica la interfaz de red en la que se realizará la captura.
- -s especifica el tamaño del búfer de captura.



- -t especifica el formato de la hora en los registros de captura.
- -v proporciona información adicional en los registros de captura.
- -w especifica el archivo en el que se guardará la captura.

En estos ejemplos capturaríamos el tráfico que pasa por interfaz de red eth9 y la guardaríamos en un archivo captura.out, pongo distintos ejemplos:

- .tcpdump -i eth9 -w captura.out (captura de cabeceras de los paquetes).
- .tcpdump -i eth9 -w captura.out -A (el -A significa All y capturaría de las cabeceras y cuerpos de los paquetes de datos).
- .tcpdump -i eth9 -c 10 -w captura.out (se capturará el tráfico que pasa por la interfaz eth9 durante 10 segundos).

Snoop sería el comando nativo equivalente en el sistema operativo Solaris.

Acceso remoto con Telnet

Dentro de las labores de un administrador de sistemas está el acceso remoto a los mismos, ya sea para buscar información en algún fichero del sistema, para copiar información o ejecutando en remoto algún comando.

Usando telnet podemos acceder a una máquina remota de la misma forma que lo haríamos si estuviéramos sentados delante de la consola y utilizásemos su teclado para introducir los comandos.

Los comandos que se teclean por parte del usuario son transmitidos directamente a la máquina remota y la respuesta de ésta es mostrada en la pantalla del usuario. De esta forma el sistema local es transparente al usuario, el cual tiene la sensación de estar conectado directamente a la máquina remota.

Para que podamos iniciar una sesión telnet se tienen que dar un par de condiciones:

- Que tengamos una cuenta de usuario en la máquina con la que queremos conectar.
- Que el servidor tenga un servicio de telnet activo.

Para acceder al sistema remoto se nos solicitará la identificación para poder entrar al sistema.

Por ejemplo:

- Para acceder a la máquina (inexistente) tux.mimasterd.org escribiremos:

```
$telnet tux.mimasterd.org
```

A continuación, se nos pedirá el nombre de usuario y la contraseña.



Si podemos acceder a algún servidor vía telnet, es interesante probar la posibilidad que nos ofrece Linux de trabajar en modo gráfico con programas situados en otro equipo, para esto tendremos que:

- Desde un Xterm de la máquina local ejecutar:

```
$ xhost +máquina_remota
```

- Después haremos un telnet a la máquina remota y una vez conectados escribiremos:

```
$ export DISPLAY=máquina_local:0
```

- Por último, ya sólo tenemos que ejecutar el comando que deseemos, por ejemplo, puedes probar con:

```
$ mozilla &
```

8.2.1.2. SSH



Fuente:

https://ca.wikipedia.org/wiki/Fitxer:SSH_Communications_Security_logo.svg

SSH permite ejecutar comandos en nuestra consola de comandos que, por ejemplo, copien ficheros a otro equipo de la red. Es el más utilizado actualmente, ya que garantiza la seguridad de las comunicaciones (lo que no ocurre con Telnet).

SSH permite ejecutar comandos en nuestra consola de comandos que, por ejemplo, copien ficheros a otro equipo de la red. Es el más utilizado actualmente, ya que garantiza la seguridad de las comunicaciones (lo que no ocurre con Telnet).



SSH (o Secure SHell) es el nombre de un protocolo y del programa que lo implementa cuya principal función es el acceso remoto a un servidor por medio de un canal seguro en el que toda la información está cifrada.

Además de la conexión a otros dispositivos, SSH permite copiar datos de forma segura (tanto archivos sueltos como simular sesiones FTP cifradas), gestionar claves RSA para no escribir contraseñas al conectar a los dispositivos y pasar los datos de cualquier otra aplicación por un canal seguro tunelizado mediante SSH y también puede redirigir el tráfico del (Sistema de Ventanas X) para poder ejecutar programas gráficos remotamente.

El puerto TCP asignado es el 22.

Al principio solo existían los r-commands, que eran los basados en el programa rlogin, el cual funciona de una forma similar a telnet.

La primera versión del protocolo y el programa eran libres y los creó un finlandés llamado Tatu Ylönen, pero su licencia fue cambiando y terminó apareciendo la compañía SSH Communications Security, que lo ofrecía gratuitamente para uso doméstico y académico, pero exigía el pago a otras empresas. En el año 1997 (dos años después de que se creara la primera versión) se propuso como borrador en la IETF.

A principios de 1999 se empezó a escribir una versión que se convertiría en la implementación libre por excelencia, la de OpenBSD, llamada OpenSSH.

SCP

SCP (Secure Copy Protocol o Protocolo de copia seguro) es un protocolo basado en SSH, como acabamos de ver un protocolo de conexión remota segura. La autenticación y cifrado de datos que ofrece SSH es aprovechada por SCP para realizar transferencias de ficheros de manera confiable y confidencial. Se emplea cuando la seguridad en entornos de red sea importante. Se puede emplear para enviar ficheros como datos financieros o información médica, personal.

El protocolo SSH está configurado para escuchar en el puerto 22, SCP se servirá de esto para realizar su tarea.

8.2.2. Modo gráfico

Permite conectarnos a otro equipo de la red, de forma que podemos ver su pantalla e interactuar con ella como si fuera nuestro propio ordenador. Por otra parte, también podemos ver las acciones que realiza el usuario de dicho equipo.

Los programas de acceso en modo gráfico nos permiten controlar el ordenador remoto como si estuviésemos sentados enfrente de su consola.

Para ello se utilizan determinados servicios o aplicaciones, que en algunos casos tienen versiones gratuitas que permiten probarlos con ciertas limitaciones.



8.2.2.1. Escritorio remoto de Google Chrome

Lo que ofrece Chrome es facilidad de uso mediante **su herramienta de escritorio remoto**, y que Google Chrome, está instalado en prácticamente todos los ordenadores y eso permite poder acceder a cualquier ordenador sólo con instalar una extensión en el navegador.

El Escritorio remoto de Chrome está disponible en la Web para el ordenador. Un usuario puede descargarse la app del Escritorio remoto de Chrome para dispositivos móviles y poder realizar el acceso de forma remota.

El escritorio remoto de Chrome:

- Es una herramienta totalmente gratuita.
- Permite el acceso no sólo a Chrome sino a todo el ordenador.
- Permite conectar a distancia desde el Chrome de tu ordenador, aunque **también tienes aplicaciones móviles** para conectarte y controlar tu PC desde Android o iOS.

Puedes usar una computadora o un dispositivo móvil para acceder a los archivos y las aplicaciones de otra computadora mediante Internet con el Escritorio remoto de Chrome.

8.2.2.1.1. Configuraciones

Vamos a ver a continuación formas de uso del escritorio remoto de Google Chrome.

Configuración del acceso remoto en el ordenador

Pasos para configurar el acceso remoto a tu computadora Mac, Windows o Linux:

- Abrir Chrome en el ordenador.
- En la barra de direcciones, hay que teclear:

remotedesktop.google.com/access.
- En "Configurar el acceso remoto", hacer clic en Descargar 
- Seguir las instrucciones en pantalla para descargar e instalar el Escritorio remoto de Chrome.

Es posible que sea necesario ingresar la contraseña del ordenador para darle acceso al Escritorio remoto de Chrome, y que se solicite realizar cambios de la configuración de seguridad en Preferencias.



Compartir el ordenador

Para permitir que otras personas accedan de forma remota a tu ordenador, y puedan acceder sin restricciones a tus apps, archivos, correos electrónicos, historial y documentos.

- Abrir Chrome en el ordenador.
- En la barra de direcciones de la parte superior, hay que teclear remotedesktop.google.com/support y, luego, presiona Intro.
- En "Obtener asistencia", hacer clic en Descargar 
- Seguir las instrucciones en pantalla para descargar e instalar el Escritorio remoto de Chrome.
- En "Obtener asistencia", hay que seleccionar Generar código.
- Es necesario enviar ese código que se ha generado a la persona que deseas que acceda a tu ordenador.
- Cuando la persona ingrese el código en el sitio, aparecerá un cuadro de diálogo con su dirección de correo electrónico, es necesario entonces seleccionar "Compartir" para darle acceso completo.
- Para finalizar la sesión de uso compartido, hay que hacer clic en Dejar de compartir.
- El código de acceso solo funcionará una vez, y se pedirá que se confirme cada 30 minutos mientras se esté compartiendo el ordenador.

Cómo acceder a una computadora de forma remota

- Abrir Chrome en el ordenador.
- En la barra de direcciones de la parte superior, hay que teclear remotedesktop.google.com/access y, luego, presiona Intro.
- Hay que hacer clic en Acceso para seleccionar la computadora que deseas.
- Hay que ingresar el PIN que se te solicita para acceder a otra computadora.
- Por último, hay que seleccionar la flecha para comenzar la conexión.

Todas las sesiones de escritorio remoto están encriptadas por completo. Para garantizar la seguridad.



Cómo detener una sesión remota

Para terminar la conexión, hay que cerrar la pestaña o bien seleccionar Opciones > Desconectar.

Cómo quitar una computadora de tu lista

- Abrir Chrome en el ordenador.
- En la barra de direcciones de la parte superior, hay que teclear `remotedesktop.google.com/access` y, luego, presiona Intro.
- Junto al ordenador que se desea eliminar hay que hacer clic en Inhabilitar conexiones remotas 

Cómo brindar asistencia remota

Si alguien compartió un código de acceso remoto contigo, puedes brindarle asistencia de forma remota:

- Abrir Chrome en el ordenador.
- En la barra de direcciones de la parte superior, hay que teclear `remotedesktop.google.com/support` y, luego, presiona Intro.
- Hay que ingresar el código debajo de "Brindar asistencia" y, luego, hacer clic en Conectar.



+ Info

Puedes obtener más información sobre el acceso remoto para Android, iPhone y iPad, etc. en la web oficial.

<https://support.google.com/chrome/answer/1649523?co%20%E2%80%A2=GENIE.Platform%3DDesktop&hl=es-419>

8.2.2.2. Escritorio remoto de Windows 10

Controlar un ordenador de forma remota puede ser muy útil en un montón de situaciones diferentes, como, por ejemplo, si se necesita conectar desde casa al ordenador del trabajo, si se desea ayudar a algún familiar, o amistad a arreglar problemas en su ordenador o si simplemente se tienen varios ordenadores en casa y no se quiere tener un teclado y ratón para cada uno.



Existen aplicaciones de terceros que permiten conectarse de forma remota a un ordenador, pero el propio Windows 10 integra un sistema de escritorio remoto.

Se necesita licencia de una versión superior para poder utilizarlo, como Windows 10 Pro.

Teniendo Windows Pro, la opción de escritorio remoto aparecerá en la configuración del sistema.

En el escritorio remoto se configurarán permisos a diferentes usuarios, o requerir que equipos usen autenticación a nivel de red.

Una vez activada, es necesario descargar la aplicación de cliente con la que se realizará la conexión a ese ordenador, y que está disponible para Windows, macOS, Android e iOS.

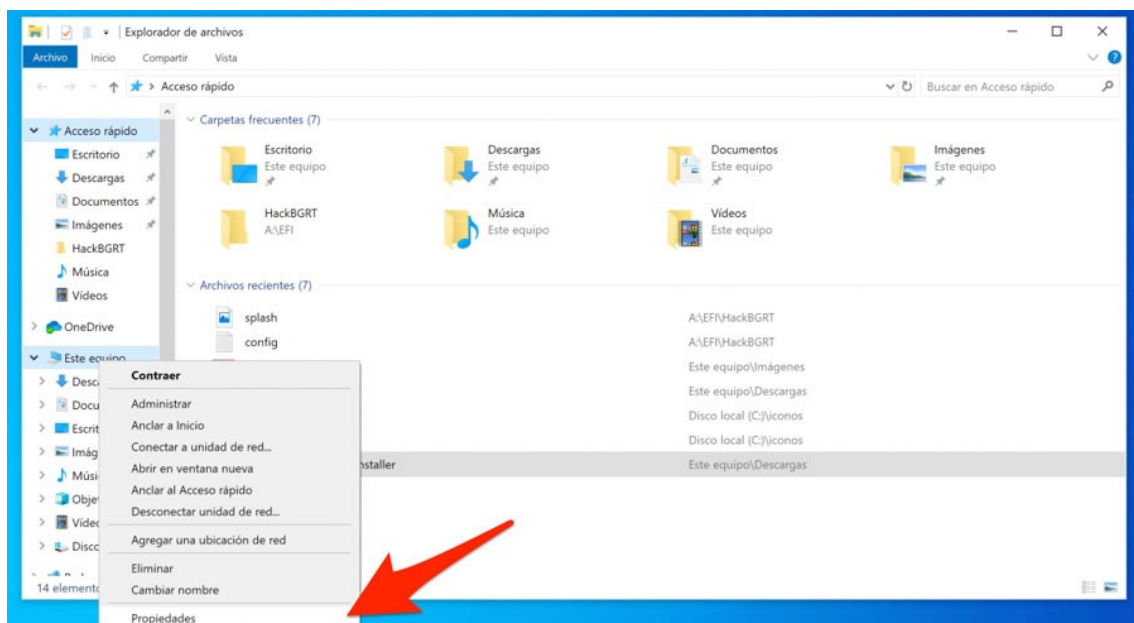
Para poder utilizar este método de conexión remota a otros PCs **no es necesario instalar ningún software** adicional. Todo lo necesario lo incluye Windows de serie.

Vamos a ver como configurarlo y utilizarlo.

8.2.2.2.1. Configurar el PC para que acepte conexiones remotas

Lo primero que hay que hacer para poder controlar otro ordenador desde el propio es configurarlo para que acepten conexiones remotas.

Para poder hacer esto es necesario tener acceso físico al PC o darle las indicaciones a una persona que lo tenga. Solo será necesario hacerlo en el primer uso y ya quedará listo para todas las futuras conexiones que se realicen.

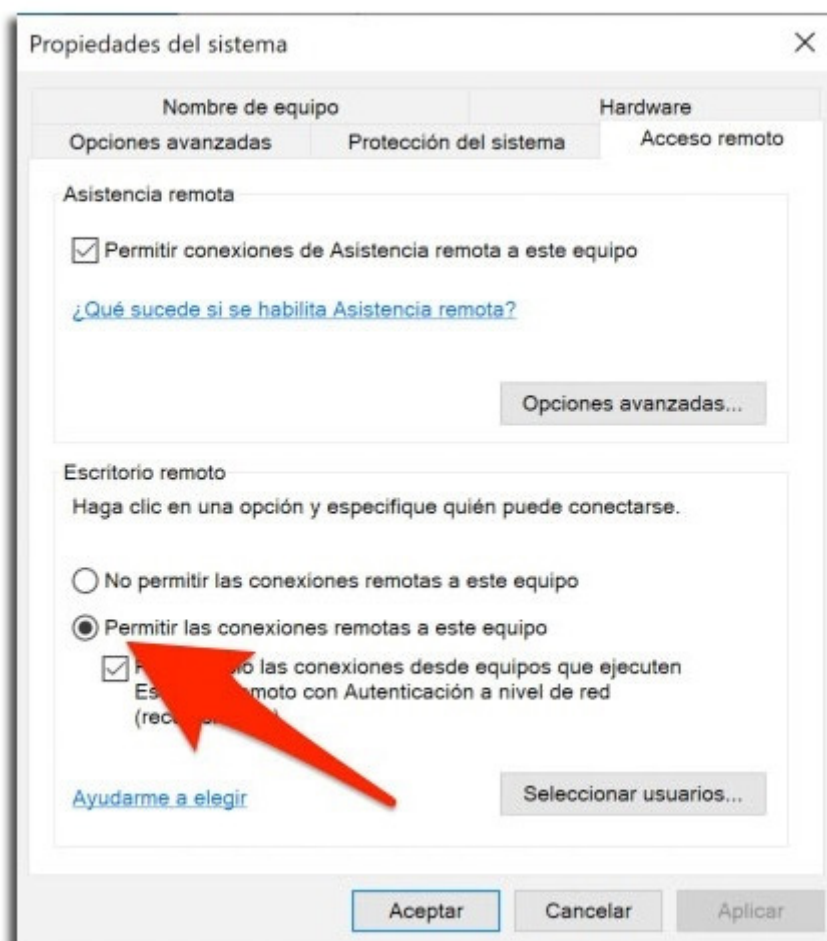




Para permitir las conexiones remotas lo primero es abrir una ventana del Explorador de Windows, pinchar con el botón derecho sobre Este Equipo, seleccionar la opción Propiedades y en la nueva ventana que se despliega pinchar sobre Configuración de acceso remoto.

A continuación, en la nueva ventana hay que marcar la casilla Permitir las conexiones remotas a este equipo y pincha aceptar, y ya el equipo aceptará conexiones remotas de cualquier usuario que tenga permisos de administrador en el equipo.

Si se necesita conectar con algún usuario que no sea administrador, hay que pinchar sobre el botón "Seleccionar usuarios" y después añadir a la lista los usuarios a los que se quiere conceder acceso remoto.



Si es necesario poder acceder al ordenador desde Internet, es decir, desde fuera de la red local, hay que **abrir el puerto** correspondiente, concretamente hay que acceder a los ajustes del router y abrir el puerto 3389 tanto en el protocolo TCP como UDP, que es el que necesita el servicio para funcionar.



8.2.2.2.2. Conectarte de forma remota al ordenador

Una vez realizados los ajustes necesarios, ya es posible conectar de forma remota al ordenador sin ningún problema haciendo lo siguiente:

- Ejecutar la aplicación Conexión a Escritorio remoto (puedes buscarla desde la barra de Cortana para acceder más rápido).
- En el campo Equipo teclear los datos de conexión del PC.



En caso de que el ordenador esté dentro de la misma red local que el PC desde el que se va a conectar remotamente, hay que escribir el nombre del equipo o la IP de la red local (que se puede saber ejecutando CMD y tecleando ipconfig en el ordenador remoto).

Si el PC no está dentro de la red local y se precisa conectarse a él a través de Internet hay que teclear la IP pública para acceder, para averiguarla se puede acceder a <https://www.cual-es-mi-ip.net/> desde el ordenador remoto.

Una vez introducidos los datos de conexión, es necesario pinchar sobre el botón Conectar y en pocos segundos aparecerá la pantalla de login del ordenador remoto, entonces hay que introducir el usuario y contraseña y ya se podrá controlar exactamente igual que si se estuviera delante de es ordenador.

8.2.2.3. Apple Remote Desktop

Al igual que Microsoft, Apple tiene su propio sistema de acceso remoto, el Apple Remote Desktop.

Antes sucedía como en Windows, era necesario tener una versión especial del sistema operativo, que se llamaba macOS Server, pero actualmente pero como ahora esa versión ha quedado bastante olvidada, (aunque es una opción nativa de macOS), es necesario comprarla a parte para desbloquearla.



La parte negativa de este sistema es que se trata de un servicio que es sólo para macOS, lo que quiere decir que sólo se puede acceder desde otro Mac.

La idea no es tanto la de permitirte acceder a tu ordenador de cualquier sitio como la de poder crear, administrar y controlar una red de ordenadores.

8.2.2.4. TeamViewer

Es un *software* privado que ofrece licencia gratuita a los usuarios y de pago a las empresas. También se puede usar independientemente del sistema operativo de los equipos conectados. Es una de las soluciones de control remoto más populares.

Su principal función es el control remoto, pero tiene otras funcionalidades de trabajo en equipo y presentación (reuniones en línea, videoconferencias, etcétera).



Fuente: https://es.m.wikipedia.org/wiki/Archivo:TeamViewer_logo.svg

Es una herramienta muy útil para el soporte técnico de usuarios de forma profesional.

También destaca por tener aplicaciones para todos los sistemas operativos que puedas imaginar, y tiene opciones como el control de varios ordenadores a la vez, el grabado de sesiones, un chat para comunicarte entre equipos o la posibilidad de enviar archivos y documentos de un ordenador a otro.

8.2.2.5. SupRemo

Se trata de otra herramienta que es totalmente gratuita para los usuarios domésticos, pero que tiene versiones de pago con más opciones para las empresas.

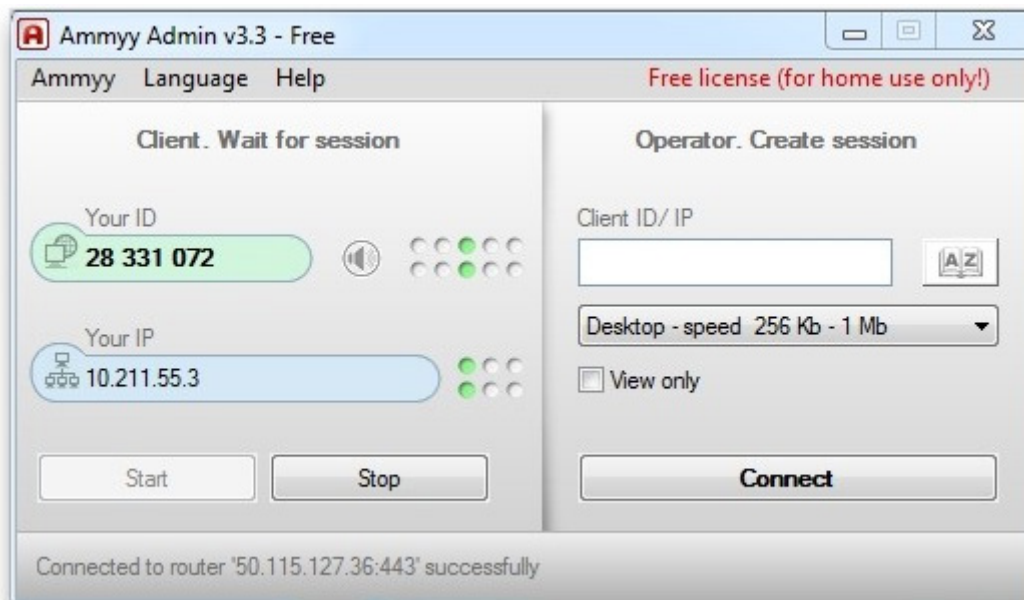
Una de sus mejores características es que no es necesario configurar nada a nivel de ordenador, es instalar y listo. Además, las conexiones están cifradas con el algoritmo AES-256.

Otra característica interesante de esta aplicación es que es una herramienta multiplataforma, que tiene aplicaciones para Windows, GNU/Linux y macOS, así como para Android o iOS.

Permite conectarte a ordenadores y escritorios remotos, con la posibilidad de trabajar con múltiples pantallas y conexiones simultáneas, o transferir archivos y carpetas entre los ordenadores conectados.



8.2.2.6. Ammyy Admin



Esta es una herramienta muy ligera, con un instalador que tiene un peso mínimo alrededor de 1 MB y un proceso de configuración sencillo para usuarios sin conocimiento técnicos.

Es una herramienta ligera para usar sólo ocasionalmente y que se limite a permitir controlar tu ordenador de forma remota, pero no permite el intercambio de archivos ni dispone de funciones avanzadas.

Dispone de dos versiones:

- Versión gratuita que **sólo puede utilizarse durante 15 horas al mes** con una única sesión.
- Versiones de pago.

8.2.2.7. Iperius remote

Una aplicación que tiene **una modalidad freeware profesional** que da buenas opciones a coste cero.

Evidentemente, la versión gratuita está más limitada que la profesional, permitiendo sólo una conexión a la vez, aunque a cualquier ordenador y con una lista compartida de equipos y contactos.

Al ser una solución profesional, **también tiene un chat multiusuario** para poder hablar entre los miembros del equipo, así como una cronología de accesos. Además de su cliente para ordenadores, también tienes aplicaciones para Android e iOS con las que conectarte remotamente a tu ordenador desde cualquier sitio.



8.2.2.8. AnyDesk

AnyDesk es completamente gratuita para uso personal y no requiere de conocimientos avanzados de informática.

Simplemente es necesario tener una conexión WiFi estable y dispositivo con el cliente instalado, que puede ser un ordenador o incluso móviles como Android e iOS.

Algunas de sus características son:

- Su versión para móviles tiene una serie de controles adaptados con opciones avanzadas con determinados movimientos del dedo.
- También permite el envío de archivos de forma remota.
- También permite controlar tu móvil desde el ordenador, aunque en este caso es una función que no funciona para todos los dispositivos.

8.2.2.9. VNC Connect

La aplicación ofrece la posibilidad de instalarla en cualquier sistema operativo de sobremesa, y también tiene clientes móviles para Android e iOS, lo que significa que su flexibilidad es máxima.

La herramienta ofrece:

- Conexión remota a ordenadores.
- Poder enviar invitaciones a otras personas para acceder a tus equipos.
- Copias de seguridad.
- El bloqueo del acceso a los clientes remotos por si te roban algún dispositivo en el que tenías acceso.

8.3. Tecnología Wake On Lan

Wake on LAN (WOL, o también WoL) es un estándar de redes de computadoras Ethernet que permite encender remotamente computadoras apagadas.

Esta tecnología es muy útil para administradores de sistemas, Wake On LAN hace que sea posible arrancar uno o más equipos desde un ordenador, tablet o smartphone conectados en la red local.



Hoy en día implementan este método en instituciones educativas para encender desde el servidor central los equipos que poseen. También puede resultar útil a un administrador de red, para encender un equipo que esté en una habitación alejada o en otro un piso.

Cualquier empresa u organismo con una conexión de banda ancha y un router pueden aprovechar este sistema para encender un equipo.

Hay que realizar unas configuraciones en hardware y Bios para que el ordenador se pueda arrancar de forma remota, lo que se conoce también como que sea "wakeable".

Para poder realizar el encendido remoto, es necesario:

- Que la opción Wake on LAN este activada en la configuración BIOS de la placa base de la máquina a encender.



Habilitar (Enabled) la opción en la BIOS

- Puede ser necesario configurar el ordenador para que reserve energía para la tarjeta de red cuando está apagado y también puede ser necesario activar esta característica desde la configuración de la tarjeta de red.

- Que la fuente de alimentación sea ATX:

Este tipo de alimentación continúa alimentando la placa madre mientras estén conectadas a la corriente eléctrica y, por tanto, también a la placa de red.

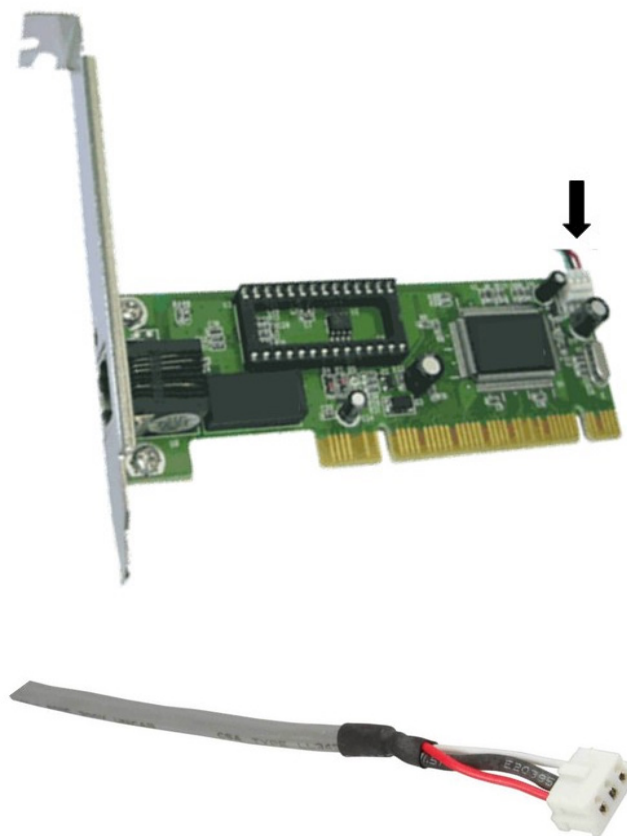
La placa base suele tener un led, que indica que está recibiendo alimentación, aunque el ordenador este apagado.

- Que la placa base del ordenador soporte la tecnología WoL:

La mayoría de placas base (también llamada placa madre) modernas cuentan con un controlador Ethernet integrado en placa base, que incorpora WoL sin necesidad de un cable externo.

Las placas madre antiguas, que no disponen de tarjeta de red integrada en la placa base tienen un conector WAKEUP-LINK que debe ser conectado a la tarjeta de red PCI a través de un cable de 3-pin determinado.

Los sistemas que soportan la norma PCI 2.2 en conjunto con una placa de red PCI compatible normalmente no requieren un cable WoL ya que la energía necesaria es provista por el bus PCI.



Tarjeta de red PCI con conector WAKEUP-LINK, y cable Wol



+ Info

Los computadores portátiles con el chipset Intel 3945 o posterior (con soporte BIOS) permiten usar el estándar usando wireless (IEEE 802.11).

Esto es llamado Wake on Wireless LAN (WoWLAN).

8.3.1. Funcionamiento

Conexiones Ethernet, incluyendo redes domésticas y de trabajo, redes inalámbricas y la misma Internet, están basadas en paquetes de datos enviados entre ordenadores.

Para encender un ordenador de forma remota, hay que enviarle un paquete (llamado paquete mágico) a través de la red, donde se indica la dirección MAC del equipo que se quiere encender.



Las computadoras que están apagadas y tienen activado el sistema Wake-on-LAN, "escuchan" paquetes entrantes en modo de bajo consumo de energía mientras la máquina está apagada.

Cuando en esta escucha, la tarjeta de red reconoce que tiene la dirección MAC especificada, responde "despertando" al equipo mediante una señal enviada a la placa base del mismo, produciéndose el arranque de la máquina (como cuando se pulsa el botón de encendido).

Se denomina paquete mágico (magic packet) a una trama de difusión que contiene una cadena de 6 bytes de valor 255 ("FF FF FF FF FF FF" en hexadecimal), seguida de 16 repeticiones de la dirección MAC del computador de destino.

Características del paquete mágico:

- Tiene un tamaño fijo de 102 bytes, que comienza con 6 bytes, con el valor hexadecimal FF, que sería la dirección de broadcast.

Esto significa que se enviará este paquete a todos los equipos de la subred.

- Luego siguen 16 grupos de 6 valores hexadecimal cada uno, que contienen la dirección física o MAC address.

Normalmente el paquete mágico se envía como un datagrama utilizando un protocolo de transmisión sin conexión, como UDP, y el puerto de envío es 7 o 9. Esta es la práctica más común.

- La mayoría de los paquetes mágicos se envían en la capa de enlace de datos (capa 2 del modelo OSI).

En la mayoría de los casos, el paquete mágico, se transmite a una red determinada utilizando una dirección de transmisión y no se utiliza ninguna dirección IP (capa 3 del modelo OSI). Pero también se pueden enviar utilizando una dirección IP específica.



+ Info

Wake on Internet.

Si es conexión con IP fija, tenemos todo listo: los datos que debemos ingresar son los mismos que para una red LAN.

En caso de contar con más de un equipo o conexión ADSL hay que tener el router siempre online y con la opción subnet directed broadcasts habilitada.



En caso de que el router no disponga de esta opción, habrá que establecer en él las rutas estáticas que cada PC tiene en la red interna (dirección IP <---> dirección física).

Datagrama

Un datagrama es un paquete de datos que constituye el mínimo bloque de información en una red de conmutación por datagramas, la cual es uno de los dos tipos de protocolo de comunicación por conmutación de paquetes usados para encaminar por rutas diversas dichas unidades de información entre nodos de una red, por lo que se dice que no está orientado a conexión. La alternativa a esta conmutación de paquetes es el circuito virtual, orientado a conexión.

Los datagramas se componen de:

- Una **cabecera** con información de control.
- Los propios **datos** que se desean transmitir.

En la técnica de datagramas, cada paquete se trata de forma independiente gracias a que puede contener en la cabecera la dirección de origen y destinatario. Mediante un encaminador, también conocido como enrutador o, más popularmente, router, la red puede encaminar cada fragmento hacia el receptor o ETD (Equipo Terminal de Datos) por rutas diferentes.

Este funcionamiento es la diferencia esencial con la conmutación por circuito virtual y determina sus virtudes y defectos, que también condicionan su idoneidad al tipo de aplicación de la red. Tiene ventajas e inconvenientes:

- Como ventajas, esta flexibilidad permite:
 - Control del tráfico para aprovechar la capacidad de canal de cada tramo de red.
 - Adaptarse ante congestiones y caídas de nodos intermedios, evitando bloqueos.
 - Abaratar costes, al poder ajustar el ancho de banda y número de líneas precisados.
- Como inconvenientes, impide garantizar:
 - Una velocidad constante del flujo de datos.
 - Que cada paquete se reciba en el orden original.
 - Que todos lleguen a su destino.



Por tanto, se depende de nuevos procedimientos para reconstruir la información adecuadamente en el destino. Además, aumenta el volumen de tráfico un poco, al repetirse información de cabecera como la dirección a cada trama.

En su uso en Internet, tiene protocolos:

- **Orientados a conexión.**

Donde el protocolo aplicado para transportar los paquetes es TCP, del inglés Transmission Control Protocol ("protocolo de control de transmisión"), que garantiza que todos los paquetes lleguen correctamente y en orden.

- **No orientados a conexión.**

Donde el protocolo aplicado es UDP, del inglés User Datagram Protocol ("protocolo de datagrama de usuario"), que no garantiza la entrega de los datagramas.

8.3.2. Cómo realizar el arranque

Una vez que tenemos el hardware con las características necesarias y activado en Bios, hay que saber la dirección IP, máscara de subred y MAC address de cada uno de los equipos de la red.

Existen diversos modos de hacerlo, dependerá de la versión del sistema operativo que esté instalado, nombramos alguno de ellos:

- En Windows, ingresamos en la consola de comandos y ejecutamos el comando `arp -a` o `arp -g`, desde cualquier equipo de la red.

Aparecerán en pantalla todas las direcciones IP y sus respectivas MAC de la subred.

Si lo queremos en un archivo de texto, lo hacemos con la siguiente sentencia: `arp -a > macaddress.txt`.

- En GNU/Linux, también se puede usar el comando `arp`.

Con la opción `arp -f nombre_de_archivo`, se guardan los resultados de la conversión de direcciones en un archivo de texto. Si no se especifica ningún nombre para el archivo, la información se guardará en la carpeta `/etc/ethers` por defecto).

Otro método es realizarlo en cada equipo, mediante el comando `ipconfig /all`.

Si ya sabemos la dirección IP y la máscara, podemos ejecutar el comando `getmac`, para ver la dirección MAC.



8.3.3. Herramientas de software para Wake On Lan

Existen diferentes programas para realizar el envío de paquetes mágicos a los ordenadores despertarlos.

Vamos a ver los más conocidos:

- SolarWinds Wake-On-LAN.
- Engineer's Toolset.
- Depicus Wake-on-LAN Tools.
- NirSoft WakeMeOnLan.
- Aquila Wake on LAN.
- Wake On LAN de HM Software NL.
- EMCO WakeOnLan.
- Wake On LAN X.

SolarWinds Wake-On-LAN

SolarWinds es reconocida como una de las mejores herramientas de monitoreo de ancho de banda de red, y por otras muchas herramientas más pequeñas, que cubren diferentes necesidades de los administradores de red, como son la calculadora de subred avanzada y el servidor Kiwi Syslog.

Es muy simple, funciona con la introducción de la dirección IP y de la MAC de la máquina que se desea despertar, y automáticamente genera y envía un paquete mágico diseñado para despertar a la máquina indicada.

La herramienta también requiere ingresar la dirección IP de la computadora para despertarse. Al principio, esto puede parecer extraño ya que el estándar Wake-on-LAN solo usa direcciones MAC, pero la razón por la que también se requiere una dirección IP tiene que ver con lo que hace la herramienta después de que se envía el paquete mágico.

El hecho de que sea necesario introducir la IP, es que una vez que se envía el comando para reactivar la computadora remota, la herramienta SolarWinds Wake-onLAN abre inmediatamente una ventana secundaria donde aparecerá una confirmación de que el comando tuvo éxito, cuando la computadora remota finalice el arranque. Esta función se basa en el ping para confirmar el estado.



+ Info

Puedes consultar más información en la web.

<https://www.solarwinds.com>

Engineer's Toolset

La herramienta SolarWinds Wake-On-LAN también está disponible como parte de Engineer's Toolset, que es un paquete de unas 60 herramientas útiles destinadas a ingenieros y administradores de redes, como son las herramientas dedicadas a la resolución de problemas como Ping Sweep, DNS Analyzer y TraceRoute que se pueden usar para realizar diagnósticos de red y ayudar a resolver problemas complejos de red rápidamente.

Las herramientas pueden monitorear sus dispositivos y generar alertas sobre la disponibilidad o problemas de salud, algunos también se pueden utilizar para la gestión de la configuración y la consolidación de registros.

Depicus Wake-on-LAN Tools

Depicus es una empresa de desarrollo de software, que tiene una herramienta Wake-on-LAN basada en la web que se puede utilizar para iniciar una computadora de forma remota desde cualquier lugar de la web, su uso es principalmente para computadoras domésticas y requiere una configuración complicada en el router.

NirSoft WakeMeOnLan

WakeMeOnLan escanea la red cuando todas las computadoras están encendidas y recopila todas sus direcciones MAC, guardando la información en un archivo, de forma que cuando se necesita arrancar de manera remota un ordenador apagado.

Se puede consultar ese archivo y fácilmente seleccionar el ordenador/es a encender, haciéndolo simplemente con un clic.

Aquila Wake on LAN

Esta herramienta incorpora muchas características, algunas de ellas son:

- Activar una computadora remota que está apagada.
- Apagar una computadora remota.
- Hacer ping a la computadora remota seleccionada para mostrar su estado.



- Realizar un apagado de emergencia de todas las computadoras seleccionadas a la vez.
- Conectarse al servidor remoto a través de Escritorio remoto.
- Los paquetes mágicos pueden ayudar a solucionar problemas de Wake-on-LAN.
- Programar despertares y paradas.
- Incluye herramientas que le permiten escanear una red en busca de hosts, direcciones IP y direcciones MAC.

La herramienta también mantiene un registro de eventos donde encontrará un historial de activaciones, paradas y excepciones, y tiene un sistema de notificación avanzado que incluye notificaciones de la bandeja del sistema, notificaciones de sonido, notificaciones por correo electrónico y consejos de globos.

La interfaz gráfica de usuario es fácil de usar y dispone de una interfaz de línea de comandos, por lo que admite entornos de red complejos mediante el uso de difusiones dirigidas a subredes.

Wake On LAN de HM Software NL

Es una herramienta gratuita de Windows que solo funciona en las versiones de Windows 10 y Windows 10 Mobile.

Es una utilidad simple que solo proporciona el propósito de enviar un paquete mágico al host especificado.

La configuración inicial de la herramienta requiere que cree dispositivos "wakeable", cada uno de los cuales tiene un nombre, un icono y, por supuesto, su dirección MAC, y aparecerán en las ventanas principales de la herramienta.

Una vez que aparecen, tan solo hay que hacer clic en el ícono de la computadora en la ventana de la herramienta y elegir "Enviar WOL (Paquete Mágico)".

EMCO WakeOnLan

Dispone de todas las funciones para encender las computadoras en red de forma rápida y sencilla.

Está diseñado para activar múltiples computadoras simultáneamente, y está listo para trabajar en redes grandes con una estructura compleja, ya que el software puede automatizar todas las operaciones necesarias para reactivar las computadoras en red:

- Explora la red para detectar las computadoras disponibles.
- Recopila las direcciones MAC de todas las computadoras en red utilizando varios métodos.
- Genera los paquetes mágicos Wake-on-LAN.



- Incluye un módulo de programación para que las tareas de Wake-on-LAN puedan ejecutarse automáticamente a una hora específica.

Esto es muy útil cuando se quiere, por ejemplo, implementar software en computadoras remotas y hay primero que asegurarse de que estén todos encendidos.

Wake On LAN X

Esta herramienta se ha diseñado para ser simple e intuitiva y también portátil, ya que no es necesaria la instalación, solo hay que lanzar el ejecutable.

Se puede reiniciar o apagar una o varias computadoras remotas simultáneamente, mientras se monitorea su estado en tiempo real con el ping integrado.

También cuenta con un programador de tareas integrado para poder iniciar cualquier tarea en una fecha y hora específicas, y tiene algunas funcionalidades de diagnóstico, como la posibilidad de recuperar el último tiempo de arranque de los hosts remotos o la lista de servicios configurados como "Automáticos" pero que no se ejecutan actualmente en los hosts remotos, lo que ayuda a diagnosticar los problemas de arranque.

8.4. Intel AMT/vPro

La tecnología Intel® Active Management Technology (Intel® AMT) es una característica de la tecnología Intel® vPro™ compatible con los procesadores Intel® Centrino® e Intel® Core™ 2.

La tecnología Intel® AMT proporciona funciones de administración asistida por hardware, como son:

- PC remoto enciende.
- Gestión remota del BIOS.
- Reinicio en frío remoto y apagado (incluso si el sistema no funciona o no responde).
- Arranque remoto desde CD local o archivo de imagen.
- Etc.

Hay 2 requisitos de hardware que el sistema debe cumplir:

- La placa base debe admitir procesadores con tecnología vPro™ (Intel® Centrino® con vPro™ o Intel® Core™ 2 con vPro™).
- Estos modelos de placa base ya contienen un controlador de Ethernet incorporado con el chipset habilitado para Intel® AMT.
- El procesador debe ser Intel® Centrino® o Intel® Core™ 2 con vPro™.



Intel Active Management Technology (AMT) es hardware y firmware para la administración remota fuera de banda (Smart Out-of-Band OOB), de computadoras comerciales seleccionadas, ejecutan en Intel Management Engine, un microprocesador separado no expuestos al usuario, con el fin de monitorearlos, mantenerlos, actualizarlos, actualizarlos y repararlos.

La administración basada en hardware:

- Funciona a un nivel diferente al de las aplicaciones de software y utiliza un canal de comunicación (a través de la pila TCP / IP) que es diferente de la comunicación basada en software (que es a través de la pila de software en el sistema operativo).
- No depende de la presencia de un sistema operativo o un agente de administración instalado localmente.
- Ha estado disponible en computadoras basadas en intel / amd en el pasado, pero se ha limitado en gran medida a la configuración automática mediante dhcp o bootp para la asignación dinámica de direcciones ip y estaciones de trabajo sin disco, así como wake-on-lan (wol) para encender sistemas de forma remota.

AMT no está destinado a ser utilizado por sí mismo, sino a ser utilizado con una aplicación de gestión de software. Le da a una aplicación de gestión (y, por lo tanto, al administrador del sistema que la usa) acceso a la PC a través del cable, para realizar de forma remota tareas que son difíciles o, a veces, imposibles cuando se trabaja en una PC que no tiene funcionalidades remotas.

AMT está diseñado en un procesador secundario (de servicio) ubicado en la placa base, y utiliza comunicación protegida por TLS y encriptación sólida para brindar seguridad adicional.

AMT está integrado en PC con tecnología Intel vPro y se basa en Intel Management Engine (ME).

AMT ha avanzado hacia un mayor soporte para los estándares DMTF Desktop y Mobile Architecture for System Hardware (DASH) y AMT Release 5.1 y versiones posteriores son una implementación de los estándares DASH versión 1.0 / 1.1 para la gestión fuera de banda.

AMT proporciona una funcionalidad similar a IPMI, aunque AMT está diseñado para sistemas informáticos de cliente en comparación con el IPMI típicamente basado en servidor.



+ Info

Actualmente, AMT está disponible en computadoras de escritorio, servidores, ultra-books, tabletas y computadoras portátiles con la familia de procesadores Intel Core vPro, incluidos Intel Core i5, Core i7, Core i9 y la familia de productos Intel Xeon E3-1200, Xeon E, Xeon W-1200.



La propia Intel proporciona un paquete de software de juego de herramientas para desarrolladores que permite el acceso básico a AMT, incluyéndose de forma gratuita en dispositivos vendidos al público y a pequeñas empresas, pero no se proporcionan todas las capacidades completas de AMT, como son:

- El acceso remoto cifrado a través de un certificado de clave pública.
- El aprovisionamiento automático de dispositivos remotos de clientes iAMT no configurados.

Fallas

Intel confirmó un error de Elevación remota de privilegios, Remote Elevation of Privilege bug, (CVE - 2017-5689, SA-00075) en su tecnología de administración el 1 de mayo de 2017.

Todas las plataformas Intel con capacidad de administración estándar de Intel, tecnología de administración activa o tecnología para pequeñas empresas, de Nehalem en 2008 a Kaby Lake en 2017 tiene un agujero de seguridad explotable de forma remota en el ME.

Algunos fabricantes, como Purism y System76 ya están vendiendo hardware con Intel Management Engine desactivado para evitar el exploit remoto.

Intel confirmó el 20 de noviembre de 2017 fallas de seguridad importantes adicionales en el ME que afectan a una gran cantidad de computadoras que incorporan el firmware de Management Engine, Trusted Execution Engine y Server Platform Services, desde Skylake en 2015 hasta Coffee Lake en 2017 (SA-00086).

Las actualizaciones de software proporcionan actualizaciones a la próxima versión secundaria de Intel AMT. Las nuevas versiones principales de Intel AMT se integran en un nuevo chipset y se actualizan mediante un nuevo hardware.



+ Info

Puede obtener más información en la web oficial de Intel.

<https://www.intel.com/content/www/us/en/architecture-and-technology/intel-active-management-technology.html>



8.4.1. Funciones y tareas de administración de AMT

Intel AMT incluye funciones:

- De administración remota, seguridad, administración de energía y configuración remota basadas en hardware que permiten el acceso remoto independiente a las PC habilitadas para AMT.

Intel AMT es una tecnología de seguridad y administración integrada en las PC con tecnología Intel vPro.

- Intel AMT utiliza un canal de comunicación fuera de banda (OOB) basado en hardware que funciona independientemente de la presencia de un sistema operativo en funcionamiento. El canal de comunicación es independiente del estado de energía de la PC, la presencia de un agente de administración y el estado de muchos componentes de hardware, como unidades de disco duro y memoria.

Las funciones basadas en hardware se pueden combinar con secuencias de comandos para automatizar el mantenimiento y el servicio.

Las características de AMT basadas en hardware en computadoras portátiles y de escritorio incluyen:

- Canal de comunicación remoto cifrado para el tráfico de red entre la consola de TI e Intel AMT.
- Capacidad para una PC con cable (conectada físicamente a la red) fuera del firewall de la empresa en una LAN abierta para establecer un túnel de comunicación seguro (a través de AMT) de regreso a la consola de TI. Los ejemplos de una LAN abierta incluyen una computadora portátil con cable en casa o en un sitio SMB que no tiene un servidor proxy.
- Encendido / apagado / ciclo de encendido remotos a través de WOL encriptado.
- Arranque remoto, mediante redireccionamiento de dispositivos electrónicos integrados (IDE-R).
- Redirección de consola, vía serial sobre LAN (SOL).
- Teclado, video, mouse (KVM) a través de la red.
- Filtros basados en hardware para monitorear los encabezados de paquetes en el tráfico de red entrante y saliente en busca de amenazas conocidas (basados en temporizadores programables) y para monitorear amenazas conocidas / desconocidas basadas en heurísticas basadas en el tiempo. Las computadoras portátiles y de escritorio tienen filtros para monitorear los encabezados de los paquetes. Las PC de escritorio tienen filtros de encabezado de paquete y filtros basados en el tiempo.
- Circuitos de aislamiento (anteriormente y extraoficialmente llamados "disyuntores" por Intel) para bloquear puertos, limitar la velocidad o aislar completamente una PC que podría estar comprometida o infectada.
- Comprobación de presencia de agentes, a través de temporizadores programables basados en políticas y basados en hardware. Una "falta" genera un evento; y esto también puede generar una alerta.



- Alerta OOB.
- Registro de eventos persistente, almacenado en memoria protegida (no en el disco duro).
- Acceda (prearranque) al identificador único universal (UUID) de la PC.
- Acceda a la información de activos de hardware (prearranque), como el fabricante y el modelo de un componente, que se actualiza cada vez que el sistema pasa por la autoprueba de encendido (POST).
- Acceda (prearranque) al almacén de datos de terceros (TPDS), un área de memoria protegida que los proveedores de software pueden usar, en la que se puede obtener información sobre la versión, archivos .DAT y otra información.
- Opciones de configuración remota, incluida la configuración remota zero-touch basada en certificados, configuración de llave USB (light-touch) y configuración manual.
- Vía protegida de audio / video para protección de reproducción de medios protegidos con DRM.
- Las computadoras portátiles con AMT también incluyen tecnologías inalámbricas.
- Soporte para protocolos inalámbricos IEEE 802.11 a / g / n.
- Extensiones compatibles con Cisco para voz sobre WLAN.

8.4.2. Aplicaciones

La mayoría de las funciones de AMT están disponibles OOB, independientemente del estado de energía de la PC, es decir incluso si el ordenador está apagado, pero con el cable de alimentación conectado, si el sistema operativo se ha bloqueado, si falta el agente de software o si el hardware (como un disco duro o memoria) ha fallado.

Hay otras funciones que requieren que la PC esté encendida, como la redirección de la consola a través de serie sobre LAN (SOL), verificación de presencia de agentes y los filtros de tráfico de red están disponibles después de que se enciende la PC.

Hay que tener en cuenta que Intel AMT tiene capacidad de encendido remoto.

Intel AMT admite estas tareas de administración:

- Encienda, apague, apague y vuelva a encender la computadora de forma remota.
- Inicie la PC de forma remota al redirigir de forma remota el proceso de inicio de la PC, lo que hace que se inicie desde una imagen diferente, como un recurso compartido de red, un CD-ROM o DVD de inicio, una unidad de reparación u otro dispositivo de inicio. Esta función admite el arranque remoto de una PC que tiene un sistema operativo dañado o faltante.



- Redirigir de forma remota las E / S del sistema a través de la redirección de la consola a través de serie a través de LAN (SOL). Esta función admite la resolución de problemas remota, reparación remota, actualizaciones de software y procesos similares.
- Acceda y cambie la configuración del BIOS de forma remota. Esta función está disponible incluso si la PC está apagada, el sistema operativo está inactivo o el hardware ha fallado. Esta función está diseñada para permitir actualizaciones y correcciones remotas de los ajustes de configuración. Esta función admite actualizaciones completas de BIOS, no solo cambios en configuraciones específicas.
- Detecta tráfico de red sospechoso.

En las computadoras portátiles y de escritorio, esta función permite que un administrador del sistema defina los eventos que podrían indicar una amenaza entrante o saliente en un encabezado de paquete de red.

En las PC de escritorio, esta función también admite la detección de amenazas conocidas y / o desconocidas (incluidos gusanos informáticos de movimiento lento y rápido) en el tráfico de red a través de filtros basados en heurística basados en el tiempo.

El tráfico de red se verifica antes de que llegue al sistema operativo, por lo que también se verifica antes de que se carguen el sistema operativo y las aplicaciones de software, y después de que se apaguen (un período tradicionalmente vulnerable para los ordenadores).

- Bloquear o limitar el tráfico de red hacia y desde sistemas sospechosos de estar infectados o comprometidos por virus informáticos, gusanos informáticos u otras amenazas.

Esta función utiliza circuitos de aislamiento basados en hardware Intel AMT que pueden activarse manualmente (de forma remota, por el administrador del sistema) o automáticamente, según la política de TI (un evento específico).

- Administre filtros de paquetes de hardware en el adaptador de red integrado.
- Envíe automáticamente la comunicación OOB a la consola de TI cuando un agente de software crítico pierde su registro asignado con el temporizador programable basado en hardware basado en políticas.

Un "error" indica un problema potencial. Esta función se puede combinar con alertas OOB para que la consola de TI sea notificada solo cuando ocurre un problema potencial (ayuda a evitar que la red se inunde con notificaciones de eventos "positivos" innecesarios).

- Reciba eventos de captura de eventos de plataforma (PET) fuera de banda del subsistema AMT (por ejemplo, eventos que indican que el sistema operativo está bloqueado o bloqueado, o que se ha intentado un ataque de contraseña).

Se puede emitir una alerta en un evento (como no cumplir, en combinación con la verificación de presencia de un agente) o en un umbral (como alcanzar una velocidad de ventilador en particular).



- Acceda a un registro de eventos persistente, almacenado en la memoria protegida.

El registro de eventos está disponible OOB, incluso si el sistema operativo está inactivo o el hardware ya ha fallado.

- Descubra un sistema AMT independientemente del estado de energía de la PC o del estado del sistema operativo.
- La detección (acceso previo al arranque al UUID) está disponible si el sistema está apagado, su sistema operativo está comprometido o no funciona, el hardware (como un disco duro o memoria) ha fallado o faltan agentes de administración.
- Realice un inventario de software o acceda a información sobre el software en la PC.

Esta función permite a un proveedor de software de terceros almacenar información de versión o activos de software para aplicaciones locales en la memoria protegida Intel AMT.

(Este es el almacén de datos de terceros protegido, que es diferente de la memoria AMT protegida para información de componentes de hardware y otra información del sistema).

El administrador del sistema puede acceder OOB al almacén de datos de terceros. Por ejemplo, un programa antivirus podría almacenar información de la versión en la memoria protegida que está disponible para datos de terceros.

Un script de computadora podría usar esta función para identificar las PC que deben actualizarse.

- Realice un inventario de hardware cargando la lista de activos de hardware de la PC remota.

(Controlador de administración de placa base, BIOS, procesador, memoria, discos, baterías portátiles, unidades reemplazables en el campo y otra información).

La información de los activos de hardware se actualiza cada vez que el sistema se ejecuta mediante la autoprueba de encendido (POST).



+ Info

A partir de la versión principal 6, Intel AMT incorpora un servidor VNC patentado, para acceso fuera de banda utilizando tecnología de visor compatible con VNC dedicada, y tiene capacidad KVM (teclado, video, mouse) completa durante todo el ciclo de energía, incluido el control ininterrumpido del escritorio cuando se carga un sistema operativo.



Los clientes como VNC Viewer Plus de RealVNC también brindan funcionalidad adicional que podría facilitar la realización (y observación) de ciertas operaciones de Intel AMT, como apagar y encender la computadora, configurar el BIOS y montar una imagen remota (IDER).

8.4.3. Aprovisionamiento e integración

AMT admite aprovisionamiento remoto basado en certificados o basado en PSK (implementación remota completa), aprovisionamiento basado en llave USB (aprovisionamiento "con un solo toque"), aprovisionamiento manual y aprovisionamiento mediante un agente en el host local ("Aprovisionamiento basado en host").

Un OEM también puede pre-aprovisionar AMT.

La versión actual de AMT admite la implementación remota en equipos portátiles y de escritorio. (La implementación remota era una de las características clave que faltaban en las versiones anteriores de AMT y que retrasó la aceptación de AMT en el mercado).

La implementación remota, hasta hace poco, solo era posible dentro de una red corporativa.

La implementación remota permite a un administrador de sistemas implementar PC sin "tocar" los sistemas físicamente.

También permite a un administrador de sistemas retrasar las implementaciones y poner en uso las PC durante un período de tiempo antes de que las funciones de AMT estén disponibles para la consola de TI.

A medida que evolucionan los modelos de entrega e implementación, AMT ahora se puede implementar a través de Internet, utilizando métodos "Zero-Touch" y basados en host.

Las PC se pueden vender con AMT habilitado o deshabilitado.

El OEM determina si enviar AMT con las capacidades listas para configurar (habilitadas) o deshabilitadas. El proceso de instalación y configuración puede variar según la versión del OEM.

AMT incluye una aplicación de icono de privacidad, llamada IMSS, que notifica al usuario del sistema si AMT está habilitado. Depende del OEM decidir si desea mostrar el icono o no.

AMT admite diferentes métodos para deshabilitar la tecnología de administración y seguridad, y diferentes métodos para volver a habilitar la tecnología.



AMT se puede desaproveccionar de dos formas:

- **Parcialmente**, mediante los ajustes de configuración.

Deja el PC en el estado de configuración.

En este estado, el PC puede iniciar automáticamente su proceso de configuración remota automatizado.

- **Por completo**, borrando todos los ajustes de configuración, las credenciales de seguridad y los ajustes operativos y de red.
 - Borra el perfil de configuración, así como las credenciales de seguridad y las configuraciones operativas de red necesarias para comunicarse con Intel Management Engine.
 - Devuelve Intel AMT a su estado predeterminado de fábrica.

Una vez que se deshabilita AMT, para volver a habilitar AMT, un administrador de sistemas autorizado puede restablecer las credenciales de seguridad necesarias para realizar la configuración remota mediante:

- Usando el proceso de configuración remota (configuración remota completamente automatizada a través de certificados y claves).
- Acceder físicamente a la PC para restaurar las credenciales de seguridad, ya sea mediante una llave USB o ingresando las credenciales y los parámetros MEBx manualmente.
- Hay una manera de restablecer totalmente AMT y volver a los valores predeterminados de fábrica. Esto se puede hacer de dos formas:
 - Establecer el valor apropiado en el BIOS.
 - Borrando la memoria CMOS y / o NVRAM.



+ Info

La instalación y la integración de AMT son compatibles con un servicio de instalación y configuración (para instalación automatizada), una herramienta de servidor web AMT (incluida con Intel AMT) y AMT Commander, una aplicación patentada gratuita y no compatible disponible en el sitio web de Intel.



8.4.4. Comunicación

Todo el acceso a las funciones de Intel AMT se realiza a través de Intel Management Engine en el hardware y firmware de la PC.

La comunicación AMT depende del estado del motor de administración, no del estado del sistema operativo de la PC.

Como parte de Intel Management Engine, el canal de comunicación AMT OOB se basa en la pila de firmware TCP / IP diseñada en el hardware del sistema, y puesto que se basa en la pila TCP / IP, la comunicación remota con AMT se produce a través de la ruta de datos de la red antes de que la comunicación pase al sistema operativo.

Intel AMT admite redes cableadas e inalámbricas.

Para portátiles inalámbricos con alimentación por batería, la comunicación OOB está disponible cuando el sistema está activo y conectado a la red corporativa, incluso si el sistema operativo no funciona.

La comunicación OOB también está disponible para portátiles inalámbricos o con cable conectados a la red corporativa a través de una red privada virtual (VPN) basada en el sistema operativo host cuando los portátiles están activos y funcionando correctamente.

AMT versión 4.0 y superior puede establecer un túnel de comunicación seguro entre una PC con cable y una consola de TI fuera del firewall corporativo. En este esquema, un servidor de presencia de administración (Intel lo llama una "puerta de enlace habilitada para vPro") autentica la PC, abre un túnel TLS seguro entre la consola de TI y la PC, y media la comunicación. El plan está destinado a ayudar al usuario o al PC mismo a solicitar mantenimiento o servicio cuando se encuentra en oficinas satélite o lugares similares donde no hay un servidor proxy o dispositivo de gestión en el sitio.

Una PC AMT almacena la información de configuración del sistema en una memoria protegida.

Para PC con la versión 4.0 y superior, esta información puede incluir los nombres de los servidores de administración de "lista blanca" apropiados para la empresa.

La lista blanca (también conocida como lista de permisos) es la práctica de permitir explícitamente a algunas entidades identificadas el acceso a un privilegio, servicio, movilidad, acceso o reconocimiento en particular. (Es lo opuesto a las listas negras).

Cuando un usuario intenta iniciar una sesión remota entre la PC cableada y un servidor de la empresa desde una LAN abierta, AMT envía la información almacenada a un servidor de presencia de administración (MPS) en la "zona desmilitarizada" ("DMZ") que existe entre los cortafuegos corporativo y cortafuegos del cliente (la PC del usuario). El MPS usa esa información para ayudar a autenticar la PC. Luego, el MPS media la comunicación entre la computadora portátil y los servidores de administración de la empresa.



Debido a que la comunicación está autenticada, se puede abrir un túnel de comunicación seguro mediante el cifrado TLS. Una vez que se establecen comunicaciones seguras entre la consola de TI e Intel AMT en la PC del usuario, un administrador del sistema puede usar las características típicas de AMT para diagnosticar, reparar, mantener o actualizar la PC de forma remota.

8.4.5. Diseño

La gestión del motor Intel (ME), también conocido como el Motor de manejabilidad Intel, es un subsistema autónomo que ha sido incorporado en prácticamente la totalidad de Intel 's procesador conjuntos de chips desde 2008.

Está ubicado en el Platform Controller Hub de las placas base Intel modernas.

Intel Management Engine siempre se ejecuta mientras la placa base esté recibiendo energía, incluso cuando la computadora está apagada. Este problema se puede mitigar con la implementación de un dispositivo de hardware, que puede desconectar la alimentación de red.

Intel ME es un objetivo atractivo para los piratas informáticos, ya que tiene acceso de nivel superior a todos los dispositivos y evita por completo el sistema operativo. La Electronic Frontier Foundation ha expresado su preocupación por Intel ME y algunos investigadores de seguridad han expresado su preocupación de que sea una puerta trasera.

El principal competidor de Intel, AMD, ha incorporado la tecnología AMD Secure equivalente (formalmente llamada Platform Security Processor) en prácticamente todas sus CPU posteriores a 2013.

El motor de administración se confunde a menudo con Intel AMT (tecnología de administración activa de Intel). AMT se ejecuta en ME, pero solo está disponible en procesadores con vPro.

AMT ofrece a los propietarios de dispositivos la administración remota de su computadora, como encenderla o apagarla y reinstalar el sistema operativo.

Sin embargo, el ME en sí está integrado en todos los conjuntos de chips de Intel desde 2008, no solo en aquellos con AMT. Si bien el propietario puede desaprovisionar AMT, no existe una forma oficial y documentada de desactivar el ME.

El subsistema consiste principalmente en firmware propietario que se ejecuta en un microprocesador separado que realiza tareas durante el arranque, mientras la computadora está funcionando y mientras está inactiva. Siempre que el chipset o SoC esté conectado a la corriente (a través de la batería o fuente de alimentación), continúa funcionando incluso cuando el sistema está apagado. Intel afirma que el ME debe proporcionar un rendimiento completo. Su funcionamiento exacto está en gran parte indocumentado y su código está ofuscado usando tablas confidenciales de Huffman almacenadas directamente en el hardware, por lo que el firmware no contiene la información necesaria para decodificar su contenido.



Diseño: Hardware

El Management Engine (ME) es un coprocesador aislado y protegido, integrado como parte no opcional en todos los conjuntos de chips Intel actuales (a partir de 2015).

Información complementaria:

A partir de ME 11, se basa en la CPU de 32 bits basada en Intel Quark x86 y ejecuta el sistema operativo MINIX 3.

El estado ME se almacena en una partición de la memoria flash SPI, utilizando el Sistema de archivos Flash integrado (EFFS).

Las versiones anteriores se basaban en un núcleo ARC, con Management Engine ejecutando ThreadX RTOS de Express Logic.

- Las versiones 1.x a 5.x de la ME usaban ARCTangent-A4 (solo instrucciones de 32 bits).
- Las versiones 6.x a 8.x usaban el ARCompact más nuevo (arquitectura mixta de conjuntos de instrucciones de 32 y 16 bits).
- A partir de ME 7.1, el procesador ARC también podría ejecutar Subprogramas de Java.

El ME comparte la misma interfaz de red e IP que el sistema anfitrión. El tráfico se enruta según los paquetes a los puertos 16992-16995. Existe soporte en varios controladores Intel Ethernet, exportados y configurados a través del Protocolo de transporte de componentes de administración (MCTP).

El ME también se comunica con el host a través de la interfaz PCI.

En Linux, la comunicación entre host y el ME se realiza a través de `/dev/mei`.

Hasta el lanzamiento de los procesadores Nehalem, el ME generalmente estaba integrado en el puente norte de la placa base, siguiendo el diseño del concentrador de controlador de memoria (MCH).

Con las arquitecturas Intel más nuevas (Intel 5 Series en adelante), ME se incluye en el Platform Controller Hub (PCH).

Diseño-Firmware

- Management Engine (ME): conjuntos de chips convencionales.
- Servicios de plataforma de servidor (SPS) – servidor.
- Trusted Execution Engine (TXE): tableta / móvil / bajo consumo.



8.4.6. Seguridad

Debido a que AMT permite el acceso a la PC por debajo del nivel del sistema operativo, la seguridad de las funciones de AMT es una preocupación clave.

La seguridad para las comunicaciones entre Intel AMT y el servicio de aprovisionamiento y / o la consola de administración se puede establecer de diferentes maneras según el entorno de red:

- Puede establecer mediante certificados y claves (infraestructura de clave pública TLS o TLS-PKI).
- Mediante claves precompartidas (TLS-PSK).
- (Los conjuntos de cifrado de claves precompartidas de Transport Layer Security, TLS-PSK, son un conjunto de protocolos criptográficos que proporcionan una comunicación segura basada en claves precompartidas (PSK). Estas claves precompartidas son claves simétricas compartidas de antemano entre las partes que se comunican.)
- Contraseña de administrador.

Las tecnologías de seguridad que protegen el acceso a las funciones de AMT están integradas en el hardware y el firmware, y como otras funciones de AMT basadas en hardware, las tecnologías de seguridad están activas incluso si la PC está apagada, el sistema operativo falla, faltan agentes de software o el hardware (como un disco duro o memoria) ha fallado.

Debido a que el software que implementa AMT existe fuera del sistema operativo, el mecanismo de actualización normal del sistema operativo no lo mantiene actualizado, por lo que los defectos de seguridad en el software AMT pueden ser particularmente graves, ya que permanecerán mucho tiempo después de que se hayan descubierto y los posibles atacantes los conozcan.



+ Info

El 15 de mayo de 2017, Intel anunció una vulnerabilidad crítica en AMT.

Según la actualización, "la vulnerabilidad podría permitir que un atacante de red obtenga acceso de forma remota a equipos o dispositivos comerciales que utilicen estas tecnologías".

Intel anunció la disponibilidad parcial de una actualización de firmware para parchear la vulnerabilidad de algunos de los dispositivos afectados.



8.4.7. Redes

Hay protocolos para la administración remota en banda que utilizan un canal de comunicación de red seguro (por ejemplo, Secure Shell), pero algunos otros protocolos no están protegidos, por lo tanto, algunas empresas han tenido que elegir entre tener una red segura o permitir que TI use aplicaciones de administración remota sin comunicaciones seguras para mantener y reparar las PC.

Las tecnologías de seguridad y los diseños de hardware modernos permiten la gestión remota incluso en entornos más seguros. Por ejemplo, Intel AMT es compatible con:

- IEEE 802.1x.
- Entorno de ejecución de prearranque (PXE).
- Cisco SDN.
- Microsoft NAP.

Con Intel AMT en el entorno de red seguro, y por tanto con todas las funciones de AMT disponibles en un entorno de red seguro:

- La red puede verificar la postura de seguridad de una PC habilitada para AMT y autenticar la PC antes de que se cargue el sistema operativo y antes de que la PC tenga acceso a la red.
- El arranque PXE se puede utilizar manteniendo la seguridad de la red.

En otras palabras, un administrador de TI puede utilizar una infraestructura PXE existente en una red IEEE 802.1x, Cisco SDN o Microsoft NAP.

Intel AMT puede incorporar credenciales de seguridad de red en el hardware, a través del agente de confianza integrado Intel AMT y un complemento de postura AMT, que:

- Recopila información sobre la postura de seguridad.

Como la configuración del firmware y los parámetros de seguridad de software de terceros (como software antivirus y antispyware), BIOS y memoria protegida.

- El complemento y el agente de confianza pueden almacenar los perfiles de seguridad en la memoria no volátil protegida de AMT, que no se encuentra en la unidad de disco duro.

Debido a que AMT tiene un canal de comunicación fuera de banda, puede presentar la postura de seguridad de la PC a la red incluso si el sistema operativo o el software de seguridad de la PC están comprometidos.

Dado que AMT presenta la postura fuera de banda, la red también puede autenticar la PC fuera de banda, antes de que se carguen el sistema operativo o las aplicaciones y antes de que intenten acceder a la red. Si la postura de seguridad no es correcta, un administrador del sistema puede enviar una actualización OOB (a través de Intel AMT) o reinstalar el software de seguridad crítico antes de permitir que la PC acceda a la red.



El soporte para diferentes posturas de seguridad depende de la versión de AMT:

- Soporte para IEEE 802.1x y Cisco SDN requiere AMT versión 2.6 o superior para los ordenadores portátiles, y AMT versión 3.0 o superior para PCs de escritorio.
- El soporte para Microsoft NAP requiere AMT versión 4.0 o superior.
- La compatibilidad con el arranque PXE con seguridad de red completa requiere AMT versión 3.2 o superior para PC de escritorio.

La tecnología AMT incluye varios esquemas de seguridad, tecnologías y metodologías para proteger el acceso a las funciones de AMT durante la implementación y durante la administración remota.

Las tecnologías y metodologías de seguridad AMT incluyen:

- Seguridad de la capa de transporte, incluida la clave previamente compartida TLS (TLS-PSK).
- Autenticación HTTP.
- Inicio de sesión único en Intel AMT con autenticación de dominio de Microsoft Windows, basado en Microsoft Active Directory y Kerberos.
- Firmware firmado digitalmente.
- Generador de números pseudoaleatorios (PRNG) que genera claves de sesión.
- Memoria protegida (no en la unidad de disco duro) para datos críticos del sistema, como UUID, información de activos de hardware y ajustes de configuración del BIOS.
- Listas de control de acceso (ACL).
- Al igual que con otros aspectos de Intel AMT, las tecnologías y metodologías de seguridad están integradas en el chip.

Vamos a indicar algunas Vulnerabilidades y exploits conocidos:

- **Ring -3 rootkit.**

El RootKit "Ring-3" fue demostrado por el laboratorio "Invisible Things" para el chipset Q35; no funciona para el chipset Q45 posterior, ya que Intel implementó protecciones adicionales.

El exploit funcionó reasignando la región de memoria normalmente protegida (los 16 MB superiores de RAM) reservada para el ME.

El rootkit aprovechaba que el coprocesador ARC ME, figuraba en muchos chipsets modernos, para infectar el sistema incluso si la tecnología Intel Management Engine (AMT) no está habilitada. El coprocesador ME, creado para proporcionar funciones de gestión remota, actúa a un nivel muy bajo del sistema, resultando un objetivo muy interesante para los atacantes. Al alcanzar el ME, un rootkit podría persistir en el sistema incluso en estados de bajo consumo como S3, esquivando múltiples técnicas de rastreo y eliminación tradicionales.

Para el chipset Q35 vulnerable, un registrador de pulsaciones de teclas Patrick Stewin demostró el rootkit basado en ME.



- **Aprovisionamiento sin intervención.**

Otra evaluación de seguridad de Vassilios Ververis mostró serias debilidades en la implementación del chipset GM45.

En particular, criticó a AMT por transmitir contraseñas no cifradas en el modo de aprovisionamiento SMB cuando se utilizan las funciones de redirección IDE y Serial over LAN.

También encontró que el modo de aprovisionamiento "zero touch" (ZTC) todavía está habilitado incluso cuando el AMT parece estar deshabilitado en BIOS.

Ververis compró a Go Daddy un certificado que es aceptado por el firmware ME y permite el aprovisionamiento remoto "sin contacto" de máquinas (posiblemente desprevénidas), que transmiten sus paquetes HELLO a los posibles servidores de configuración.

- **Bob silencioso es silencioso.**

En mayo de 2017, Intel confirmó que muchas computadoras con AMT tenían una vulnerabilidad crítica de escalada de privilegios sin parchear (CVE - 2017-5689).

La vulnerabilidad, que fue apodada " Silent Bob is Silent" por los investigadores que lo habían informado a Intel, afecta a numerosas laptops, computadoras de escritorio y servidores vendidos por Dell., Fujitsu, Hewlett-Packard (más tarde Hewlett Packard Enterprise y HP Inc.), Intel, Lenovo y posiblemente otros.

Esos investigadores afirmaron que el error afecta a los sistemas fabricados en 2010 o después.

Otros informes afirmaron que el error también afecta a los sistemas fabricados en 2008.

La vulnerabilidad se describió como la que proporciona a los atacantes remotos, control total de las máquinas afectadas, incluida la capacidad de leer y modificar todo. Se puede usar para instalar malware persistente (posiblemente en firmware) y leer y modificar cualquier dato.

- **Tatu Ylönen, ssh.com.**

El proceso de autorización del usuario remoto incluyó un error del programador: comparó el hash (user_response) del token de autorización proporcionado por el usuario con el valor real del hash (computed_response) usando este código:

```
strncmp (respuesta_calculada, respuesta_usuario, longitud_respuesta)
```

La vulnerabilidad era que response_length era la longitud del token proporcionado por el usuario y no del token verdadero.

- Dado que el tercer argumento a favor strcmp es la longitud de las dos cadenas que se van a comparar, si es menor que la longitud de computed_response, solo se probará la igualdad de una parte de la cadena.



Específicamente, si `user_response` es la cadena vacía (con longitud 0), esta "comparación" siempre devolverá `True` y, por lo tanto, validará al usuario. Esto permitió a cualquier persona simplemente iniciar sesión en la admin cuenta en los dispositivos editando su paquete HTTP enviado para usar la cadena vacía como response valor del campo.

- **PLATINO.**

En junio de 2017, el grupo de delitos informáticos PLATINUM se destacó por explotar las capacidades de serie sobre LAN (SOL) de AMT para realizar la exfiltración de datos de documentos robados.

- **SA-00086.**

En noviembre de 2017, la firma de seguridad Positive Technologies detectó serias fallas en el firmware de Management Engine (ME), quien afirmó haber desarrollado un exploit funcional de este sistema para alguien que tenga acceso físico a un puerto USB.

El 20 de noviembre de 2017, Intel confirmó que se habían encontrado una serie de fallas graves en el motor de administración, el motor de ejecución confiable, los servicios de plataforma de servidor y lanzó una "actualización de firmware crítica".

8.4.8. Evitación y mitigación

Las PC con AMT suelen ofrecer una opción en el menú de la BIOS para apagar la AMT, aunque los OEM implementan las características de la BIOS de manera diferente, y, por lo tanto, la BIOS no es un método confiable para apagar la AMT.

Se supone que las PC basadas en Intel que se envían sin AMT no pueden tener AMT instalado más adelante, pero, sin embargo, siempre que el hardware de la PC sea potencialmente capaz de ejecutar AMT, no está claro qué tan efectivas son estas protecciones.

Actualmente, existen guías de mitigación y herramientas para deshabilitar AMT en Windows, pero Linux solo ha recibido una herramienta para verificar si AMT está habilitado y aprovisionado en sistemas Linux.

La única forma de solucionar esta vulnerabilidad es instalar una actualización de firmware. Intel ha puesto a disposición una lista de actualizaciones.

A diferencia de AMT, generalmente no existe una forma oficial y documentada de desactivar Management Engine (ME); siempre está encendido, a menos que el OEM no lo habilite en absoluto.



+ Info

En 2015, una pequeña cantidad de proveedores de la competencia comenzaron a ofrecer PC basadas en Intel diseñadas o modificadas específicamente para abordar posibles vulnerabilidades de AMT y preocupaciones relacionadas.



8.4.9. Configuración de un cliente Intel AMT

En primer lugar, es necesario realizar una configuración en la Bios.

La configuración del Intel Management Engine BIOS Extension (MEBx) se utiliza para activar o desactivar Intel AMT y configurarlo.

Es recomendable tener la BIOS protegida por contraseña, de tal forma que se protegen diversas configuraciones incluyendo el acceso a MEBx.

Al iniciar el sistema es necesario entrar en la configuración del motor de administración de Intel® AMT (Intel® AMT ME), esto puede hacerse de varias formas (según los OEM):

- En algunos casos aparece un mensaje indicando que es necesario pulsar <CTRL + P> mientras se realiza el arranque del equipo para acceder a la configuración MEBx.
- En otros casos, el mensaje es de presione F2 (o Del).

De este modo se entra en la configuración de la Bios donde hay una pestaña separada para Intel® AMT ME).

Una vez en la configuración de MEBx, hay que hacer los siguientes pasos en la configuración de Bios:

Configuraciones de Intel® AMT Manageability Engine

- Cambio de la contraseña predeterminada de Intel® AMT ME:

La contraseña predeterminada es "admin", es necesario cambiarla a una contraseña más fuerte.

Pautas para crear una buena contraseña de Intel® AMT ME:

- La longitud mínima: 8 caracteres.
- Al menos un carácter de un dígito: 0 ... 9.
- Al menos un carácter no alfanumérico: !, \$, ~, #, _, +, -...
- Caracteres latinos: tanto en minúsculas (a, b, ..., z) como en mayúsculas (A, B, ..., Z).
- Seleccione la función de gestión como Intel AMT.
- Seleccione las políticas de energía: esto se puede hacer a través de BIOS, WebUI o la interfaz de Intel AMT SOAP.



Configuraciones de Intel AMT

- Habilitar / deshabilitar DHCP (para sistemas móviles, tiene que usar DHCP).
- Nombre de host y dirección IP: si está eligiendo IP estática, debe tener un nombre de host y dirección IP independientes para Intel ME que la CPU de su host. Si elige DHCP, puede usar el mismo nombre de host y dirección IP para Intel ME como la CPU del host.
- Aprovisionamiento: Pequeña Mediana Empresa (SMB) / Empresa.
- Habilitar SOL / IDE-R.

Hay que pulsar F10 para guardar la configuración y reiniciar el sistema y a continuación confirmar que están los siguientes controladores instalados en el sistema:

- Controlador de interfaz de red Intel 82566DM.
- Intel Management Engine Interface (también conocido como controlador HECI).
- Serial-Over-Lan (SOL) Driver.
- Controlador de redireccionamiento IDE.
- Servicio de tecnología de administración activa Intel® LMS.
- Servicio de estado del sistema Intel® AMT.

Se recomienda revisar el sitio de su OEM para ver si hay actualizaciones de Bios.

El siguiente paso es verificar si puede acceder al sistema cliente de AMT desde el sistema de administración, para hacerlo es necesario deshabilitar cualquier firewall en su cliente y en el sistema de administración. Intente hacer ping al cliente desde el sistema de gestión. Ya se puede conectar al sistema cliente desde el sistema de administración utilizando WebUI.

El dispositivo Intel AMT tiene una interfaz web incorporada que puede ser utilizada por el sistema de administración para conectarse al cliente y cambiar algunos de los parámetros de configuración.

Acceder a las funciones de AMT de forma remota mediante Radmin Viewer

Se puede acceder a las funciones de AMT de forma remota mediante Radmin Viewer 3.3 gratuito.

Para conectarse a una computadora remota a través del modo de conexión Intel® AMT hay que realizar los siguientes pasos:

- Agregar un registro de la agenda para la computadora de destino.
- Hacer clic con el botón derecho en el registro para mostrar el menú contextual del Registro.
- Elegir el elemento del menú Intel® AMT.
- Elegir la operación AMT a realizar.



8.5. Entorno PXE

PXE (Preboot eXecution Environment), entorno de ejecución de prearranque, es una tecnología que proporciona un entorno para arrancar e instalar el sistema operativo en ordenadores de forma remota a través de una red, de forma independiente a los dispositivos de almacenamiento o de los sistemas operativos instalados.

PXE:

- Fue introducido como parte del framework Wired for Management por Intel.
- Fue descrito en la especificación (versión 2.1) publicada por Intel y Systemsoft el 20 de septiembre de 1999.
- Utiliza varios protocolos de red como IP, UDP, DHCP y TFTP.
- Utiliza varios conceptos como Globally Unique Identifier (GUID), Universally Unique Identifier (UUID) y Universal Network Device Interface (UNDI).

El término cliente PXE sólo se refiere al papel que la máquina juega en el proceso de arranque mediante PXE.

Un cliente PXE puede ser un servidor, una computadora de mesa, portátil o cualquier otra máquina que esté equipada con código de arranque PXE.



Resumiendo

El firmware del cliente trata de encontrar un servicio de redirección PXE en la red para recabar información sobre los servidores de arranque PXE disponibles.

Tras analizar la respuesta, el firmware solicitará al servidor de arranque apropiado el file path de un network bootstrap program (NBP), lo descargará en la memoria RAM del computador mediante TFTP, probablemente lo verificará, y finalmente lo ejecutará.

Si se utiliza un único NBP para todos los clientes PXE se puede especificar mediante BOOTP sin necesidad de un proxy DHCP, pero aún será necesario un servidor TFTP.



8.5.1. Protocolo PXE

El protocolo PXE consiste en una combinación de los protocolos DHCP y TFTP con pequeñas modificaciones en ambos.

- DHCP es utilizado para localizar el servidor de arranque apropiado.
- TFTP se descarga el programa inicial de bootstrap y archivos adicionales.

Para el arranque con PXE, es necesario un paquete denominado DHCPOFFER. Este paquete DHCPOFFER extendido contiene:

- Un campo PXE Discovery Control para indicar si se debe utilizar Multicasting, Broadcasting, o Unicasting para contactar con los servidores de arranque PXE.
- Una lista con las direcciones IP de los servidores de arranque PXE.
- Un menú en el que cada entrada representa un servidor de arranque PXE.
- Un prompt que indica al usuario que pulse [Tecla de función| <F8>]] para ver el menú de arranque.
- Un tiempo de espera que lanza la primera opción del menú de arranque cuando expira.



+ Info

PXE fue diseñado para funcionar sobre diferentes arquitecturas.

La versión 2.1 de la especificación asigna identificadores de arquitectura a seis tipos distintos de sistemas, incluyendo IA-64 y DEC Alpha.

Aunque la especificación sólo soporta completamente IA-32. Intel incluyó PXE en la EFI para IA-64, creando un estándar de facto con esta implementación.

Funcionamiento

Para iniciar una sesión de arranque con PXE el firmware envía un paquete de tipo DHCPDISCOVER extendido con algunas opciones específicas de PXE al puerto 67/UDP (puerto estándar del servicio DHCP).



Estas opciones indican que el firmware es capaz de manejar PXE, pero serán ignoradas por los servidores DHCP estándar.

Si un servicio de redirección PXE (Proxy DHCP) recibe un paquete DHCPDISCOVER extendido, responde con un paquete de difusión DHCPOFFER extendido con opciones PXE al puerto 67/UDP, este paquete se difundirá hasta que la mayoría de los clientes PXE se auto-configuren mediante DHCP. Los clientes se identificarán con su GUID/UUID.

Hay que tener en cuenta que el servicio de proxy DHCP debe ejecutarse sobre el mismo servidor que el servicio estándar de DHCP, y puesto que ambos servicios no pueden compartir el puerto 67/UDP:

- El Proxy DHCP se ejecuta sobre el puerto 4011/UDP y espera que los paquetes DHCPDISCOVER extendidos de los clientes PXE sean paquetes DHCPREQUEST.
- El servicio estándar DHCP debe enviar una combinación especial de opciones PXE en su paquete DHCPOFFER, de forma que los clientes PXE sepan que deben buscar un proxy DHCP en el mismo servidor, en el puerto 4011/UDP.

Servidor de arranque

Para contactar con cualquier servidor de arranque PXE el firmware debe obtener una dirección IP y el resto de información de un único paquete DHCPOFFER extendido.

Tras elegir el servidor de arranque PXE apropiado:

- El firmware envía un paquete DHCPREQUEST extendido mediante multicast o unicast al puerto 4011/UDP o broadcast al puerto 67/UDP.

(El paquete DHCPREQUEST extendido también puede ser un paquete DHCPINFORM).

- Este paquete contiene el servidor de arranque PXE y la capa de arranque PXE, permitiendo ejecutar múltiples tipos de servidores de arranque mediante un único *daemon* (o programa) de arranque.

Si un servidor de arranque PXE recibe un paquete DHCPREQUEST extendido como el descrito anteriormente y si está configurado para el tipo de servidor de arranque PXE y la arquitectura de cliente solicitados:

- Debe responder devolviendo un paquete DHCPACK donde se incluyen unos campos iniciales con cierta información.

Tras recibir el paquete DHCPACK solicitado, el **Network Bootstrap Program** es descargado y ejecutado en la RAM del cliente. Tiene acceso a las APIs del firmware PXE (Pre-boot, UDP, TFTP, Universal Network Device Interface, UNDI).



+ Info

Puedes consultar más información en la web oficial de Microsoft.

<https://docs.microsoft.com/es-es/troubleshoot/mem/configmgr/boot-from-pxe-server>

9. Bibliografía

- <http://es.wikipedia.org>
- <https://mediosdetransmisionyperturbaciones.wordpress.com/perturbaciones/>
- <https://es.slideshare.net/marthasol/perturbaciones-en-la-transmisin-3431088>
- https://guimi.net/monograficos/G-Cableado_estructurado
- <https://definicion.de>
- <https://es.slideshare.net/johnwlad18/interfaz-dte-dce>
- <https://unitel-tc.com/normas-sobre-cableado-estructurado/>
- <http://normcableestruc.blogspot.com/2017/>
- <https://www.c3comunicaciones.es/>
- https://campusvirtual.univalle.edu.co/moodle/pluginfile.php/56106/mod_resource/content/0/03_-_Arquitectura_Modelo_de_Referencia_OSI_TCP_IP.pdf
- <https://es.slideshare.net/kcfariam/dispositivos-y-protocolo-de-interconexion>
- <http://www.nmt.com.mx/blogposts/dominios-de-colision-y-broadcast.php>
- https://guimi.net/monograficos/G-Redes_de_comunicaciones/G-RCnode61.html
- <https://www.datacenterdynamics.com/es/opinion/los-nuevos-est%C3%A1ndares-de-centros-de-datos-tier-5/>
- <https://www.profesionalreview.com/2019/02/23/que-es-sai>
- https://es.wikipedia.org/wiki/Gestión_de_servicios_de_tecnologías_de_la_información



- <https://kueski.com/blog/finanzas-personales/emprender/outsourcing/>
- <https://es.wikipedia.org/wiki/Subcontratación>
- <https://asesneg.com.mx/insourcing-supuesto-la-subcontratacion-laboral/>
- https://es.wikipedia.org/wiki/Gobernanza_de_las_tecnolog%C3%ADas_de_la_informaci%C3%B3n
- <https://www.entrepreneur.com/article/360776>
- https://es.wikipedia.org/wiki/Gestión_de_servicios_de_tecnologías_de_la_información
- <https://es.sendinblue.com/blog/omnicanalidad-que-es/>
- <https://www.zendesk.es/blog/help-desk/>
- <https://www.zendesk.com.mx/blog/herramienta-de-ticketing/>
- <https://blog.comparasoftware.com/las-7-mejores-herramientas-de-ticketing/>
- <https://medac.es/blogs/educacion-infantil/las-herramientas-tic-en-la-educacion/>
- <https://i.ulatina.ac.cr/blog/qu3-son-las-tic-y-para-que-sirven>
- <https://tic.crue.org/wp-content/uploads/2016/03/transformacion-digital-univ.pdf>
- https://en.wikipedia.org/wiki/IT_service_management
- <https://www.servicetonic.com/es/itil/3-itil-conceptos-y-principios/#:~:text=ITIL%20es%20un%20conjunto%20de,en%20las%20operaciones%20de%20TI.>
- <https://www.servicetonic.com/es/itil/itil-v3-gestion-de-incidencias/>
- <https://www.splashtop.com/es/what-is-remote-access>
- <https://support.google.com/chrome/answer/1649523?co=GENIE.Platform%3DDesktop&hl=es-419>
- <https://www.xataka.com/basics/programas-escritorio-remoto>
- <https://www.adslzone.net/esenciales/windows-10/controlar-ordenador-remoto/>
- <https://es.wikipedia.org/wiki/Telnet>
- https://www.picasa.org/moodle/pluginfile.php/379/mod_resource/content/0/entrega4/e4_html/node177.html



- [https://es.wikipedia.org/wiki/Secure_Shell#:~:text=SSH%20\(o%20Secure%20Shell\)%20es, toda%20la%20informaci%C3%B3n%20est%C3%A1%20cifrada.](https://es.wikipedia.org/wiki/Secure_Shell#:~:text=SSH%20(o%20Secure%20Shell)%20es, toda%20la%20informaci%C3%B3n%20est%C3%A1%20cifrada.)
- https://es.wikipedia.org/wiki/Wake_on_LAN
- <http://cursoadministracionderedes.blogspot.com/2014/02/tecnologia-wake-on-lan.html>
- <https://ccnadesdezero.es/mejores-herramientas-wake-on-lan/>
- https://en.wikipedia.org/wiki/Intel_Active_Management_Technology
- https://en.wikipedia.org/wiki/Metasploit_Project
- <https://www.dmtf.org/standards/redfish>
- <https://en.wikipedia.org/wiki/TLS-PSK>
- <https://soporte.proitsecurity.cl/knowledgebase.php?article=36#:~:text=>
- <https://blog.asiaqualityfocus.com/es/proveedores-oem-y-odm-en-que-se-diferencian/>
- https://en.wikipedia.org/wiki/Intel_Management_Engine
- https://en.wikipedia.org/wiki/Intel_Management_Engine#Security_vulnerabilities